



Safety and Security of Artificial Intelligence Systems

Australia • Canada • European Union • New Zealand
United Kingdom

July 2023

LL File No. 2023-022302
LRA-D-PUB-002615

This report is provided for reference purposes only.
It does not constitute legal advice and does not represent the official
opinion of the United States Government. The information provided
reflects research undertaken as of the date of writing.
It has not been updated.

Contents

Comparative Summary 1

Figure 1: Types of Legislation Related to AI by Jurisdiction 3

Australia 4

Canada 25

European Union 35

New Zealand 52

United Kingdom 66

Table:

Table of Primary Sources 89

Comparative Summary

Jenny Gesley
Foreign Law Specialist

This report surveys the safety and security of artificial intelligence systems (AI systems) in five selected jurisdictions, namely **Australia**, **Canada**, **New Zealand**, the **United Kingdom (UK)**, and the **European Union (EU)**.

The use of AI has increased exponentially and is permeating every aspect of our lives, from personal to professional. While it can be used in many positive ways to solve global challenges, there are also security risks to be considered, such as fundamental rights infringements, personal data security, and harmful uses. The European Union Agency for Cybersecurity (ENISA) has identified three dimensions to the relationship between cybersecurity and AI. First, there is the cybersecurity of AI, meaning a lack of robustness and the vulnerabilities of AI models and algorithms. Second, AI can also support cybersecurity when it is used as a tool or means to create advanced cybersecurity, such as by developing more effective security controls and by facilitating the efforts of law enforcement and other public authorities to respond to cybercrime. Lastly, there is the malicious use of AI, meaning when AI is used in a harmful, malicious, or adversarial way to create more sophisticated types of attacks.¹ This report focuses on the first dimension.

In order to ensure that AI systems are used to benefit society, jurisdictions around the world are looking into ways to regulate AI. Whereas the **EU** intends to adopt its legislative proposal for a specific Artificial Intelligence Act (draft AI Act) by the end of 2023 and the **Canadian** government introduced an Artificial Intelligence and Data Act (AIDA) in June 2022, other surveyed jurisdictions have not yet advanced similar legislation. Both **Australia** and **New Zealand** do not currently have laws or proposed specific laws related to AI. However, a May 2023 discussion paper published by the **Australian** government seeks public feedback on possible policy and regulatory responses to AI, including the adoption of a risk-based approach similar to the EU draft AI Act. Likewise, the **UK** has not passed AI-specific legislation and does not intend to do so currently, but might at a later stage “enhance regulatory powers, ensure regulatory coordination, or create new institutional architecture.” Currently, there are 18 legal frameworks containing over 50 pieces of legislation that touch upon AI in the **UK**. Figure 1 below depicts types of AI-related legislation by jurisdiction.

There is no universal definition of an “AI system.” The **European Parliament**, in its amendments to the draft AI Act, proposes to align its definition with that of the OECD. An AI system is accordingly defined as “a machine-based system that is designed to operate with varying levels of autonomy and that can, for explicit or implicit objectives, generate outputs such as predictions, recommendations, or decisions, that influence physical or virtual environments.” **Canada’s** proposed AIDA defines an AI system in a similar way with a few minor variations. The **UK** acknowledged the EU’s definition, but criticized it for not capturing the full application of AI and its regulatory implications. It stated that “no single definition is going to be suitable for every

¹ ENISA, Cybersecurity of AI and Standardisation 10 (Mar. 14, 2023), para. 2.2, <https://perma.cc/TL52-PFMG>.

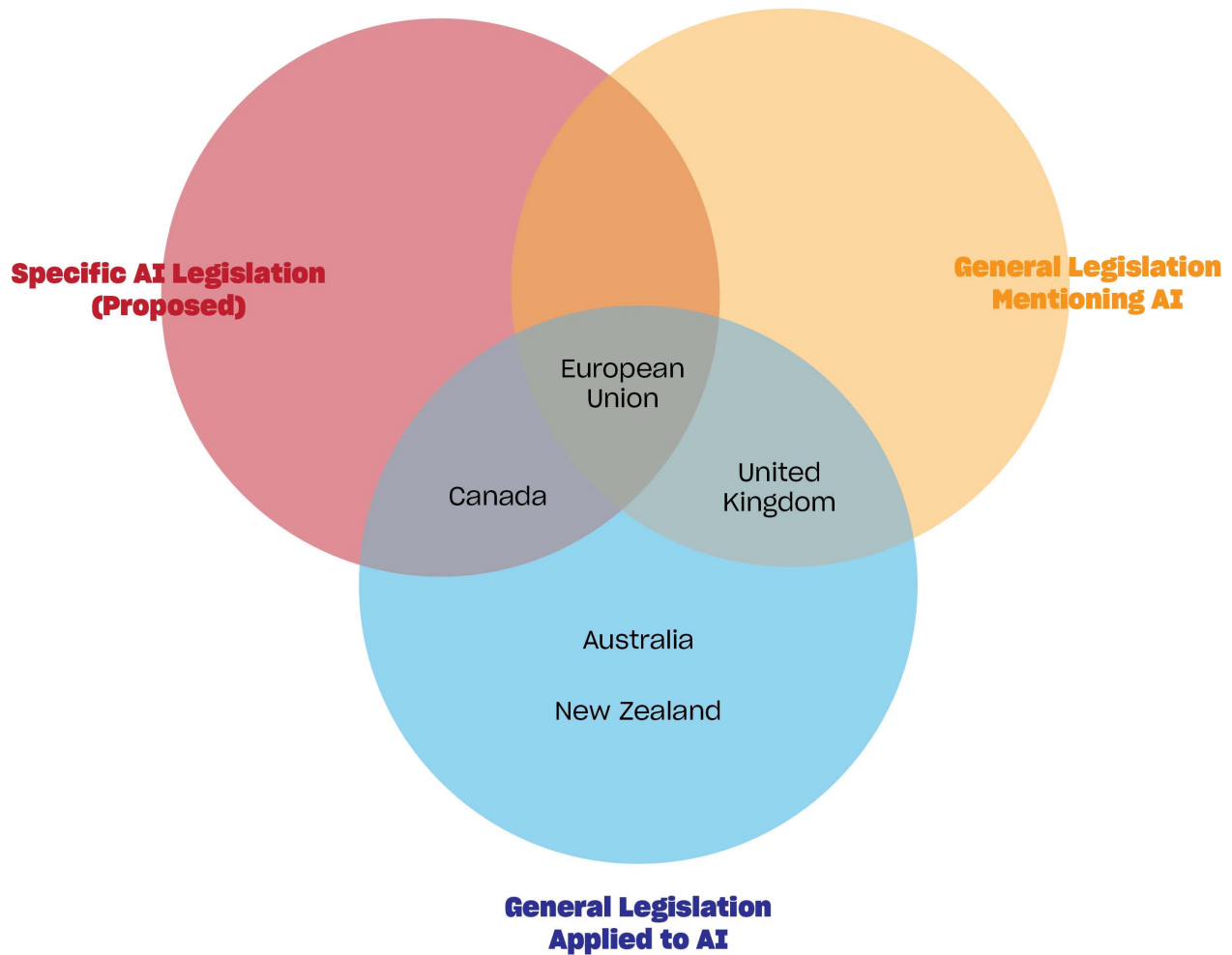
scenario.” **Australia** and **New Zealand** do not have a legal definition of AI, but various public and private sector bodies have provided definitions in documents that discuss AI.

The proposed **EU** draft AI Act contains specific security requirements for AI systems that would qualify as high-risk, in particular registration in an EU Database for Stand-Alone High-Risk AI Systems and compliance with detailed mandatory requirements with regard to risk management systems; the quality of data sets used; technical documentation; record keeping; transparency and provision of information to users; human oversight; appropriate levels of accuracy, robustness, and cybersecurity; quality management systems; and ex-ante conformity assessment. The proposed bill in **Canada** contains similar security requirements, with the exception of provisions on quality management systems and appropriate levels of robustness. They appear to reflect those in the US National Institute of Standards and Technology’s AI Risk Management Framework 1.0. In addition, there is a Directive on Automated Decision-Making that requires all automated decisions by federal institutions to be subject to an algorithmic impact assessment. **Australia** and **New Zealand** have several technology-neutral general statutes and guidance documents that address aspects of cybersecurity that are not specific to AI systems. In the **UK**, an impact assessment found that there are “key gaps in the UK’s current legal frameworks relate[d] to individual rights, safety standards specific to AI, transparency, human involvement, accountability, and rights to redress.”

With regard to security of personal data, the **EU**’s General Data Protection Regulation (GDPR) makes security of personal data a prerequisite for the processing of personal data and requires controllers to apply the principles of security by design and by default. The **UK** incorporated the EU GDPR into its national law through the Data Protection Act 2018 (DPA). The DPA, together with other EU legislation, was incorporated into a new body of domestic law after the UK left the EU. In **Canada**, in addition to the federal Personal Information Protection and Electronic Documents Act, the proposed bill would, among other things, require covered people to “establish measures with respect to the manner in which data is anonymized” and “establish measures with respect to the management of anonymized data.” As mentioned, **Australia**’s Privacy Act 1988 (Cth) and **New Zealand**’s Privacy Act 2020 are technology-neutral and apply to AI systems. Guidance by the Office of the **Australian** Information Commissioner regarding data analytics recommends, among other things, using de-identified data wherever possible, taking a privacy-by-design approach, and protecting information in line with risk assessments. In **New Zealand**, the Privacy Commissioner expects entities implementing generative AI tools to, for example, conduct privacy impact assessments, be transparent, and ensure human review.

With regard to AI security policy across the supply chain, no concrete AI-specific measures have been implemented by the surveyed jurisdictions. However, the **EU**’s **ENISA** noted that the AI-related supply chain issue is one of the challenges for cybersecurity. Likewise, the **UK** government stated that “AI supply chains can be complex and opaque, making effective governance of AI and supply chain risk management difficult.” It added, however, that it is too soon to introduce new measures to regulate the AI supply chain.

Figure 1: Types of Legislation Related to AI by Jurisdiction



Australia

Kelly Buchanan
Chief, Foreign, Comparative, and
International Law Division II

SUMMARY Australia does not currently have specific laws related to artificial intelligence (AI). However, a discussion paper published in May 2023 seeks public feedback on possible policy and regulatory responses to AI, including the adoption of a risk-based approach similar to that developed in the European Union and Canada. In addition, various work has been undertaken in the public and private sectors related to AI regulation and development, including the publication of an AI ethics framework in 2019 and the establishment of a national AI center and a Responsible AI Network to provide guidance to Australian businesses, as well as discussion and guidance regarding general and sector-specific laws and their application to AI. Existing laws relevant to the regulation of AI include, for example, privacy legislation, telecommunications law, legislation related to the protection of critical infrastructure, consumer protection law, and anti-discrimination legislation. A recent report on reforming the federal privacy statute made recommendations on the regulation of automated decision-making under that law.

In terms of cybersecurity of AI, there are various laws and government documents that may be relevant. The government is considering the development of new cybersecurity legislation that would harmonize the existing “patchwork” of laws, policies, and frameworks, as well as possible amendments to critical infrastructure legislation that would bring customer data and “systems” into the definition of critical assets.

Relevant government agencies have engaged with international partners on cybersecurity guidance relevant to AI and on the development of AI-related standards.

I. Introduction

Australia does not currently have specific legislation or provisions that regulate artificial intelligence (AI).¹ Both the current and previous government have engaged in discussions regarding the AI policy and regulatory framework.² There has been a focus in recent years on developing a self-regulatory, principles-based approach, including the development of ethics principles and the establishment of a Responsible AI Network to guide AI adoption among

¹ See Lachlan Mee, *Regulating Artificial Intelligence in Australia*, LinkedIn (Oct. 7, 2022), <https://perma.cc/58LR-EPBN>; Kim O’Connell et al., *Developments in the Regulation of Artificial Intelligence*, KWM (Apr. 19, 2023), <https://perma.cc/J6D4-2968>.

² See generally Dudley Kneller, *A Change in Government May Put the Brakes on Australia’s Support of AI and ADM? Or Perhaps Not?*, Gadens (July 18, 2022), <https://perma.cc/7CBZ-28DT>.

Australian businesses. However, on May 31, 2023, the government released a discussion paper, *Safe and Responsible AI in Australia*,³ that

focuses on governance mechanisms to ensure AI is developed and used safely and responsibly in Australia. These mechanisms can include regulations, standards, tools, frameworks, principles and business practices.⁴

The government is seeking feedback on the options presented in the paper through a submission process, closing on July 26, 2023, to inform “consideration across government on any appropriate regulatory and policy responses” to AI.⁵

In addition, on June 1, 2023, the National Science and Technology Council published a research report on generative AI, which was commissioned by the government.⁶ The report included “examples of strategies that have been put in place internationally by other advanced economies since the launch of models like ChatGPT to address the potential opportunities and impacts of artificial intelligence (AI).”⁷

Previously, in March 2022, the Department of the Prime Minister and Cabinet’s Digital Technology Taskforce published a paper for consultation, *Positioning Australia as a Leader in Digital Economy Regulation (Automated Decision Making and AI Regulation): Issues Paper*.⁸ The submission process closed in May 2022,⁹ but the new government, elected that same month, does not appear to have taken further action related to the paper.

In 2021, the government released Australia’s *Digital Economy Strategy*, which included a vision for Australia to be a top 10 digital economy by 2030.¹⁰ Also in 2021, the government published its *AI Action Plan*, which “set out a vision for Australia to be a global leader in developing and adopting trusted, secure and responsible AI.”¹¹ Both of these documents were published under the previous government and have been removed from current departmental websites.

³ Department of Industry, Science and Resources, *Safe and Responsible AI in Australia: Discussion Paper* (June 2023), <https://perma.cc/GW2C-NC75>; Press Release, Ed Husic, Safe and Responsible AI (June 1, 2023), <https://perma.cc/BT7T-QW9U>; Jake Evans, *Artificial Intelligence Technologies Could be Classified by Risk, As Government Consults on AI Regulation*, ABC News (May 31, 2023), <https://perma.cc/64XT-U8NX>.

⁴ *Supporting Responsible AI: Discussion Paper*, Department of Industry, Science and Resources, <https://perma.cc/F4KF-SSMA>.

⁵ Id.

⁶ *Rapid Response Information Report: Generative AI*, Australia’s Chief Scientist (June 1, 2023), <https://perma.cc/N4BZ-23DX>.

⁷ Id.

⁸ Australian Government, *Positioning Australia as a Leader in Digital Economy Regulation – Automated Decision Making and AI Regulation: Issues Paper* (Mar. 2022), <https://perma.cc/QB3A-7KE3>.

⁹ *Positioning Australia as a Leader in Digital Economy Regulation (Automated Decision Making and AI Regulation): Issues Paper*, Department of Industry, Science and Resources, <https://perma.cc/6U66-8WUH>.

¹⁰ Australian Government, *Digital Economy Strategy 2030* (2021), <https://perma.cc/4A8U-CBWF>.

¹¹ See *Australia’s Artificial Intelligence Action Plan*, Department of Industry, Sciences and Resources (archived page), <https://perma.cc/BQ4J-FHEW>.

In recent years, several policy and investment initiatives have commenced in relation to AI, including:

- Publication of Australia's "AI Ethics Framework" in 2019¹²
- Development of a "List of Critical Technologies in the National Interest,"¹³ which includes AI technologies¹⁴
- Becoming a founding member of the Global Partnership on Artificial Intelligence¹⁵
- Government funding for programs and grants to support businesses to "integrate quantum and artificial intelligence technologies into their operations"¹⁶
- The "Next Generation AI and Emerging Technologies Graduates" national scholarship program¹⁷

The 2023 discussion paper provides an overview of current federal government initiatives relevant to the "development, application or deployment of AI."¹⁸

State and territory governments are also considering the implications of AI for their own policy and regulatory frameworks. However, such work is not covered in this report.

II. Overview of the Legal and Policy Framework

A. Relevant Laws and Possible AI Legislation

Current Commonwealth (i.e. federal) laws relevant to AI, including cybersecurity¹⁹ of AI, include:

¹² *Australia's Artificial Intelligence Ethics Framework*, Department of Industry, Science and Resources (Nov. 7, 2019), <https://perma.cc/Z7UP-7R5L>.

¹³ *List of Critical Technologies in the National Interest*, Department of Industry, Science and Resources (May 19, 2023), <https://perma.cc/B758-QPXY>.

¹⁴ *List of Critical Technologies in the National Interest: AI Technologies*, Department of Industry, Science and Resources, <https://perma.cc/3WAS-MD5S>.

¹⁵ *The Global Partnership on Artificial Intelligence Launches*, Department of Industry, Science and Resources (June 16, 2020), <https://perma.cc/2KVE-SKPN>.

¹⁶ *Investments to Grow Australia's Critical Technologies Industries*, Department of Industry, Science and Resources (May 12, 2023), <https://perma.cc/V863-6PJ5>. Information on funding initiatives under the previous government is available at *Funding Available for AI and Digital Capability Centres*, Department of Industry, Science and Resources (Mar. 31, 2022), <https://perma.cc/RQU2-F9Q2>.

¹⁷ *Next Generation AI and Emerging Technologies Graduates Program*, CSIRO, <https://perma.cc/WF3A-VEMY>.

¹⁸ *Safe and Responsible AI in Australia: Discussion Paper*, *supra* note 3, at 15 & attachment A.

¹⁹ See Dennis Miralis et al., *Australia*, in *Cybersecurity 2023* (ICLG, 2023), <https://perma.cc/38UH-B72B>.

- Privacy Act 1988 (Cth)²⁰
- Security of Critical Infrastructure Act 2018 (Cth)²¹ (SOCI Act)
- Telecommunications Act 1997 (Cth)²²
- Telecommunications (Interception and Access) Act 1979 (Cth)²³
- Criminal Code Act 1995 (Cth)²⁴
- Corporations Act 2001 (Cth)²⁵

Other general laws that could be relevant include consumer protection legislation, copyright legislation, online safety legislation, anti-discrimination legislation, administrative law, and common law related to tort and contract.²⁶ In addition, sector-specific regulations that may apply include those related to therapeutic goods, food, motor vehicles, airline safety, and financial services.²⁷ The 2023 *Safe and Responsible AI in Australia* discussion paper states that “[t]hese are areas where the government has deemed specific sector-specific laws are necessary,” which “need to be well designed to avoid duplicating economy-wide regulations while filling in any gaps appropriate to AI.”²⁸

The discussion paper notes that “the process of applying or adjusting” existing regulatory frameworks is already under way.”²⁹ This includes the implementation of the Online Safety Act 2021 (Cth), which contains provisions on cyberbullying, image-based abuse, and the removal of illegal and harmful online content; the publication of guidance on software as a medical device; a determination by the Office of the Australian Information Commissioner (OAIC) regarding Clearview AI’s gathering and use of biometric information for a facial recognition tool; new laws to provide regulators with powers to combat online misinformation and disinformation, which

²⁰ Privacy Act 1988 (Cth), <https://perma.cc/TP5W-Z238>.

²¹ Security of Critical Infrastructure Act 2018 (Cth), <https://perma.cc/QX3Y-QZHL>.

²² Telecommunications Act 1997 (Cth), <https://perma.cc/P85S-MMK8> (vol 1), <https://perma.cc/ET5H-TFCF> (vol 2).

²³ Telecommunications (Interception and Access) Act 1979 (Cth), <https://perma.cc/42DG-GN2G>.

²⁴ Criminal Code Act 1995 (Cth), <https://perma.cc/9YWA-732B>. Part 10.7 of the code contains computer offenses.

²⁵ Corporations Act 2001 (Cth) s 180, <https://perma.cc/5S7W-CTXW>. Commentators explain that “[a] failure by a company to prevent, mitigate, manage or respond to [a cybersecurity] Incident may result in breaches of provisions of the *Corporations Act 2001* (Cth). The *Corporations Act 2001* (Cth) imposes duties on directors to exercise powers and duties with the care and diligence that a reasonable person would. A director who ignores the real possibility of an Incident may be liable for failing to exercise their duties with care and diligence.” Miralis, *supra* note 19.

²⁶ *Safe and Responsible AI in Australia: Discussion Paper*, *supra* note 3, at 10.

²⁷ *Id.*

²⁸ *Id.*

²⁹ *Id.*

were announced in January 2023; and the review of the Privacy Act (further discussed below, Part IV.D).³⁰

Through the consultation process related to the discussion paper the government is seeking to “identify potential gaps in the existing domestic governance landscape and any possible additional AI governance mechanisms to support the development and adoption of AI.”³¹ The paper specifically seeks feedback on a possible risk management approach for AI, “which builds on the EU’s proposed AI Act and Canada’s directive.”³² It notes that “[t]here is a developing international direction towards a risk-based approach for governance of AI,”³³ and that there is a need to “ensure there are appropriate safeguards, especially for high-risk applications of AI and ADM.”³⁴

According to some legal commentators, writing prior to the release of the discussion paper, “[t]he expectation is that a dedicated AI law will be introduced in Australia which will at least address the concerns raised by the [Australian Human Rights Commission (HRC)] and other government and industry body reports.”³⁵ Furthermore, “[i]t may well be that the regulation of AI in Australia will be modelled off the EU’s AI Act and will adopt a similar risk-based approach which prescribes certain requirements based on the degree of risk the relevant AI system presents, and the industry in which the AI system is deployed.”³⁶ The same commentators suggest that “[f]uture AI laws in Australia will likely include robust and prescriptive requirements with respect to transparency, and the degree to which decisions made by AI systems can be explained which are integral to this evaluative process.”³⁷

A recent survey of the Australian public found that “Australians expect AI to be regulated and want an independent regulator to monitor the technology as it booms into mainstream society.”³⁸ The Australian Information Industry Association noted the difficulty in regulating AI but said there was a need for “guidelines” and “guardrails,” that the absence of a specific policy on AI was a “major obstacle” to the sector, and that while existing laws could be used in cases where AI causes harm, those laws “do not ensure AI technologies are designed or used safely.”³⁹

³⁰ Id. at 11.

³¹ Id. at 4.

³² Id. at 31-32 & attachment C.

³³ Id. at 16.

³⁴ Id. at 26.

³⁵ Kit Lee & Philip Catania, *Australia*, in Comparative Guides: Artificial Intelligence, Global Legal Post (May 2023), <https://perma.cc/W7CS-LEZS>.

³⁶ Id.

³⁷ Id.

³⁸ Jake Evans, *Two-Thirds of Australians Say Not Enough Being Done to Protect from Unsafe AI, as Minister Called on to Act*, ABC News (Mar. 28, 2023), <https://perma.cc/NF79-FQ73>.

³⁹ Id.

B. Policies and Guidance of Relevant Agencies

There are several government agencies involved in promoting and regulating AI in Australia.

The Department of Industry, Science and Resources administers AI investment programs and provides advice to the government on relevant policies and legislation. It led the development of the 2023 discussion paper.

The National Artificial Intelligence Centre, coordinated by CSIRO (Australia's national science agency),⁴⁰ supports the Responsible AI Network⁴¹ and seeks to coordinate "Australia's expertise and capabilities for a strong, collaborative and focused AI ecosystem that benefits all Australians."⁴² In March 2023, the center published *Australia's AI Ecosystem Momentum Report*.⁴³ The center is coordinated by the Data61 Group, which is the "data and digital specialist arm" of CSIRO.⁴⁴ Data61 and the then-named Department of Industry, Innovation and Science developed the *Artificial Intelligence Roadmap* in 2019.⁴⁵

The Responsible AI Network seeks to provide clear guidance for industry on best practices, with "six actionable pillars": Law, Standards, Principles, Governance, Leadership, and Technology. CSIRO states that "[w]orldwide, Standards and regulatory changes are coming, which will require major upskilling and change for organisations to adapt to this new regulatory landscape."⁴⁶

The HRC has been active in advocating for the regulation of AI using a human rights approach.⁴⁷ It published its *Human Rights and Technology Final Report* in 2021, which contained several recommendations for regulating AI, including the establishment of an AI Safety Commissioner.⁴⁸

⁴⁰ National Artificial Intelligence Centre, CSIRO, <https://perma.cc/7P6C-FK8L>; *The National Artificial Intelligence Centre is Launched*, Department of Industry, Science and Resources (Dec. 14, 2021), <https://perma.cc/6WEP-X4BU>.

⁴¹ National AI Centre's Responsible AI Network, CSIRO, <https://perma.cc/QL9Q-EDTN>.

⁴² National Artificial Intelligence Centre, *supra* note 40.

⁴³ National Artificial Intelligence Centre, *Australia's AI Ecosystem Momentum* (Mar. 2023), <https://perma.cc/9QAU-QBLV>.

⁴⁴ Data61 Business Unit, CSIRO, <https://perma.cc/27EX-394U>. See also *Artificial Intelligence*, CSIRO, <https://perma.cc/86FS-CYN5>.

⁴⁵ *Artificial Intelligence Roadmap*, CSIRO, <https://perma.cc/9LLZ-SDZQ>; CSIRO Data61, *Artificial Intelligence: Solving Problems, Growing the Economy and Improving Our Quality of Life* (2019), <https://perma.cc/XB7W-J5F5>.

⁴⁶ National AI Centre's Responsible AI Network, *supra* note 41.

⁴⁷ See, e.g., Australian Human Rights Commission, *Human Rights in the Digital Age: Additional Material Submitted to the UN Global Digital Compact 12 – 17* (Submission to the United Nations' Office of the Secretary-General's Envoy on Technology, Apr. 30, 2023), <https://perma.cc/6VUC-Y9BT>.

⁴⁸ Australian Human Rights Commission, *Human Rights and Technology: Final Report* (2021), <https://perma.cc/TPD5-LDNW>.

It previously published the *Artificial Intelligence: Governance and Leadership Whitepaper* in 2019⁴⁹ and a technical paper titled *Using Artificial Intelligence to Make Decisions: Addressing the Problem of Algorithmic Bias* in 2020.⁵⁰

Other agencies have examined and provided guidance on the use of AI in different regulatory contexts:

- The Australian Securities and Investments Commission (ASIC) has published “cyber resilience good practices”⁵¹ and a regulatory guide on the provision of automated financial product advice to retail clients using algorithms and technology.⁵² ASIC’s 2022-23 priorities for the supervision of market intermediaries includes “undertaking a thematic review of artificial intelligence/machine learning (AI/ML) practices and associated risks and controls among market intermediaries and buy-side firms, including the implementation of AI/ML guidance issued by the International Organization of Securities Commissions (IOSCO).”⁵³
- In 2020, the Australian Competition and Consumer Commission (ACCC) commenced its Digital Platform Services Inquiry, which is expected to be completed in 2025.⁵⁴ It has published several consultation papers and interim reports. Most recently, in March 2023, it published an issues paper on the “expanding ecosystems of digital platform providers in Australia,” which will be the focus of its seventh interim report to be published in September 2023.⁵⁵ The issues paper discusses the impact of large providers of digital platform services expanding into different sectors and technologies, including AI (although the focus of the paper is on smart home devices and cloud storage and computing), including increased risk of potential consumer and competition issues arising from this.⁵⁶

⁴⁹ Australian Human Rights Commission, *Artificial Intelligence: Governance and Leadership Whitepaper* (2019), <https://perma.cc/YR7W-7EM3>.

⁵⁰ Australian Human Rights Commission, *Using Artificial Intelligence to Make Decisions: Addressing the Problem of Algorithmic Bias Technical Paper* (2020), <https://perma.cc/8CW8-2XUT>.

⁵¹ *Cyber Resilience Best Practices*, Australian Securities and Exchange Commission, <https://perma.cc/B2W3-NCD2>.

⁵² Australian Securities and Exchange Commission, *Providing Digital Financial Product Advice to Retail Clients* (Regulatory Guide 255, Aug. 2016), <https://perma.cc/5P6T-3WPT>.

⁵³ ASIC’s *Priorities for the Supervision of Market Intermediaries in 2022–23*, Australian Securities and Exchange Commission, <https://perma.cc/MSY8-W8GU>.

⁵⁴ *Digital Platform Services Inquiry 2020-25*, Australian Competition and Consumer Commission, <https://perma.cc/5685-6RV9>.

⁵⁵ Id. See also Justin Hendry, *ACCC to Probe Big Tech’s Growing ‘Web’*, InnovationAus.com (Mar. 8, 2023), <https://perma.cc/R4B9-3QRQ>.

⁵⁶ Australian Competition and Consumer Commission, *Digital Platform Services Inquiry – September 2023 Report on the Expanding Ecosystems of Digital Platform Service Providers: Issues Paper* (Mar. 2023), <https://perma.cc/UZJ5-YC4B>.

- The National Transport Commission published a paper on *The Regulatory Framework for Automated Vehicles in Australia* in February 2022, which presented “proposals on the end-to-end regulatory framework for the commercial deployment of automated vehicles.”⁵⁷
- Standards Australia published a report titled *An Artificial Intelligence Standards Roadmap: Making Australia’s Voice Heard*,⁵⁸ which set out recommendations related to ensuring Australia can effectively influence AI standards development globally and that AI-related standards are developed in a way that takes into account diversity and inclusion, ensures fairness, and builds social trust.⁵⁹
- The Office of the Australian Information Commissioner (OAIC), among other relevant activities, has made various submissions as part of consultation processes related to the regulation of AI. These include submissions on the HRC’s 2019 whitepaper (expressing the view that “there is scope within the existing regulatory framework, with appropriate adjustments, to increase accountability in the use of AI and related technology and to ensure effective oversight”⁶⁰) and on the HRC’s 2020 human rights and technology discussion paper (stating that it considers “data protection [to be] a central pillar of this regulatory approach which provides a framework for addressing many issues highlighted in the discussion paper”⁶¹), as well as on the discussion paper on the AI ethics framework (in which it suggested that “further consideration should be given to the suitability of adopting some EU GDPR rights in the Australian context where gaps are identified in relation to emerging and existing technologies, including AI”⁶²).
- The Therapeutic Goods Administration (TGA) has published guidance on the regulation of software-based medical devices, including artificial intelligence text-based products, stating that these “may be subject to medical device regulations for software and need approval by the TGA.”⁶³ It has also published medical device cyber security guidance for industry, which is intended for “manufacturers that develop software for use in or as standalone medical devices, such as in Software as a Medical Device (SaMD); this includes devices that

⁵⁷ National Transport Commission, *The Regulatory Framework for Automated Vehicles in Australia* 2 (Feb. 2022), <https://perma.cc/B3AE-BHH2>.

⁵⁸ Standards Australia, *An Artificial Intelligence Standards Roadmap: Making Australia’s Voice Heard* (Mar. 2020), <https://perma.cc/ULQ7-T456>.

⁵⁹ *Standards Australia Sets Priorities for Artificial Intelligence*, Standards Australia (Mar. 12, 2020), <https://perma.cc/WA8L-9A58>.

⁶⁰ Office of the Australian Information Commissioner (OAIC), *Artificial Intelligence: Governance and Leadership White Paper – Submission to the Australian Human Rights Commission* (June 19, 2019), <https://perma.cc/G99Z-JSGY>.

⁶¹ OAIC, *Human Rights and Technology Discussion Paper – Submission to the Australian Human Rights Commission* (July 6, 2020), <https://perma.cc/VKC2-2XL8>.

⁶² OAIC, *Artificial Intelligence: Australia’s Ethics Framework – Submission to the Department of Industry, Innovation and Science and Data* 61 (June 24, 2019), <https://perma.cc/VR2B-K466>.

⁶³ *Regulation of Software Based Medical Devices*, Therapeutic Goods Administration (last updated June 2, 2023), <https://perma.cc/L9D3-XYH6>.

incorporate artificial intelligence in their design.”⁶⁴ The TGA in addition has published cyber security information for users of medical devices.⁶⁵

- The Office of the Commonwealth Ombudsmen has published the *Automated Decision-Making: Better Practice Guide*,⁶⁶ which provides guidance to government agencies.
- The Australian Communications and Media Authority (ACMA) published an occasional paper on artificial intelligence in communications and the media in 2020 which examined
 - > the implementation of ethical principles in communications and media markets
 - > potential risks to consumers in interacting with automated customer service agents
 - > the challenge of misinformation risks associated with online “filter bubbles” and content personalisation, including to diversity in individuals’ news consumption
 - > how AI may be used in unsolicited communications and by scammers
 - > developments in technical standardisation
 - > how AI could change the spectrum environment⁶⁷

III. Definition of AI Systems

There is no definition of AI or AI systems in Australia’s legislation. Most recently, the *Safe and Responsible AI in Australia* paper states that AI

refers to an engineered system that generates predictive outputs such as content, forecasts, recommendations or decisions for a given set of human-defined objectives or parameters without explicit programming. AI systems are designed to operate with varying levels of automation.⁶⁸

IV. Cybersecurity of AI

As stated above, there are no specific rules or requirements related to AI in Australian legislation, including with respect to cybersecurity. Entities in both the public and private sectors have obligations placed on them regarding data protection, risk management, and incident reporting. There are also principles, guidance documents, and strategies developed by government agencies that are relevant to ensuring the protection of AI data and systems. As also noted above, authorities that regulate particular sectors or entities, such as ASIC and the TGA, have issued their own guidance on cybersecurity or cyber resilience.

⁶⁴ *Medical Device Cyber Security Guidance for Industry*, Therapeutic Goods Administration (Apr. 8, 2021; last updated Nov. 24, 2022), <https://perma.cc/R6VS-RBY2>.

⁶⁵ *Medical Device Cyber Security Information for Users*, Therapeutic Goods Administration (Apr. 8, 2021; last updated Nov. 24, 2022), <https://perma.cc/TYF7-6HKN>.

⁶⁶ Commonwealth Ombudsman, *Automated Decision-Making: Better Practice Guide* (2020), <https://perma.cc/X7QM-2JE4>.

⁶⁷ Australian Communications and Media Authority, *Artificial Intelligence in Communications and Media: Occasional Paper 2* (July 2020), <https://perma.cc/S8DR-GEH6>.

⁶⁸ *Safe and Responsible AI in Australia: Discussion Paper*, *supra* note 3, at 5.

There are several government agencies with responsibilities related to cybersecurity. The Cyber and Infrastructure Security Centre (CISC), part of the Department of Home Affairs, commenced operations in 2021.⁶⁹ Under the current government, the position of Coordinator for Cyber Security was established in February 2023. It is to be supported by the National Office for Cyber Security and the Cyber and Infrastructure Security Group, both within the Department of Home Affairs.⁷⁰ The aim is to “ensure a centrally coordinated approach,” including “triaging” action after a major incident.⁷¹

In addition, the Australian Cyber Security Centre (ACSC) sits within the Australian Signals Directorate, the agency responsible for electronic and communications intelligence and security. The ACSC includes staff from several agencies and “is a hub for private and public sector collaboration and information-sharing on cyber security, to prevent and combat threats and minimise harm to Australians.”⁷²

A. Cyber Security Strategy and Possible Cyber Security Act

In late 2022, the government appointed a Cyber Security Strategy Expert Advisory Board, which is responsible for developing a new national cybersecurity strategy.⁷³

In early 2023, the advisory board published a discussion paper on the 2023-2030 Australian Cyber Security Strategy,⁷⁴ with submissions closing in April 2023.⁷⁵ Previous strategies were published in 2016 and 2020, and the latter was complemented by *Australia's 2021 International Cyber and Critical Technology Engagement Strategy*. However, the current government decided to replace the 2020 strategy with a new seven-year strategy to be completed in 2023.⁷⁶ This strategy will progress in parallel with other activities, including the Privacy Act review (discussed below), the digital platform services inquiry, and the National Plan to Combat Cybercrime.⁷⁷

⁶⁹ *What is the Cyber and Infrastructure Security Centre*, Cyber and Infrastructure Security Centre (CISC), <https://perma.cc/E7QF-EHP4>.

⁷⁰ David McGovern, *Privacy, Digital Safety and Cyber Security: Budget Resources* (Australian Parliamentary Library, Budget Review 2023-24, May 2023), <https://perma.cc/37CH-C6SS>.

⁷¹ Michelle Grattan, *Albanese Government to Appoint Coordinator for Cyber Security, Amid Increasing Threat to Systems and Data*, *The Conversation* (Feb. 26, 2023), <https://perma.cc/YEP7-K67J>.

⁷² *Cyber Security*, Australian Signals Directorate, <https://perma.cc/476B-Y26W>.

⁷³ *Id.*

⁷⁴ Expert Advisory Panel, *2023–2030 Australian Cyber Security Strategy: Discussion Paper* (Feb. 2023), <https://perma.cc/CY6J-QSHV>.

⁷⁵ *2023-2030 Australian Cyber Security Strategy Discussion Paper*, Department of Home Affairs, <https://perma.cc/XL73-DWCN>.

⁷⁶ Denham Sadler, *Govt to Appoint Cyber Leader to Run New Office*, *ACS InformationAge* (Feb. 28, 2023), <https://perma.cc/KZY7-U56Q>.

⁷⁷ Expert Advisory Panel, *supra* note 74, at 14.

The government has stated that it has a goal of Australia becoming the most cyber secure nation by 2030.⁷⁸ In February 2023, the prime minister said that “government policies and regulations, business sector systems and measures and our general awareness and capacity as a nation are simply not at the level that we need them to be.”⁷⁹ The government has said that its priorities for a new cyber security policy include “increasing whole-of-nation protection efforts, ensuring critical infrastructure and government systems are resilient, building sovereign capabilities to tackle cyber threats, strengthening international engagement, and growing a national cyber workforce.”⁸⁰

The 2023 discussion paper refers to “enhancing and harmonising” the regulatory frameworks for cybersecurity:

We have heard from industry that business owners often do not feel their cyber security obligations are clear or easy to follow, both from an operational perspective and as company directors. There are a range of implicit cyber security obligations placed on Australian businesses and nongovernment entities, including through the corporations, consumer, critical infrastructure, and privacy legislative and regulatory frameworks. However, it is clear from stakeholder feedback and the increasing frequency and severity of major cyber incidents, that more explicit specification of obligations, including some form of best practice cyber security standards, is required across the economy to increase our national cyber resilience and keep Australians and their data safe.

To be the most cyber secure nation in the world by 2030, Australians should have confidence that digital products and services sold are fit for purpose and include appropriate best practice cyber security protections.

There may also be opportunities to simplify and streamline existing regulatory frameworks. For example, stakeholders have encouraged government to streamline reporting obligations and response requirements following a major cyber incident.

It is clear that a package of regulatory reform is necessary. How this would be implemented, including the potential consideration of a new *Cyber Security Act*, drawing together cyber-specific legislative obligations and standards across industry and government, and the details of these reforms is something on which feedback will be welcomed. This should also consider whether further developments to the SOCI Act are warranted, such as including customer data and ‘systems’ in the definition of critical assets to ensure the powers afforded to government under the SOCI Act extend to major data breaches such as those experienced by Medibank and Optus, not just operational disruptions.⁸¹

Upon the release of the discussion paper, at a roundtable meeting on cybersecurity, the Minister for Home Affairs said that “Australia has a patchwork of policies, laws and frameworks that are

⁷⁸ Cameron Abbott & Rob Pulham, *Australia to be the Most Security Cyber Nation?*, National Law Review (Mar. 6, 2023), <https://perma.cc/NW42-S5CV>.

⁷⁹ Speech, Prime Minister, Cyber Security Roundtable (Feb. 27, 2023), <https://perma.cc/NFH2-EPGR>.

⁸⁰ Grattan, *supra* note 71.

⁸¹ Expert Advisory Panel, *supra* note 74, at 17.

not keeping up with the challenges presented by the digital age. Voluntary measures and poorly executed plans will not get Australia where we need to be to thrive in the contested environment of 2030.”⁸²

B. ACSC Information Security Manual

The Australian Cyber Security Centre produces the *Information Security Manual* (ISM). The purpose of the ISM, most recently published in March 2023, is to “outline a cyber security framework that an organisation can apply, using their risk management framework, to protect their systems and data from cyber threats.”⁸³ The manual is intended for chief information security officers, chief information officers, cyber security professionals, and information technology managers. It is not mandatory to comply with the ISM as a matter of law, unless legislation or a direction given under legislation compels compliance. The ACSC states that

[w]hile the ISM contains examples of when legislation or laws may be relevant for an organisation, there is no comprehensive consideration of such issues. When designing, operating and decommissioning systems, an organisation is encouraged to familiarise themselves with relevant legislation, such as the *Archives Act 1983*, *Privacy Act 1988*, *Security of Critical Infrastructure Act 2018* and *Telecommunications (Interception and Access) Act 1979*.⁸⁴

The ISM contains cyber security principles, which are grouped into four key activities: govern, protect, detect, and respond. The ACSC explains that “[a]n organisation should be able to demonstrate that the cyber security principles are being adhered to within their organisation.”⁸⁵

The ACSC further states that

[t]he risk management framework used by the ISM draws from National Institute of Standards and Technology (NIST) Special Publication (SCP) 800-37 Rev. 2, *Risk Management Framework for Information Systems and Organizations: A System Life Cycle Approach for Security and Privacy*. Broadly, the risk management framework used by the ISM has six steps: define the system, select controls, implement controls, assess controls, authorise the system and monitor the system.⁸⁶

C. Guidance on Cyber Supply Chain Risk Management

The ACSC has published specific guidance “to assist organisations in identifying risks associated with their use of suppliers, manufacturers, distributors and retailers (i.e. businesses that

⁸² Keely McDonough, *Australia to Overhaul Cyber Security Laws: The Legal Implications Coming Down the Line*, LSG Online (Mar. 6, 2023), <https://perma.cc/H5CM-K9JT>.

⁸³ *Information Security Manual (ISM)*, ACSC, <https://perma.cc/T5WX-BNPL>.

⁸⁴ *Using the Information Security Manual*, ACSC, <https://perma.cc/E83J-XYPL>.

⁸⁵ Id.

⁸⁶ Id.

constitute their cyber supply chain).”⁸⁷ This includes risks due to foreign control or interference, poor security practices, lack of transparency, access and privileges, and poor business practices.

In addition, the ACSC has published separate guidelines on procurement and outsourcing, stating that

[c]yber supply chain risk management activities should be conducted during the earliest possible stage of procurement of applications, ICT equipment and services. In particular, an organisation should consider the security risks that may arise as systems, software and hardware are being designed, built, stored, delivered, installed, operated, maintained and decommissioned. This includes identifying and managing jurisdictional, governance, privacy and security risks associated with the use of suppliers, such as application developers, ICT equipment manufacturers, service providers and other organisations involved in distribution channels.⁸⁸

The guidance cross-references particular parts of the ISM related to supply chain risk management.

D. Federal Privacy Act

1. Protection of Personal Information

The Privacy Act “regulates the way individuals’ personal information is handled.”⁸⁹ The responsibilities in the act apply to federal government agencies and to organizations with an annual turnover of more than AU\$3 million (about US\$1.98 million), as well as some small business operators, such as private sector health service providers and businesses that sell or purchase personal information. Some particular acts and practices of other small business operators are also covered.⁹⁰

The Australian Privacy Principles (APP) are the “cornerstone” of the privacy protection framework in the act. Entities covered by the act are referred to as “APP entities.”⁹¹ There are 13 APPs that govern standards, rights, and obligations in relation to

⁸⁷ *Identifying Cyber Supply Chain Risks*, ACSC (Jan. 7, 2021; last updated May 22, 2023), <https://perma.cc/LWX4-Y7Y8>.

⁸⁸ *Guidelines for Procurement and Outsourcing*, ACSC (Mar. 2, 2023), <https://perma.cc/P2GJ-KL85>.

⁸⁹ *Rights and Responsibilities*, Office of the Australian Information Commissioner (OAIC), <https://perma.cc/5GXF-GCK6>.

⁹⁰ *Id.*

⁹¹ *Read the Australian Privacy Principles*, OAIC, <https://perma.cc/6L9X-8BSN>. See also Privacy Act 1988 (Cth) s 6 (definitions of agency, organisation, APP entity).

- the collection, use and disclosure of personal information
- an organisation or agency's governance and accountability
- integrity and correction of personal information
- the rights of individuals to access their personal information.⁹²

The APPs are intended to be technology neutral. A breach of an APP can lead to regulatory action and penalties.⁹³

Broadly, APP entities must have a privacy policy; must only collect personal information that is reasonably necessary for, or directly related to, one of the entity's functions or activities; must not collect sensitive information without an individual's consent; must collect personal information only by lawful and fair means; must notify an individual of the collection of their personal information; must not use or disclose the information for a secondary purpose without the individual's consent; must take reasonable steps to ensure that the personal information held is up to date and complete; and must take reasonable steps to protect the information from misuse, interference, and loss, and from unauthorized access, modification, or disclosure. Further principles relate to individuals being able to access and correct information held about them.⁹⁴

The OAIC provides detailed guidelines on each of the APPs, including the mandatory requirements and how it will interpret the APPs. For example, for the APP on the security of personal information, the guidelines state that "reasonable steps" include, where relevant, taking steps and implementing strategies in relation to the following:

- governance, culture and training
- internal practices, procedures and systems
- ICT security
- access security
- third party providers (including cloud computing)
- data breaches
- physical security
- destruction and de-identification
- standards.⁹⁵

The OAIC has published guidance related to the use of data analytics and the APPs, which recommends that, for example, entities use de-identified data wherever possible; embed good privacy governance by taking a privacy-by-design approach; conduct privacy assessments for data analytics projects; be open and transparent about privacy practices; know what is being collected; and protect information in line with risk assessments.⁹⁶

⁹² *Australian Privacy Principles*, OAIC, <https://perma.cc/AUR6-CKDK>. See also Privacy Act 1988 (Cth) pt 3 div 2 & sch 1.

⁹³ *Australian Privacy Principles*, *supra* note 92.

⁹⁴ *Australian Privacy Principles Quick Reference*, OAIC, <https://perma.cc/EQR3-P387>.

⁹⁵ OAIC, *Australian Privacy Principles Guidelines: Privacy Act 1988*, para. 11.8 (Dec. 2022), <https://perma.cc/67VV-D9AE>.

⁹⁶ *Guide to Data Analytics and the Australian Privacy Principles*, OAIC (Mar. 21, 2018), <https://perma.cc/ZCB6-H33A>.

2. Notification of Data Breaches

The Notifiable Data Breaches Scheme was established by amendments made to the Privacy Act in 2017. Under this scheme, entities covered by the Privacy Act 1988 (Cth) are required to notify the OAIC and affected individuals of any “eligible data breach” as soon as practicable.⁹⁷ A notifiable breach is one that is likely to result in serious harm to an individual whose personal information is involved.⁹⁸

The OAIC handles complaints, conducts investigations, and takes other regulatory action in relation to data breaches.⁹⁹ Amendments to the act made in 2022 gave the office new powers to investigate and gather information related to privacy breaches and increased fines for companies that experience “serious” or “repeated” breaches.¹⁰⁰

3. Review of the Privacy Act

Automated decision-making (ADM) was considered as part of the government’s recently completed review of the Privacy Act 1988 (Cth).¹⁰¹ In February 2023, the *Privacy Act Review Report* was released,¹⁰² containing 116 proposals to reform the Privacy Act to “adequately protect Australians’ privacy in the digital age.”¹⁰³ The government is now considering its response to the report.¹⁰⁴

The report proposed new transparency requirements “for automated decisions that use personal information and have a significant effect on individuals. . . . Entities would need to provide information about types of personal information used in automated decision-making systems and how such decisions are made.”¹⁰⁵ The report specifically contained the following proposals:

Proposal 19.1 Privacy policies should set out the types of personal information that will be used in substantially automated decisions which have a legal or similarly significant effect on an individual’s rights.

⁹⁷ See *The Legal 500: Data Protection & Cyber Security Comparative Guide Australia*, Gilbert & Tobin (June 8, 2023), <https://perma.cc/EL8N-X4FG>. See also Privacy Act 1988 (Cth) pt 3C.

⁹⁸ *About the Notifiable Data Breaches Scheme*, OAIC, <https://perma.cc/J9XV-24HD>.

⁹⁹ Id. See also Privacy Act 1988 (Cth) pt 4.

¹⁰⁰ See Victoria Savage, *Everything You Need to Know About Australia’s New Cybersecurity Law*, LoginTC (Dec. 6, 2022), <https://perma.cc/4BEE-K7VR>; *Australian Government Serious About Data Privacy: Substantial Increases in Fines and Enhanced Regulatory Powers*, Jones Day (Jan. 2023), <https://perma.cc/CG33-CJPL>. See also Privacy Act 1998 (Cth) s 13G.

¹⁰¹ See *Review of the Privacy Act 1988*, Attorney-General’s Department, <https://perma.cc/X9KD-BP8Z>.

¹⁰² Attorney-General’s Department, *Privacy Act Review: Report 2022* (2022), <https://perma.cc/5XXE-8PPF>.

¹⁰³ *Privacy Act Review Report: Highlights and Hot Takes*, Gilbert & Tobin (Feb. 16, 2023), <https://perma.cc/LA7M-8N2N>.

¹⁰⁴ *Review of the Privacy Act 1988*, *supra* note 101.

¹⁰⁵ *Privacy Act Review: Report 2022*, *supra* note 102, at 3.

Proposal 19.2 High-level indicators of the types of decisions with a legal or similarly significant effect on an individual's rights should be included in the Act. This should be supplemented by OAIC Guidance.

Proposal 19.3 Introduce a right for individuals to request meaningful information about how substantially automated decisions with legal or similarly significant effect are made. Entities will be required to include information in privacy policies about the use of personal information to make substantially automated decisions with legal or similarly significant effect.

This proposal should be implemented as part of the broader work to regulate AI and ADM, including the consultation being undertaken by the Department of Industry, Science and Resources.¹⁰⁶

The report further stated that

[g]uidance should be provided to entities to clarify the meaning of 'substantially automated', which should not capture decisions where a human decision-maker has genuine oversight of a decision, reviews a decision before it is applied and has discretion to alter the decision. Consultation will be required to ensure the parameters of 'substantially automated' are appropriately calibrated.¹⁰⁷

It also explained how other current and proposed requirements in the Privacy Act "would also operate to safeguard the integrity of automated decisions through obligations relating to personal information used in ADM systems."¹⁰⁸ For example, "the obligation in APP 10 to take reasonable steps to ensure the accuracy and quality of personal information held by entities and the application of the fair and reasonable test may operate to require entities to monitor their ADM systems for bias where the decisions being made would significantly impact individuals."¹⁰⁹

E. AI Ethics Principles

The AI Ethics Principles are voluntary and intended to "be aspirational and complement – not substitute – existing AI regulations and practices."¹¹⁰ In summary, the principles cover the following matters:

- **Human, societal and environmental wellbeing:** AI systems should benefit individuals, society and the environment.
- **Human-centred values:** AI systems should respect human rights, diversity, and the autonomy of individuals.
- **Fairness:** AI systems should be inclusive and accessible, and should not involve or result in unfair discrimination against individuals, communities or groups.

¹⁰⁶ Id. at 12, 191-193.

¹⁰⁷ Id. at 191.

¹⁰⁸ Id. at 193.

¹⁰⁹ Id.

¹¹⁰ *Australia's AI Ethics Principles*, Department of Industry, Science and Resources, <https://perma.cc/S23U-S2Z2>.

- **Privacy protection and security:** AI systems should respect and uphold privacy rights and data protection, and ensure the security of data.
- **Reliability and safety:** AI systems should reliably operate in accordance with their intended purpose.
- **Transparency and explainability:** There should be transparency and responsible disclosure so people can understand when they are being significantly impacted by AI, and can find out when an AI system is engaging with them.
- **Contestability:** When an AI system significantly impacts a person, community, group or environment, there should be a timely process to allow people to challenge the use or outcomes of the AI system.
- **Accountability:** People responsible for the different phases of the AI system lifecycle should be identifiable and accountable for the outcomes of the AI systems, and human oversight of AI systems should be enabled.¹¹¹

F. SOCI Act

1. Requirements and Application

The SOCI Act, which was amended in 2021 and again in 2022,¹¹² “was implemented as a response to technological changes that have increased cyber connectivity to critical infrastructure.”¹¹³ One of the objects of the act is “imposing enhanced cybersecurity obligations on relevant entities for systems of national significance in order to improve their preparedness for, and ability to respond to, cybersecurity incidents.”¹¹⁴

The act imposes legal obligations (“positive security obligations”) on critical infrastructure assets. First, such assets must provide owner and operator information to the Register of Critical Infrastructure Assets.¹¹⁵ This obligation, in part 2 of the act, currently applies to a list of asset classes that includes, for example, broadcasting, domain name system, data storage or processing, food and grocery, hospital, public transport, and electricity.¹¹⁶

Second, specific critical infrastructure assets must report cybersecurity incidents to the ACSC under part 2B of the act. This requirement covers a separate list of asset classes, including those listed above, as well as, for example, banking, education, freight infrastructure and services, ports, and water.¹¹⁷

¹¹¹ Id.

¹¹² *Legislative Information and Reforms: Critical Infrastructure*, CISC, <https://perma.cc/MWD6-LJ5Q>. For information on the background policy and consultation process, see *Engagement on Critical Infrastructure Reforms*, Department of Homeland Security, <https://perma.cc/H7GE-H66K>.

¹¹³ Miralis et al., *supra* note 19.

¹¹⁴ Security of Critical Infrastructure Act 2018 (Cth) s 3(c).

¹¹⁵ Id. pt 2.

¹¹⁶ *Reporting and Compliance*, CISC, <https://perma.cc/Q5W9-6QXL>. See also Security of Critical Infrastructure (Application) Rules (LIN 22/026) 2022 (Cth) r 4, <https://perma.cc/FN7T-N64L>.

¹¹⁷ *Reporting and Compliance*, *supra* note 116; Security of Critical Infrastructure (Application) Rules (LIN 22/026) 2022 (Cth) r 5.

In addition, a much smaller subset of critical infrastructure assets may be privately designated as Systems of National Significance.¹¹⁸ Enhanced cyber security obligations may apply to such assets under Part 2C of the act, requiring them to

1. develop, update and comply with a cyber security incident response plan
2. undertake cyber security exercises to build cyber preparedness
3. undertake vulnerability assessments; and
4. provide system information.¹¹⁹

The SOCI Act also enables the government to “assist in the defence of critical infrastructure assets from cyber security threats, in light of their criticality to the social or economic stability of Australia or its people, the defence of Australia, or national security.”¹²⁰

In February 2023, CISC published the 2023 Critical Infrastructure Resilience Strategy¹²¹ and the Critical Infrastructure Resilience Plan 2023.¹²²

As noted above, the discussion paper on a new cybersecurity strategy suggests that customer data and “systems” could be included as critical assets under the SOCI Act to empower the government to give directions and gather information in response to significant data breaches.¹²³

2. Risk Management Program

In February 2023, the Minister for Home Affairs and Cybersecurity approved a new risk management program for Australian organizations deemed to be running infrastructure critical to the national interest.¹²⁴ The program “is the final of three preventative elements of the Security of Critical Infrastructure Act 2018 as amended in 2021 and 2022.”¹²⁵ The requirements related to risk management programs are contained in Part 2A of the act.

The Cyber and Infrastructure Security Centre explains that

[t]he Critical Infrastructure Risk Management Program (CIRMP) is intended to uplift core security practices that relate to the management of certain critical infrastructure assets. It aims to ensure responsible entities take a holistic and proactive approach toward identifying, preventing and mitigating risks.

¹¹⁸ CISC, *The Enhanced Cyber Security Obligations Framework* (May 2022), <https://perma.cc/5NN8-D8HV>.

¹¹⁹ CISC, *Protection of Australia’s Critical Infrastructure Summary* (Feb. 2023), <https://perma.cc/N9WK-7LT7>.

¹²⁰ *Id.*

¹²¹ CISC, *Critical Infrastructure Resilience Strategy* (Feb. 2023), <https://perma.cc/CAF7-NF98>.

¹²² CISC, *Critical Infrastructure Resilience Plan* (Feb. 2023), <https://perma.cc/KQK9-J9MP>.

¹²³ Expert Advisory Panel, *supra* note 74, at 17.

¹²⁴ Press Release, Clare O’Neil, World Leading Protection for Australia’s Critical Infrastructure (Feb. 21, 2023), <https://perma.cc/W4FV-R5JQ>.

¹²⁵ *Legislative Information and Reforms: Regulatory Obligations*, CISC, <https://perma.cc/TD5U-BW25>.

Responsible entities of the asset classes in section 4 of the *Security of Critical Infrastructure (Critical infrastructure risk management program) Rules* (LIN 23/006) 2023 (the Rules) are required to establish, maintain, and comply with a written risk management program that manages the ‘material risk’ of a ‘hazard’ occurring, which could have a relevant impact on their critical infrastructure asset.

Responsible entities must identify, and as far as is reasonably practicable, take steps to minimise or eliminate these ‘material risks’ that could have a ‘relevant impact’ on their asset.¹²⁶

The Rules specify that the following asset classes are covered by part 2A of the act, and are therefore subject to the CIRMP requirements:

- (a) a critical broadcasting asset;
- (b) a critical domain name system;
- (c) a critical data storage or processing asset;
- (d) a critical electricity asset;
- (e) a critical energy market operator asset;
- (f) a critical gas asset;
- (g) a designated hospital;
- (h) a critical food and grocery asset;
- (i) a critical freight infrastructure asset;
- (j) a critical freight services asset;
- (k) a critical liquid fuel asset;
- (l) a critical financial market infrastructure asset mentioned in paragraph 12D(1)(i) of the Act;
- (m) a critical water asset.¹²⁷

G. Telecommunications Legislation

The Telecommunications Act 1997 (Cth) regulates carriers and carriage service providers in their use and disclosure of personal information,¹²⁸ and the Telecommunications (Interception and Access Act) 1979 (Cth) requires providers of telecommunications services to collect and retain certain types of data for minimum period of two years.¹²⁹ Providers must comply with the Privacy Act in relation to that data.¹³⁰

Under security reforms enacted in 2017, “[a]ll carriers, carriage service providers and carriage service intermediaries are required to do their best to protect networks and facilities from unauthorised access and interference.”¹³¹ This includes “maintaining ‘competent supervision’

¹²⁶ CISC, *Critical Infrastructure Risk Management Program* (Feb. 2023), <https://perma.cc/K9TY-E4ZK>.

¹²⁷ *Security of Critical Infrastructure (Critical infrastructure risk management program) Rules* (LIN 23/006) 2023 r 4 (Cth), <https://perma.cc/BU5H-8GTT>.

¹²⁸ Telecommunications Act 1997 (Cth) pt 13.

¹²⁹ Telecommunications (Interception and Access) Act 1979 (Cth) pt 5-1A.

¹³⁰ *Id.* s 187LA.

¹³¹ *Legislative Information and Reforms: Telecommunications Sector Security (TSS)*, CISC, <https://perma.cc/2SZP-PEDQ>. See Telecommunications Act 1997 (Cth) pt 14.

and ‘effective control’ over telecommunications networks and facilities owned or operated by them.”¹³² Furthermore,

- “Carriers and nominated carriage service providers are required to notify government of planned changes to their networks and services that could compromise their ability to comply with the security obligation.”¹³³
- “The Secretary of the Department of Home Affairs has the power to obtain information and documents from carriers, carriage service providers and carriage service intermediaries, to monitor and investigate their compliance with the security obligation.”¹³⁴
- “The Minister for Home Affairs has the power to direct a carrier, carriage service provider or carriage service intermediary to do, or not do, a specified thing that is reasonably necessary to protect networks and facilities from national security risks.”¹³⁵

V. International Collaboration on Cybersecurity Guidance

The ACSC has worked with the government agencies with responsibilities for national cybersecurity in other countries to develop guidance related to particular cybersecurity issues.

In April 2023, the relevant authorities in the United States, Australia, Canada, United Kingdom, Germany, Netherlands, and New Zealand jointly published *Shifting the Balance of Cybersecurity Risk: Principles and Approaches*.¹³⁶ This “first-of-its-kind joint guidance urges manufacturers to take urgent steps necessary to ship products that are secure-by-design and -default.”¹³⁷ The U.S. Cybersecurity and Infrastructure Security Agency (CISA) explains that

[i]n addition to specific technical recommendations, this guidance outlines several core principles to guide software manufacturers in building software security into their design processes prior to developing, configuring, and shipping their products.

Many private sector partners have made invaluable contributions toward advancing security-by-design and security-by-default. With this joint guide, the authoring agencies seek to progress an international conversation about key priorities, investments, and decisions necessary to achieve a future where technology is safe, secure, and resilient by design and default.¹³⁸

¹³² *Legislative Information and Reforms: Telecommunications Sector Security (TSS)*, supra note 131.

¹³³ *Id.*

¹³⁴ *Id.*

¹³⁵ *Id.*

¹³⁶ U.S. Cybersecurity & Infrastructure Security Agency (CISA) et al., *Shifting the Balance of Cybersecurity Risk: Principles and Approaches for Security-by-Design and -Default* (Apr. 13, 2023), <https://perma.cc/LRC2-UWU3>.

¹³⁷ *Security-by-Design and -Default*, CISA (last updated June 12, 2023), <https://perma.cc/7XG3-H535>.

¹³⁸ *Id.*

In addition, also in April 2023, the cybersecurity authorities of the United States, United Kingdom, Australia, Canada, and New Zealand published *Cybersecurity Best Practices for Smart Cities*.¹³⁹ The guidance

provides an overview of risks to smart cities including expanded and interconnected attack surfaces; information and communications technologies (ICT) supply chain risks; and increasing automation of infrastructure operations. To protect against these risks, the government partners offer three recommendations to help communities strengthen their cyber posture: secure planning and design, proactive supply chain risk management, and operational resilience.¹⁴⁰

VI. Contribution to Development of International AI Standards

Standards Australia's report, *An Artificial Intelligence Standards Roadmap: Making Australia's Voice Heard*, states that Australia is participating in the development of AI-related standards by the Artificial Intelligence Joint Technical Committee of the International Organization for Standardization (ISO) and the International Electrotechnical Commission (IEC) (ISO/IEC JTC 1/SC 42), the Institute of Electrical and Electronic Engineers (IEEE), and the IEC (including through OCEANIS, the Open Community for Ethics in Autonomous and Intelligent Systems).¹⁴¹

In 2019, "Standards Australia signed an agreement to enable the adoption of IEEE Standards through the Standards Australia process, where no suitable ISO or IEC standard is available. This enables the adoption of IEEE Standards with the Australian Standards designation under some circumstances."¹⁴²

¹³⁹ CISA et al., *Cybersecurity Best Practices for Smart Cities* (Apr. 19, 2023), <https://perma.cc/TD99-AG2V>.

¹⁴⁰ *Cybersecurity Best Practices for Smart Cities*, CISA (Apr. 19, 2023), <https://perma.cc/M48K-2AW2>.

¹⁴¹ *An Artificial Intelligence Standards Roadmap: Making Australia's Voice Heard*, supra note 58, at 23.

¹⁴² *Id.* at 19.

Canada

*Michael Chalupovitsch, Tariq Ahmad
Foreign Law Specialists*

SUMMARY Canada does not currently have a stand-alone law that governs artificial intelligence (AI). On June 16, 2022, the Minister of Innovation, Science and Economic Development introduced Bill C-27, which would, among other things, enact the Artificial Intelligence and Data Act (AIDA). The proposed legislation requires certain obligations on the design, development, and use of AI systems and their associated harms, including assessing whether a system is high-impact, record keeping, and publishing certain information on AI systems, among other obligations.

Cybersecurity falls under the mandate of the Communications Security Establishment (CSE), which is Canada's signals intelligence agency.¹ CSE operates the Canadian Centre for Cyber Security, which issues security guidance to government, industry, researchers, and the general public. Its AI guidance document sets out common methods of compromising AI systems such as data poisoning, adversarial attacks, and model inversions.

I. Introduction

Currently, Canada does not have stand-alone legislation or regulations governing the use of artificial intelligence (AI). The 2017 federal budget included \$125 million Canadian dollars (approximately US\$94.11 million) in funding for the establishment of a Pan-Canadian AI Strategy under the auspices of the Canadian Institute for Advanced Studies (CIFAR).² An assessment of the strategy was conducted by CIFAR in 2020.³

Budget 2021 provided CAD443.8 million (approximately US\$334.11 million) over 10 years to support the commercialization of AI, attract and retain academic talent, enhance research and develop research centers, and adopt AI standards.⁴ Canada is a member of the Global Partnership on AI (GPAI), which was established in 2020.⁵

¹ *Cyber security*, Communications Security Establishment (CSE), <https://perma.cc/L26R-8NTH>.

² Department of Finance Canada, *Building a Strong Middle Class: Budget 2017* (Mar. 22, 2017), <https://perma.cc/7SB7-8QTA>; *Pan-Canadian Artificial Intelligence Strategy*, Innovation, Science and Economic Development Canada, <https://perma.cc/P57Q-KE4X>.

³ CIFAR, *Pan-Canadian Artificial Intelligence Strategy Assessment Report* (Oct. 2020), <https://perma.cc/5L8L-KEAS>.

⁴ Department of Finance Canada, *Budget 2021: A Recovery Plan for Jobs, Growth, and Resilience* (Apr. 19, 2021), <https://perma.cc/NSD2-V5DY>.

⁵ *About GPAI*, GPAI, <https://perma.cc/H435-MCRY>. Canada also hosts the International Centre of Expertise in Montréal on Artificial Intelligence (CEIMIA). *About the International Centre of Expertise in Montréal on Artificial Intelligence (CEIMIA)*, CEIMIA, <https://perma.cc/Q5NE-7X58>.

II. Overview of the Legal and Policy Framework

On June 16, 2022, the Minister of Innovation, Science and Economic Development introduced Bill C-27, which would, among other things, enact the Artificial Intelligence and Data Act (AIDA).⁶

According to the legislative summary of the bill provided by the Canadian Library of Parliament, “[t]he AI Act regulates international and interprovincial trade and commerce in artificial intelligence systems by establishing requirements for designing, developing and using AI systems and by prohibiting certain behaviours.”⁷ It is unclear when the AI Act would come into force, as it has yet to be voted on or referred to a committee for study.

The Bill is also accompanied by a companion document seeking to reassure Canadians regarding risks and concerns surrounding AI and the Government’s plans to regulate, but also to reassure the business community that it is not the intention to stifle innovation, stating,

[t]his document aims to reassure Canadians in two key ways. First, the Government recognizes that Canadians have concerns about the risks associated with this emerging technology and need to know that the Government has a plan to ensure that AI systems that impact their lives are safe. The recently published Report of the Public Awareness Working Group of the Advisory Council on AI reveals significant interest among Canadians in the opportunities offered by AI, but also concerns regarding potential harms. Nearly two-thirds of respondents believed that AI has the potential to cause harm to society, while 71% believed that it could be trusted if regulated by public authorities. Thus, we aim to reassure Canadians that we have a thoughtful plan to manage this emerging technology and maintain trust in a growing area of the economy. At the same time, AI researchers and innovators are concerned by the uncertainty that exists regarding future regulation. Recognizing that the regulation of this powerful technology is now an emerging international norm, many in the field are worried that regulation will be inflexible or that it will unfairly stigmatize their field of work. Such an outcome would have significant impacts on opportunities for Canadians and the Canadian economy. This document aims to reassure actors in the AI ecosystem in Canada that the aim of this Act is not to entrap good faith actors or to chill innovation, but to regulate the most powerful uses of this technology that pose the risk of harm. Specifically, this paper is intended to address both of these sets of concerns and provide assurance to Canadians that the risks posed by AI systems will not fall through the cracks of consumer protection and human rights legislation, while also making it clear that the Government intends to take an agile approach that will not stifle responsible innovation or needlessly single out AI developers, researchers, investors or entrepreneurs. What follows is a roadmap for the AIDA, explaining its intent and the Government's key considerations for operationalizing it through future regulations. It is intended to build understanding among stakeholders and

⁶ An Act to enact the Consumer Privacy Protection Act, the Personal Information and Data Protection Tribunal Act and the Artificial Intelligence and Data Act and to make consequential and related amendments to other Acts (Bill C-27), 44th Parliament, 1st Session, June 16, 2022, <https://perma.cc/594V-V3UN>.

⁷ Sabrina Charland et al., *Legislative Summary of Bill C-27: An Act to enact the Consumer Privacy Protection Act, the Personal Information and Data Protection Tribunal Act and the Artificial Intelligence and Data Act and to make consequential and related amendments to other Acts*, Library of Parliament Publication No. 44-1-C27-E (July 12, 2022), <https://perma.cc/8CYS-MMTH>.

Canadians on the proposed legislation, as well to support Parliamentary consideration of the Bill.⁸

On June 14, 2022, the Minister of Public Safety introduced Bill C-26, An Act respecting cyber security, amending the Telecommunications Act and making consequential amendments to other Acts in the House of Commons.⁹ The bill enacts the Critical Cyber Systems Protection Act (CCSPA). According to the Library of Parliament, the CCSPA

establishes a cyber security compliance regime for federally regulated critical cyber infrastructure. The CCSPA appears to be patterned after Australia's *Security of Critical Infrastructure Act 2018*, which was amended under the *Security Legislation Amendment (Critical Infrastructure) Act 2021*, significantly expanding the Australian federal government's powers to enforce cyber security obligations for critical infrastructures and to intervene in the private sector's response to cyber incidents affecting critical infrastructures, among other things. Also of note is the United States' *Cyber Incident Reporting for Critical Infrastructure Act of 2022*, which requires critical infrastructure operators to report cyber incidents to the Cybersecurity and Infrastructure Security Agency, and the United Kingdom's *The Network and Information Systems Regulations 2018* derived from the European Union's 2016 Directive on security of network and information systems. The overarching objective of all these regimes is to achieve an enhanced and common level of security for critical cyber infrastructures and to heighten the situational awareness of the relevant authorities.¹⁰

According to Public Safety Canada,

[t]he legislation addresses longstanding gaps in the Government's ability to protect the vital services and systems Canadians depend on by enabling it to:

- designate services and systems that are vital to national security or public safety in Canada as well as the operators or classes of operators responsible for their protection;
- ensure that designated operators are protecting the cyber systems that underpin Canada's critical infrastructure;
- ensure that cyber incidents that meet or exceed a specific threshold are reported;
- compel action by organizations in response to an identified cyber security threat or vulnerability; and
- ensure a consistent cross-sectoral approach to cyber security in response to the growing interdependency of cyber systems.¹¹

⁸ *The Artificial Intelligence and Data Act (AIDA) – Companion Document*, Innovation, Science and Economic Development Canada, <https://perma.cc/73AL-YWPG>.

⁹ An Act respecting cyber security, amending the Telecommunications Act and making consequential amendments to other Acts (Bill C-26), 44th Parliament, 1st Session, June 14, 2022, <https://perma.cc/T5EK-5E5Z>.

¹⁰ Jed Chong et al., *Legislative Summary of Bill C-26: An Act respecting cybersecurity, amending the Telecommunications Act and making consequential amendments to other Acts*, Library of Parliament Publication No. 44-1-C26-E (Oct. 6, 2022), <https://perma.cc/U6U6-ZYLZ>.

¹¹ *Protecting Critical Cyber Systems*, Public Safety Canada, <https://perma.cc/Y67Y-X7ZZ>.

III. Definition of Artificial Intelligence (AI) Systems

Bill C-27 defines an AI system as

a technological system that, autonomously or partly autonomously, processes data related to human activities through the use of a genetic algorithm, a neural network, machine learning or another technique in order to generate content or make decisions, recommendations or predictions.¹²

Public Safety Canada's National Cyber Security Strategy proposes a different definition of AI systems, as follows:

[t]he subfield of computer science concerned with developing intelligent computer programs that can solve problems, learn from experience, understand language, interpret visual scenes, and, in general, behave in a way that would be considered intelligent if observed in a human.¹³

IV. Cybersecurity of AI

Cybersecurity falls under the mandate of the Communications Security Establishment (CSE), which is Canada's signals intelligence agency.¹⁴ CSE operates the Canadian Centre for Cyber Security, which issues security guidance to government, industry, researchers, and the general public. Its AI guidance document sets out common methods of compromising AI systems such as data poisoning, adversarial attacks, and model inversions.¹⁵

The Treasury Board Secretariat, responsible for the administration of the Canadian federal government, issued the Directive on Automated Decision-Making (Directive), with the objective of ensuring "that automated decision systems are deployed in a manner that reduces risks to clients, federal institutions and Canadian society, and leads to more efficient, accurate, consistent and interpretable decisions made pursuant to Canadian law."¹⁶ All automated decisions are subject to an Algorithmic Impact Assessment, which covers 51 risk questions and 34 mitigation questions.¹⁷ These assessments must be reviewed by the legal service unit in the relevant government department or agency, and must also be released on the Open Government portal available to the public.¹⁸ The Directive includes requirements related to transparency, quality assurance, and data governance.¹⁹

¹² Bill C-27, § 2.

¹³ *National Cyber Security Strategy*, Public Safety Canada (2018), <https://perma.cc/4BE9-6ERY>.

¹⁴ *Cyber security*, Communications Security Establishment (CSE), <https://perma.cc/L26R-8NTH>.

¹⁵ *Artificial Intelligence - ITSAP.00.040*, Canadian Centre for Cyber Security, <https://perma.cc/Z4UM-GVEW>.

¹⁶ *Directive on Automated Decision-Making*, Treasury Board Secretariat (Apr. 1, 2019), <https://perma.cc/XW7V-76ZC>.

¹⁷ *Algorithmic Impact Assessment Tool*, Government of Canada, <https://perma.cc/GY77-KB7P>.

¹⁸ *Id.*

¹⁹ *Id.*

Bill C-27 would also enact a Consumer Privacy Protection Act “to support and promote electronic commerce by protecting personal information that is collected, used or disclosed in the course of commercial activities”²⁰

A. Data and Data Governance

In 2019, the Minister of Innovation, Science and Economic Development released the Canada’s Digital Charter.²¹ While not exclusively focused on AI, it included language on data governance and supporting the work of the Standards Council of Canada (SCC), ensuring the protection of data through future amendments to the Privacy Act, and expanding the powers of the Office of the Privacy Commissioner (OPC) to ensure compliance. Bill C-27, referenced above, would establish a Personal Information and Data Protection Tribunal to hear appeals from compliance decisions of the OPC.

In 2019, the SCC established the Canadian Data Governance Standardization Collaborative to “accelerate the development of industry-wide standardization strategies for data governance.” The Collaborative consists of members from “government, industry, civil society, Indigenous organizations, academia and standards development organizations.”²² The Collaborative developed the Canadian Data Governance Standardization Roadmap²³, “which describes the current and desired Canadian standardization landscape” and consists of 35 recommendations to “address gaps and explore new areas where standards and conformity assessment are needed.”²⁴ Some of the recommendations involving AI systems include the following:

- [t]o standardize terminology and the lifecycle components to lay the groundwork for the interoperability of AI solutions, and specifications for verification and validation²⁵; and
- [t]o standardize the governance approaches in organizations that use or create AI systems, encouraging diverse participation in the development of conformity assessment based standards such as ISO/IEC 42001 Artificial Intelligence Management System Standard.²⁶

In March 2023, the Collaborative was expanded into the AI and Data Governance (AIDG) Standardization Collaborative to “address national and international issues related to both AI and data governance.”²⁷ The expanded Collaborative will “support the development of

²⁰ Bill C-27, cl. 2.

²¹ Innovation, Science and Economic Development Canada, *Canada’s Digital Charter in Action: A Plan by Canadians, for Canadians* (2019), <https://perma.cc/9ET4-SA3E>.

²² *AI and Data Governance*, Standards Council of Canada (SCC), <https://perma.cc/6ZCN-WRWT>.

²³ *Id.*

²⁴ SCC, *Canadian Data Governance Standardization Roadmap* (2019), <https://perma.cc/TJZ6-EJE8>.

²⁵ *Id.* at 33.

²⁶ *Id.* at 34.

²⁷ *AI and Data Governance*, *supra* note 22.

standardization strategies that are aligned with Canada's priorities and enable the Canadian AI and data ecosystem to scale up on the international scene."²⁸

B. Record-Keeping

The Bill provides for public reporting and authorizes the Minister to order the production of records related to artificial intelligence systems. Section 60(1) stipulates that

[a]n organization must, in accordance with any prescribed requirements, keep and maintain a record of every breach of security safeguards involving personal information under its control.²⁹

A section of the Bill called "Regulation of Artificial Intelligence Systems in the Private Sector" establishes an obligation on persons who are carrying out regulated activity to keep records in accordance with regulations on the manner in which data is anonymized, use or management of anonymized data, assessments on high impact systems (and the reasons supporting their assessment), measures implemented related to risks, and monitoring of mitigation measures.³⁰ The record keeper must also keep any additional records in respect of the above requirements as provided in accordance with issued regulations.³¹

The Bill also states that "[a] person who is responsible for a high-impact system must, in accordance with the regulations and as soon as feasible, notify the Minister if the use of the system results or is likely to result in material harm."³²

The Minister may "compel the production of certain information" including records "from persons subject to the Act for the purpose of verifying compliance with the Act."³³

C. Transparency and Provision of Information to Users

According to the companion document, transparency means "providing the public with appropriate information about how high-impact AI systems are being used."³⁴ The information provided "should be sufficient to allow the public to understand the capabilities, limitations, and potential impacts of the systems."³⁵

²⁸ Id.

²⁹ Bill C-27, § 60(1).

³⁰ Id. § 10(1).

³¹ Id. § 10(2).

³² Id. § 12.

³³ *Charter Statement for Bill C-27*, Government of Canada, <https://perma.cc/5VQ6-UAD2>.

³⁴ *The Artificial Intelligence and Data Act (AIDA) – Companion Document*, *supra* note 8.

³⁵ Id.

The Bill requires a person who makes available for use a high-impact system and manages the operation of a high-impact system to publish of a plain-language description of the high-impact system on a publicly available website that includes an explanation of

- a) how the system is used;
- b) the types of content that it generates and the decisions, recommendations or predictions that it makes;
- c) the mitigation measures established under section 8 in respect of it; and
- d) any other information that may be prescribed by regulation.³⁶

The draft law also authorizes the Minister to “publish information about artificial intelligence systems posing a serious risk of harm” and “to order a person to publish information related to their compliance with the Act.”³⁷

D. Human Oversight

According to the companion document, “Human Oversight” means that “high-impact AI systems must be designed and developed in such a way as to enable people managing the operations of the system to exercise meaningful oversight” and “[t]his includes a level of interpretability appropriate to the context.”³⁸ It adds that “[m]onitoring through measurement and assessment of high-impact AI systems and their output, is critical in supporting effective human oversight.”³⁹

Under AIDA, persons responsible for AI systems are obligated to assess whether a system is high-impact, as follows:

[b]usinesses would be expected to institute appropriate accountability mechanisms to ensure compliance with their obligations under the Act. They would be held accountable for the creation and enforcement of appropriate internal governance processes and policies to achieve compliance with the AIDA. Measures would be set through regulation and would be tailored to the context and risks associated with specific regulated activities in the lifecycle of a high-impact AI system.⁴⁰

E. Risk Management System

The companion document stipulates that AIDA is “intended to protect Canadians, ensure the development of responsible AI in Canada, and to prominently position Canadian firms and values in global AI development.”⁴¹ It adds that “[t]he risk-based approach in AIDA, including key definitions and concepts, was designed to reflect and align with evolving international norms

³⁶ Bill C-27, § 11(1), (2).

³⁷ *Charter Statement for Bill C-27*, *supra* note 33.

³⁸ *The Artificial Intelligence and Data Act (AIDA) – Companion Document*, *supra* note 8.

³⁹ *Id.*

⁴⁰ *Id.*

⁴¹ *Id.*

in the AI space”⁴² including the US National Institute of Standards and Technology (NIST) Risk Management Framework (RMF), “while integrating seamlessly with existing Canadian legal frameworks.”

F. Quality Management System

We were unable to locate information in this area.

G. Conformity Assessments

According to its companion document, The AIDA would “mobilize external expertise in the private sector, academia, and civil society” to ensure that “enforcement activities” would occur through

- the designation of external experts as analysts to support administration and enforcement of Act;
- the use of AI audits performed by qualified independent auditors; and
- the appointment of an advisory committee to provide the Minister with advice.⁴³

The companion document also mentions that

[i]n addition, voluntary certifications can play an important role as the ecosystem is evolving. The AI and Data Commissioner would assess the progress of the ecosystem over time and ensure that administration and enforcement activities take into account the capabilities and scale of impact of regulated organizations. For example, smaller firms would not be expected to have governance structures, policies, and procedures comparable to those of larger firms with a greater number of employees and a wider range of activities. Small and medium-sized businesses would also receive particular assistance in adopting the practices needed to meet the requirements.⁴⁴

H. Robustness

We were unable to locate information in this area.

I. Personal Data Protection

The federal Personal Information Protection and Electronic Documents Act (PIPEDA)⁴⁵ applies to all private sector organizations that collect, use, retain, or disclose personal information in the course of their commercial activities and imposes certain obligations upon them. The Government has proposed the Consumer Privacy Protection Act as part of Bill C-27 to “modernize this law in the context of the digital economy, and it is also undertaking broader

⁴² Id.

⁴³ Id.

⁴⁴ Id.

⁴⁵ Personal Information Protection and Electronic Documents Act, S.C. 2000, c. 5, <https://perma.cc/ZB9S-BR99>.

efforts to ensure that laws governing marketplace activities and communications services keep pace.”⁴⁶

AIDA applies to persons who are carrying out a “regulated activity.” A regulated activity is defined under the Bill to include, in the course of international or interprovincial trade and commerce,

processing or making available for use any data relating to human activities for the purpose of designing, developing or using an artificial intelligence system.⁴⁷

People who carry out this activity need to “establish measures with respect to the manner in which data is anonymized” and “establish measures with respect to the management of anonymized data.”⁴⁸

In AIDA, there is a criminal provision on the possession or use of personal information in the context of artificial intelligence systems, as follows:

[e]very person commits an offence if, for the purpose of designing, developing, using or making available for use an artificial intelligence system, the person possesses — within the meaning of subsection 4(3) of the *Criminal Code* — or uses personal information, knowing or believing that the information is obtained or derived, directly or indirectly, as a result of

- (a) the commission in Canada of an offence under an Act of Parliament or a provincial legislature; or
- (b) an act or omission anywhere that, if it had occurred in Canada, would have constituted such an offence.⁴⁹

V. Adherence to Standardized Risk Management Frameworks

Institutions in Canada do not appear to have issued their own standardized risk management framework but the “current proposed standards” in AIDA “generally reflect those” in NIST’s AI Risk Management Framework 1.0 (AI RMF), and “emerging AI regulatory frameworks being considered in major economies around the world such as the EU.”⁵⁰

⁴⁶ *The Artificial Intelligence and Data Act (AIDA) – Companion Document*, supra note 8.

⁴⁷ Bill C-27, § 5(1).

⁴⁸ Gowling WLG, *The Artificial Intelligence and Data Act (AIDA)*, <https://perma.cc/5U4F-2KVR>.

⁴⁹ Bill C-27, § 38.

⁵⁰ *Artificial Intelligence Risk Management Framework Published by NIST*, FASKEN (Feb. 9, 2023), <https://perma.cc/6WTV-A89R>.

VI. AI Security Policy Across the Supply Chain

Scale AI is a technology cluster,⁵¹ which is headquartered in Montréal, that “aims to enable logistics and supply chain excellence in Canada through the adoption and use of artificial intelligence (AI) powered tools.”⁵² The National Research Council of Canada (NRC) supports the Scale AI cluster through its Artificial Intelligence for Logistics program. One of its projects is “Cybersecurity for Logistics Projects,” which includes

- secure and resilient fog computing framework for intelligent transportation systems;
- security of data provenance and machine learning for the Internet of Things;
- Internet of Things device profiling in smart transportation pathways; and
- GPS jammer risk management.⁵³

Sama, an AI data training company, commenting on the AIDA bill, believes that “the current proposed legislation needs to be broader and cover the entire AI supply chain, from data acquisition to workers’ rights. The legislation should also include vetting and inspection processes for procurement by government entities.”⁵⁴

⁵¹ *Canada’s AI-Powered Supply Chains Cluster (Scale AI)*, Innovation, Science and Economic Development Canada, <https://perma.cc/A88M-BWVE>.

⁵² Id.

⁵³ Id.

⁵⁴ Wendy Gonzalez et al., *Sama Calls for Canada’s AIDA Regulation to Cover the Entire AI Supply Chain*, Sama.com (Apr. 21, 2023), <https://perma.cc/D4FH-K7GZ>.

European Union

Jenny Gesley
Foreign Law Specialist

SUMMARY On April 21, 2021, the European Commission published a legislative proposal for an Artificial Intelligence Act (draft AI Act). The draft AI Act addresses the risks posed by AI systems to the safety or fundamental rights of citizens by following a risk-based approach ranging from complete prohibition or mandatory requirements for certain high-risk AI systems to transparency rules or voluntary compliance with the rules for low-risk AI systems. The EU envisages a possible final adoption of the AI Act at the end of 2023.

The EU cybersecurity legislative framework consists of several pieces of enacted and proposed legislation that cover certain aspects linked to cybersecurity from different angles. The proposed AI Act contains, among other things, specific requirements regarding the cybersecurity of high-risk AI systems, whereas other more general legislative acts address aspects of cybersecurity that are not specific to AI systems. Furthermore, the General Data Protection Regulation makes security of personal data a prerequisite for the processing of personal data and requires controllers to apply the principles of security by design and by default.

Under the draft AI Act, AI systems that would qualify as high-risk would have to be registered in an EU Database for Stand-Alone High-Risk AI Systems and comply with detailed mandatory requirements with regard to risk management systems; the quality of data sets used; technical documentation; record keeping; transparency and provision of information to users; human oversight; appropriate level of accuracy, robustness, and cybersecurity; quality management systems; and ex-ante conformity assessment.

I. Introduction

On April 21, 2021, the European Commission (Commission) published a legislative proposal for an Artificial Intelligence Act (draft AI Act).¹ The draft AI Act addresses the risks posed by AI systems to the safety or fundamental rights of citizens by following a risk-based approach ranging from complete prohibition or mandatory requirements for certain high-risk AI systems to transparency rules or voluntary compliance with the rules for low-risk AI systems. Furthermore, the European Union (EU) General Data Protection Regulation (GDPR), which became applicable in May 2018, makes security of personal data a prerequisite for processing of personal data and contains rules on automated individual decision-making in article 22.²

¹ *Proposal for a Regulation of the European Parliament and of the Council Laying Down Harmonised Rules on Artificial Intelligence (Artificial Intelligence Act) and Amending Certain Union Legislative Acts*, COM (2021) 206 final (Apr. 21, 2021) (Draft AI Act), <https://perma.cc/RWT9-9D97>.

² General Data Protection Regulation (GDPR), 2016 O.J. (L 119) 1, <https://perma.cc/7Y47-L7XX>.

The draft AI Act is subject to the ordinary legislative procedure, meaning the co-legislators of the EU, the Council of the European Union (Council) and the European Parliament (EP), must approve an identical text in up to three readings.³ The Council is made up of one government minister from each EU country, whereas the members of the EP are directly elected by the EU citizens.⁴ The EP adopts its position first and communicates it to the Council. To speed up the legislative process, there are informal trilogue discussions between representatives of the EP, the Council, and the Commission. The Council adopted its common position (general approach) on the draft AI Act on December 6, 2022.⁵ The plenary of the EP adopted its negotiating position in its session on June 14, 2023.⁶ Trilogues commenced after that, with a possible final adoption of the AI Act at the end of 2023.

The AI Act as an EU regulation would be directly applicable in the EU member states once it enters into force without the need for transposition into national law.⁷ The implementation of the AI Act would be monitored by national supervisory authorities.

II. Overview of the Legal and Policy Framework

A. Legislation and Policy

In 2020, the EU adopted a new “EU Cybersecurity Strategy.”⁸ It contains proposals for deploying regulatory, investment, and policy instruments to address “(1) resilience, technological sovereignty and leadership, (2) building operational capacity to prevent, deter and respond, and (3) advancing a global and open cyberspace.”⁹ Furthermore, it stated that “[c]ybersecurity must be integrated into all these digital investments, particularly key technologies like **Artificial Intelligence (AI)**, encryption and quantum computing, using incentives, obligations and benchmarks.”¹⁰

The EU cybersecurity legislative framework consists of several pieces of enacted and proposed legislation that cover certain aspects linked to cybersecurity from different angles. The proposed AI Act contains, among other things, specific requirements regarding the cybersecurity of high-

³ Consolidated Version of the Treaty on the Functioning of the European Union (TFEU), arts. 289, 294, 2016 O.J. (C 202) 47, <https://perma.cc/FM38-RYTH>.

⁴ Consolidated Version of the Treaty on European Union (TEU), arts. 14, 16, 2016 O.J. (C 202) 13, <https://perma.cc/9E8Y-B6C5>.

⁵ *General Approach*, File 2021/0106(COD) (Nov. 25, 2022), <https://perma.cc/H889-JV69>.

⁶ European Parliament (EP), P9 TA(2023)0236, *Artificial Intelligence Act. Amendments Adopted by the European Parliament on 14 June 2023 on the Proposal for a Regulation of the European Parliament and of the Council on Laying Down Harmonised Rules on Artificial Intelligence (Artificial Intelligence Act) and Amending Certain Union Legislative Acts (COM(2021)0206 – C9-0146/2021 – 2021/0106(COD))*, <https://perma.cc/JF3W-GU84>.

⁷ TFEU, art. 288, para. 2.

⁸ *Joint Communication to the European Parliament and the Council. The EU's Cybersecurity Strategy for the Digital Decade (EU Cybersecurity Strategy)*, JOIN(2020) 18 final (Dec. 16, 2020), <https://perma.cc/VUZ8-MUF2>.

⁹ *Id.* at 4.

¹⁰ *Id.* at 5 (emphasis added by author).

risk AI systems, whereas other more general legislative acts address aspects of cybersecurity that are not specific to AI systems.

1. *Draft AI Act*

The draft AI Act would apply to providers that place AI systems on the EU market or put them into service, irrespective of their location; users of AI systems located within the EU; and providers and users of AI systems in a third country, where the output produced by the AI system is used in the EU.¹¹ As mentioned, the proposal adopts a risk-based approach to regulation. It outlines four levels of risk: AI systems that pose an unacceptable risk would be completely prohibited, high-risk AI systems would be subject to detailed mandatory requirements as outlined below, limited risk AI systems would be subject to transparency requirements to alert users that they are interacting with a machine, and providers of AI systems presenting minimal or no risk would be encouraged to adopt codes of conduct or to apply the mandatory requirements for high-risk AI systems voluntarily.¹²

AI systems that would qualify as high-risk would have to be registered in an EU Database for Stand-Alone High-Risk AI Systems and comply with detailed mandatory requirements with regard to risk management systems; the quality of data sets used; technical documentation; record keeping; transparency and provision of information to users; human oversight; appropriate levels of accuracy, robustness, and cybersecurity; quality management systems; and ex-ante conformity assessment.¹³

The Commission in its proposal defines high-risk AI systems as AI systems intended to be used as a safety component of a product or those that fall under EU safety legislation, for example toys, aviation, cars, medical devices, or lifts.¹⁴ In addition, AI systems that are deployed in the following eight specific areas identified in annex III would automatically qualify as high-risk: biometric identification and categorization of natural persons; management and operation of critical infrastructure; education and vocational training; employment, worker management and access to self-employment; access to and enjoyment of essential private services and public services and benefits; law enforcement; migration, asylum, and border control management; and administration of justice and democratic processes.¹⁵ The Council in its general approach amended the requirements and added an additional horizontal layer on top of the high-risk classification to ensure that AI systems that are not likely to cause serious fundamental rights violations or other significant risks are not captured.¹⁶ Likewise, the EP added a horizontal layer, but also expanded the classification of high-risk areas to include harm to people's health, safety, fundamental rights, or environment and influencing voters in political campaigns and in

¹¹ Draft AI Act, art. 2.

¹² Id. arts. 5, 6, 52, 69, annex III.

¹³ Id. arts. 6, 8-15, 19, 51, 60, annex III.

¹⁴ Id. art. 6, para. 1.

¹⁵ Id. art. 6, para. 2 in conjunction with annex III.

¹⁶ *General Approach*, supra note 5, at 5, para. 1.5.

recommender systems used by social media platforms regulated under the Digital Services Act (DSA).¹⁷

2. General Cybersecurity Legislation

In August 2016, the first EU legislation on cybersecurity, the Network and Information Security (NIS) Directive, entered into force.¹⁸ Its aim is to “achiev[e] a high common level of security of network and information systems within the Union” by requiring EU Member States to adopt national cybersecurity strategies, designate competent national authorities, set-up computer-security incident response teams, and establish security and notification requirements for operators of essential services and for digital service providers.¹⁹ The NIS Directive was updated in 2022 to address the “expansion of the cyber threat landscape” and the divergent implementation of the NIS Directive in the EU Member States, which led to a fragmentation of the EU internal market (NIS 2 Directive).²⁰ NIS 2 entered into force on January 16, 2023, and Member States must transpose it into national law by October 17, 2024.²¹

In 2019, the Cybersecurity Act (CSA) entered into force, which established voluntary “European cybersecurity certification schemes for the purpose of ensuring an adequate level of cybersecurity for ICT [information and communication technologies] products, ICT services and ICT processes in the Union.”²² The CSA defined “cybersecurity” as “the activities necessary to protect network and information systems, the users of such systems, and other persons affected by cyber threats.”²³

Lastly, in 2022, the Commission published a proposal for a regulation on horizontal cybersecurity requirements for products with digital elements (Cyber Resilience Act, CRA).²⁴ It also covers AI systems, including the cybersecurity of products with digital elements that are classified as high-risk AI systems.²⁵ According to the explanatory memorandum, the CRA proposal is coherent with the AI Act proposal.²⁶ With regard to the relationship between the two proposed acts, recital 29 of the CRA states that

¹⁷ EP, *supra* note 6, amendments 234, 235, 739, 740; Digital Services Act [DSA], 2022 O.J. (L 277) 1, <https://perma.cc/Y5S3-Z7YX>.

¹⁸ NIS Directive, 2016 O.J. (L 194) 1, <https://perma.cc/JH4W-FHFB>.

¹⁹ *Id.* art. 1.

²⁰ NIS 2 Directive, recitals 3, 5, 2022 O.J. (L 333) 80, <https://perma.cc/EGT7-7Q3F>.

²¹ *Id.* arts. 41, 45.

²² Cybersecurity Act [CSA], art. 1, 2019 O.J. (L 151) 15, <https://perma.cc/8E4S-2BPJ>.

²³ CSA, art. 2(1).

²⁴ *Proposal for a Regulation of the European Parliament and of the Council on Horizontal Cybersecurity Requirements for Products with Digital Elements and Amending Regulation (EU) 2019/1020 (Cyber Resilience Act, CRA)*, COM/2022/454 final (Sept. 15, 2022), <https://perma.cc/N2TV-ZJRD>. For more information on the proposed Cyber Resilience Act, see Jenny Gesley, *European Union: Commission Proposes New Cybersecurity Rules for Products with Digital Elements*, *Global Legal Monitor* (Dec. 2, 2022), <https://perma.cc/2MRE-AQ4Z>.

²⁵ CRA, art. 8.

²⁶ *Id.* at 3.

[p]roducts with digital elements classified as high-risk AI systems according to Article 6 of Regulation [the AI Regulation] which fall within the scope of this Regulation should comply with the essential requirements set out in this Regulation. When those high-risk AI systems fulfil the essential requirements of this Regulation, they should be deemed compliant with the cybersecurity requirements set out in Article [Article 15] of Regulation [the AI Regulation] in so far as those requirements are covered by the EU declaration of conformity or parts thereof issued under this Regulation. As regards the conformity assessment procedures relating to the essential cybersecurity requirements of a product with digital elements covered by this Regulation and classified as a high-risk AI system, the relevant provisions of Article 43 of Regulation [the AI Regulation] should apply as a rule instead of the respective provisions of this Regulation. However, this rule should not result in reducing the necessary level of assurance for critical products with digital elements covered by this Regulation. Therefore, by way of derogation from this rule, high-risk AI systems that fall within the scope of the Regulation [the AI Regulation] and are also qualified as critical products with digital elements pursuant to this Regulation and to which the conformity assessment procedure based on internal control referred to in Annex VI of the Regulation [the AI Regulation] applies, should be subject to the conformity assessment provisions of this Regulation in so far as the essential requirements of this Regulation are concerned. In this case, for all the other aspects covered by Regulation [the AI Regulation] the respective provisions on conformity assessment based on internal control set out in Annex VI to Regulation [the AI Regulation] should apply.²⁷

That means that, as a general rule, for products with digital elements that also classify as high-risk AI systems, the CRA conformity assessment procedure would demonstrate compliance with the proposed AI Act requirements, with exceptions for certain AI critical products with digital elements.

B. Agencies

The European Union Agency for Cybersecurity (ENISA) was established in 2004 and is the EU agency that deals with cybersecurity.²⁸ It provides support to Member States, Union institutions, bodies, offices, and agencies in improving cybersecurity and acts as a reference point for advice and expertise on cybersecurity.²⁹ Among other things, it is tasked with assisting Member States in implementing EU cybersecurity legislation, in particular the NIS Directive.³⁰

With regard to the proposed AI Act, the EU Member States will have to designate one or several national competent authorities, meaning a national supervisory authority, a notifying authority, and a market surveillance authority, to supervise the application and implementation of the AI Act, in particular for monitoring the compliance of providers of high-risk AI systems with their obligations, such as ensuring an appropriate level of cybersecurity.³¹

²⁷ CRA, recital 29. This is also regulated in CRA, art. 8.

²⁸ Cybersecurity Act, arts. 3, 4.

²⁹ Id.

³⁰ Id. art. 5(2).

³¹ Draft AI Act, arts. 3(43), 23, 59.

III. Definition of Artificial Intelligence (AI) Systems

The Commission proposal defines AI systems as “[s]oftware that is developed with one or more of the techniques and approaches listed in annex I and can, for a given set of human-defined objectives, generate outputs such as content, predictions, recommendations, or decisions influencing the environments they interact with.”³² The approaches listed in the annex are machine learning approaches, logic- and knowledge-based approaches, and statistical approaches.³³

Both the Council in its general approach and the EP adopted changes to the Commission’s definition of AI systems. The Council narrowed down the definition of AI systems to systems developed through machine learning approaches and logic- and knowledge-based approaches.³⁴ It defined an AI system as

a system that is designed to operate with elements of autonomy and that, based on machine and/or human-provided data and inputs, infers how to achieve a given set of objectives using machine learning and/or logic- and knowledge based approaches, and produces system-generated outputs such as content (generative AI systems), predictions, recommendations or decisions, influencing the environments with which the AI system interacts.³⁵

The EP amended the definition of AI systems to align it with the OECD definition.³⁶ An AI system is accordingly defined as “a machine-based system that is designed to operate with varying levels of autonomy and that can, for explicit or implicit objectives, generate outputs such as predictions, recommendations, or decisions, that influence physical or virtual environments.”³⁷

IV. Cybersecurity of AI

ENISA notes that there are three dimensions with regard to the relationship between cybersecurity and AI.³⁸ They are as follows:

³² Draft AI Act, art. 3(1).

³³ *Annexes to the Proposal for a Regulation of the European Parliament and of the Council Laying Down Harmonised Rules on Artificial Intelligence (Artificial Intelligence Act) and Amending Certain Union Legislative Acts*, COM (2021) 206 final (Apr. 21, 2021), annex I, <https://perma.cc/T3X7-7WGV>.

³⁴ *General Approach*, supra note 5, at 71, art. 3(1).

³⁵ *Id.*

³⁶ The OECD defines an AI system as “a machine-based system that can, for a given set of human-defined objectives, make predictions, recommendations, or decisions influencing real or virtual environments. AI systems are designed to operate with varying levels of autonomy.” See *Recommendation of the Council on Artificial Intelligence*, OECD Legal Instruments (May 21, 2019), <https://perma.cc/G59U-RL6D>.

³⁷ EP, supra note 6, at 109, amendment 165.

³⁸ ENISA, *Securing Machine Learning Algorithms* (Dec. 14, 2021), <https://perma.cc/2L9L-6N6Z>.

- cybersecurity of AI: lack of robustness and the vulnerabilities of AI models and algorithms;
- AI to support cybersecurity: AI used as a tool/ means to create advanced cybersecurity (e.g., by developing more effective security controls) and to facilitate the efforts of law enforcement and other public authorities to better respond to cybercrime; and
- malicious use of AI: malicious/adversarial use of AI to create more sophisticated types of attacks.³⁹

This report will focus on the first of these three dimensions as outlined in the draft AI Act. The draft AI Act details the requirements for high-risk AI systems in chapter 2.⁴⁰ As mentioned, once an AI system has been classified as high-risk, it would have to comply with mandatory requirements with regard to risk management system; the quality of data sets used; technical documentation; record keeping; transparency and provision of information to users; human oversight; appropriate level of accuracy, robustness, and cybersecurity; quality management system; and ex-ante conformity assessment.

A. Data and Data Governance

The draft AI Act sets out requirements for data quality, verification of the source of data, and the integrity of data. Article 10 provides that high-risk AI systems which make use of techniques involving the training of models with data would have to be developed on the basis of training, validation, and testing data sets that meet certain specified criteria. In particular, the criteria would concern

- (a) the relevant design choices;
- (b) data collection;
- (c) relevant data preparation processing operations, such as annotation, labelling, cleaning, enrichment and aggregation;
- (d) the formulation of relevant assumptions, notably with respect to the information that the data are supposed to measure and represent;
- (e) a prior assessment of the availability, quantity and suitability of the data sets that are needed;
- (f) examination in view of possible biases;
- (g) the identification of any possible data gaps or shortcomings, and how those gaps and shortcomings can be addressed.⁴¹

Furthermore, training, validation, and testing data would have to be relevant, representative, free of error, and complete with the appropriate statistical properties.⁴² The data sets would have to

³⁹ ENISA, *Cybersecurity of AI and Standardisation* 10, para. 2.2 (Mar. 14, 2023), <https://perma.cc/TL52-PFMG>.

⁴⁰ Draft AI Act, arts. 8-15, 19.

⁴¹ Id. art. 10, para. 2.

⁴² Id. art. 10, para. 3.

take specific geographical, behavioral, or functional settings for use into account.⁴³ The proposal would allow the processing of sensitive personal data to avoid and correct bias in data sets.⁴⁴

For other high-risk AI systems that do not make use of techniques involving the training of models, “appropriate data governance and management practices” would be required to ensure data quality, although the proposal does not elaborate on the required adequacy.⁴⁵

B. Record-keeping

Record-keeping is addressed in article 12. High-risk AI systems would have to be designed and developed with logging capabilities that comply with recognized standards or common specifications to ensure the traceability of the system’s functioning, in particular with regard to AI systems having the potential to affect adversely the health or safety or the protection of fundamental rights of persons or situations leading to a modification of the AI system.⁴⁶ High-risk AI systems intended to be used for the real-time and post remote biometric identification of natural persons would have to be capable to log, at a minimum,

- (a) recording of the period of each use of the system (start date and time and end date and time of each use);
- (b) the reference database against which input data has been checked by the system;
- (c) the input data for which the search has led to a match; and
- (d) the identification of the natural persons involved in the verification of the results, as referred to in Article 14 (5).⁴⁷

The EP amended the record-keeping requirements and added requirements to measure and log the energy consumption, resource use, and environmental impact during the lifecycle of the system.⁴⁸ It deleted the requirement for record-keeping of AI systems intended to be used for biometric identification, because under the EP’s proposal, they would be completely prohibited.⁴⁹

C. Transparency and Provision of Information to Users

The draft AI Act aims to enable users to interpret the output of high-risk AI systems and use it appropriately. It would therefore require high-risk AI systems to be designed and developed in a transparent way to ensure security control.⁵⁰ To that end, user guides with concise, complete,

⁴³ Id. art. 10, para. 4.

⁴⁴ Id. art. 10, para. 5.

⁴⁵ Id. art. 10, para. 6.

⁴⁶ Id. art. 12, paras. 1-3.

⁴⁷ Id. art. 12, para. 4.

⁴⁸ EP, *supra* note 6, amendment 297.

⁴⁹ Id. amendments 220, 227.

⁵⁰ Draft AI Act, art. 1, para. 1.

correct, clear, relevant, accessible, and comprehensible information would have to be made available to users.⁵¹

In particular, the user instructions would have to include

- (a) the identity and the contact details of the provider and, where applicable, of its authorised representative;
- (b) the characteristics, capabilities and limitations of performance of the high-risk AI system, including:
 - (i) its intended purpose;
 - (ii) the level of accuracy, robustness and cybersecurity referred to in Article 15 against which the high-risk AI system has been tested and validated and which can be expected, and any known and foreseeable circumstances that may have an impact on that expected level of accuracy, robustness and cybersecurity;
 - (iii) any known or foreseeable circumstance, related to the use of the high-risk AI system in accordance with its intended purpose or under conditions of reasonably foreseeable misuse, which may lead to risks to the health and safety or fundamental rights;
 - (iv) its performance as regards the persons or groups of persons on which the system is intended to be used;
 - (v) when appropriate, specifications for the input data, or any other relevant information in terms of the training, validation and testing data sets used, taking into account the intended purpose of the AI system.
- (c) the changes to the high-risk AI system and its performance which have been pre-determined by the provider at the moment of the initial conformity assessment, if any;
- (d) the human oversight measures referred to in Article 14, including the technical measures put in place to facilitate the interpretation of the outputs of AI systems by the users;
- (e) the expected lifetime of the high-risk AI system and any necessary maintenance and care measures to ensure the proper functioning of that AI system, including as regards software updates.⁵²

The Council would additionally require providers to include illustrative examples to help users understand the instructions, as well as a description of the mechanism included within the AI system that allows users to properly collect, store, and interpret the logs.⁵³

D. Human Oversight

The draft AI Act states that human oversight is necessary to “prevent[] or minimi[ze] the risks to health, safety or fundamental rights that may emerge when a high-risk AI system is used in accordance with its intended purpose or under conditions of reasonably foreseeable misuse.”⁵⁴ Providers would therefore be required to “design[] and develop[] [high-risk AI systems] in such a way, including with appropriate human-machine interface tools, that they can be effectively

⁵¹ Id. art. 13, para. 2

⁵² Id. art. 13, para. 3.

⁵³ *General Approach*, supra note 5, at 44, para. 47 & at 96, art. 13, para. 3(f).

⁵⁴ Draft AI Act, art. 14, para. 2.

overseen by natural persons during the period in which the AI system is in use.”⁵⁵ Human oversight measures should either be identified and built into the high-risk AI system by the provider or be identified by the provider to be implemented by the user.⁵⁶ These measures must enable the individual performing oversight to fully understand the system and its limits; identify automation bias; correctly interpret the system’s output; decide not to use the system or otherwise disregard, override, or reverse the output; and intervene or interrupt the operation.⁵⁷ Furthermore, for high-risk AI systems intended to be used for biometric identification, any action or decision would have to be verified and confirmed by at least two natural persons.⁵⁸

The EP in its amendment added that persons performing oversight would need a sufficient level of AI literacy and the necessary support and authority to exercise that function.⁵⁹

E. Risk Management System

All high-risk AI systems would need to have a risk management system established, implemented, documented, and maintained.⁶⁰ The risk management system would consist of a continuous iterative process run throughout the entire lifecycle of the system with regular updating. The following steps would need to be included:

- (a) identification and analysis of the known and foreseeable risks associated with each high-risk AI system;
- (b) estimation and evaluation of the risks that may emerge when the high-risk AI system is used in accordance with its intended purpose and under conditions of reasonably foreseeable misuse;
- (c) evaluation of other possibly arising risks based on the analysis of data gathered from the post-market monitoring system referred to in Article 61;
- (d) adoption of suitable risk management measures in accordance with the provisions of the following paragraphs.⁶¹

Residual risks judged acceptable would need to be communicated to the user.⁶² However, providers would need to ensure that risks are eliminated or reduced as far as possible through adequate design and development or are adequately mitigated and controlled if they cannot be eliminated, as well as ensure that adequate information is provided.⁶³ The most appropriate risk management measures would need to be identified through testing suitable to achieve the intended purpose of the AI system throughout the development process and prior to the placing

⁵⁵ Id. art. 14, para. 1.

⁵⁶ Id. art. 14, para. 3.

⁵⁷ Id. art. 14, para. 4.

⁵⁸ Id. art. 14, para. 5.

⁵⁹ EP, *supra* note 6, amendment 314.

⁶⁰ Draft AI Act, art. 9, para. 1.

⁶¹ Id. art. 9, para. 2.

⁶² Id. art. 9, para. 4.

⁶³ Id.

on the market.⁶⁴ Special consideration would have to be given to the impact of the AI system on children or their opportunity to access such a system.⁶⁵

The Council would require testing of the AI system in real world conditions.⁶⁶ The EP, among other things, would like to see experts and external stakeholders involved to eliminate or reduce risks through adequate design and development.⁶⁷

F. Quality Management System

Providers would be obligated to establish a quality management system, which should include, among other things, security management aspects.⁶⁸ In particular, the quality management system would have to include at least the following aspects:

- (a) a strategy for regulatory compliance, including compliance with conformity assessment procedures and procedures for the management of modifications to the high-risk AI system;
- (b) techniques, procedures and systematic actions to be used for the design, design control and design verification of the high-risk AI system;
- (c) techniques, procedures and systematic actions to be used for the development, quality control and quality assurance of the high-risk AI system;
- (d) examination, test and validation procedures to be carried out before, during and after the development of the high-risk AI system, and the frequency with which they have to be carried out;
- (e) technical specifications, including standards, to be applied and, where the relevant harmonised standards are not applied in full, the means to be used to ensure that the high-risk AI system complies with the requirements set out in Chapter 2 of this Title;
- (f) systems and procedures for data management, including data collection, data analysis, data labelling, data storage, data filtration, data mining, data aggregation, data retention and any other operation regarding the data that is performed before and for the purposes of the placing on the market or putting into service of high-risk AI systems;
- (g) the risk management system referred to in Article 9;
- (h) the setting-up, implementation and maintenance of a post-market monitoring system, in accordance with Article 61;
- (i) procedures related to the reporting of serious incidents and of malfunctioning in accordance with Article 62;
- (j) the handling of communication with national competent authorities, competent authorities, including sectoral ones, providing or supporting the access to data, notified bodies, other operators, customers or other interested parties;
- (k) systems and procedures for record keeping of all relevant documentation and information;
- (l) resource management, including security of supply related measures;

⁶⁴ Id. art. 9, paras. 5-7.

⁶⁵ Id. art. 9, para. 8.

⁶⁶ *General Approach*, supra note 5, at 90, art. 9, para. 6.

⁶⁷ EP, supra note 6, amendment 269.

⁶⁸ Draft AI Act, art. 16 (b), art. 17.

(m) an accountability framework setting out the responsibilities of the management and other staff with regard to all aspects listed in this paragraph.⁶⁹

G. Robustness

All high-risk AI systems would need to be “designed and developed in such a way that they achieve, in the light of their intended purpose, an appropriate level of accuracy, robustness, and cybersecurity, and perform consistently in those respects throughout their lifecycle.”⁷⁰ In particular, they should be resilient with regard to errors, faults, or inconsistencies that may occur within the system or the environment in which the system operates and with regard to attempts by unauthorized third parties to alter their use or performance by exploiting the system vulnerabilities.⁷¹ Robustness of high-risk AI systems could be achieved through technical redundancy solutions, such as backup or fail-safe plans.⁷² Feedback loops would have to be duly addressed with appropriate mitigation measures.⁷³

Furthermore, technical solutions to achieve cybersecurity would be required to be “appropriate to the relevant circumstances and the risks” and include “measures to prevent and control for attacks trying to manipulate the training dataset (‘data poisoning’), inputs designed to cause the model to make a mistake (‘adversarial examples’), or model flaws.”⁷⁴

The EP, among other changes, emphasizes that the AI systems would have to be designed and developed following the principle of security by design and by default using state-of-the-art measures.⁷⁵ It also adds that technical solutions should address measures to prevent trying to manipulate pre-trained components used in training (‘model poisoning’) or confidentiality attacks.⁷⁶

H. Conformity Assessments

Conformity assessments to evaluate that the AI system complies with all requirements, including cybersecurity, are necessary “to ensure a high level of trustworthiness of high-risk AI systems.”⁷⁷ As mentioned, the proposal states that AI systems classified as high-risk may only be placed on the market if they have undergone an ex-ante conformity assessment showing that they comply with the requirements set out above.⁷⁸ The provider must subsequently draw up an EU

⁶⁹ Id. art. 17, para. 1.

⁷⁰ Id. art. 15, para. 1.

⁷¹ Id. art. 15, paras. 3, 4.

⁷² Id. art. 15, para. 3.

⁷³ Id.

⁷⁴ Id. art. 15, para. 4.

⁷⁵ EP, *supra* note 6, amendment 321.

⁷⁶ Id. amendment 329.

⁷⁷ Draft AI Act, recital 62.

⁷⁸ Id. arts. 3(20), 19, 43.

declaration of conformity and affix the *conformité européenne* (CE) marking of conformity to demonstrate compliance.⁷⁹ Adherence to harmonized standards or common specifications adopted by the Commission may be used to show compliance.⁸⁰ AI systems intended to be used as a safety component of a product or for biometric identification and categorization of natural persons would be subject to third party conformity assessment by independent notified bodies, whereas all other high-risk AI systems listed in the annex would be subject to internal control conformity assessments by the providers.⁸¹ Systems would have to be reassessed after substantial modifications.⁸² As mentioned, high-risk AI systems that have been certified or for which a statement of conformity has been issued under a cybersecurity scheme according to the CSA would be deemed to be in compliance with the cybersecurity requirements set out in the draft AI Act.⁸³

I. Personal Data Protection

The protection of personal data and the respect for private life are fundamental rights in the EU.⁸⁴ The GDPR defines personal data as “any information relating to an identified or identifiable natural person (data subject).”⁸⁵ As a regulation, the GDPR is directly applicable in the EU Member States with generally no domestic implementing legislation needed.⁸⁶ Processing of personal data according to the GDPR must comply with the principles of lawfulness, fairness, and transparency; purpose limitation; data minimization; accuracy and keeping data up to date; storage limitation; and integrity and confidentiality.⁸⁷ In particular, integrity and confidentiality means that data must be “processed in a manner that ensures appropriate security of the personal data, including protection against unauthorised or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organisational measures.”⁸⁸ Security of personal data is therefore a prerequisite for processing of personal data.

Article 25 employs the principle of security by design and by default. It requires controllers to implement appropriate technical and organizational measures, such as pseudonymization, to implement data-protection principles effectively, taking into account, among other things, the state of the art (security by design).⁸⁹ Furthermore, controllers must implement appropriate

⁷⁹ Id. art. 19, para. 1, arts. 48, 49.

⁸⁰ Id. arts. 40, 41.

⁸¹ Id. arts. 33, 43, recitals 64, 65.

⁸² Id. art. 43, para. 4.

⁸³ Id. art. 42, para. 2. See also above part II.A.2.

⁸⁴ Charter of Fundamental Rights of the European Union (EU Charter) arts. 7, 8, 2012 O.J. (C 326) 391, <https://perma.cc/PAX8-4MYJ>; TFEU, art. 16, para. 1.

⁸⁵ GDPR, art. 4, point (1).

⁸⁶ TFEU, art. 288, para. 2.

⁸⁷ GDPR, art. 5, para. 1. For a more detailed overview, see Jenny Gesley, *Online Privacy Law (2017 Update): European Union* (Law Library of Congress, Dec. 2017), <https://perma.cc/BE4N-ACRQ>.

⁸⁸ GDPR, art. 5, para. 1(f).

⁸⁹ Id. art. 25, para. 1.

technical and organizational measures to ensure that only personal data which are necessary for each specific purpose of the processing are processed (security by default).⁹⁰ In particular, personal data must by default not be made accessible to an indefinite number of people without consent of the data subject.⁹¹

A 2020 report on AI cybersecurity challenges by ENISA observed that

[t]o this end, security can also be an enabler of new types of processing operations, especially related to emerging technologies, such as AI. For instance, the implementation of specific security measures, like pseudonymisation or encryption, may bring data to a new format so that it cannot be attributed to a specific data subject without the use of additional information data (like a decryption key). These options could be explored in the context of AI environment, to shape new relationships between humans and machines, in a way that individuals are not by default identifiable by machines unless they wish to do so. For instance, to revert the effect of the implemented pseudonymisation or encryption.⁹²

Chapter IV, section 2 of the GDPR is entitled “security of personal data” and details measures that must be taken to ensure a level of security appropriate to the risk and requirements for notification of a data breach. In particular, article 32 provides that depending on the anticipated risks for the rights and freedoms of natural persons, the controller and the processor must implement appropriate technical and organizational measures, such as

- a) the pseudonymisation and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data in a timely manner in the event of a physical or technical incident; and
- d) a process for regularly testing, assessing and evaluating the effectiveness of technical and organisational measures for ensuring the security of the processing.⁹³

To assess the degree of risk, the controller and processor must take into account risks resulting from accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to personal data transmitted, stored or otherwise processed.⁹⁴ Adherence to an approved code of conduct or certification mechanism proves compliance with the above-mentioned requirements.⁹⁵

If there is a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to, personal data transmitted, stored, or otherwise processed, the data controller has an obligation to notify the supervisory authority without undue

⁹⁰ Id. art. 25, para. 2.

⁹¹ Id.

⁹² ENISA, *Artificial Intelligence Cybersecurity Challenges. Threat Landscape for Artificial Intelligence* 9 (Dec. 15, 2020), <https://perma.cc/H996-7KCA>.

⁹³ GDPR, art. 32, para. 1.

⁹⁴ Id. art. 32, para. 2.

⁹⁵ Id. art. 32, para. 3, arts. 40, 42.

delay.⁹⁶ The data subject must also be informed if the breach is likely to result in a high risk to the rights and freedoms of natural persons.⁹⁷ Failure to provide notification of a breach may result in administrative fines. There are two tiers of fines, depending on the nature of the breach. Fines are either up to €10 million (about US\$11 million), or in the case of an undertaking, up to 2% of the total worldwide annual turnover of the preceding financial year, whichever is higher, such as when a data breach is not notified, or up to €20 million (about US\$22 million) or up to 4% of the total worldwide annual turnover, whichever is higher, such as when the basic principles for processing (such as security of processing) are violated.⁹⁸

V. Adherence to Standardized Risk Management Frameworks

As mentioned, compliance with the requirements for high-risk AI systems can be shown by adhering to harmonized standards or common specifications.⁹⁹ Recital 61 of the draft AI Act elaborates that

[s]tandardisation should play a key role to provide technical solutions to providers to ensure compliance with this Regulation. Compliance with harmonised standards as defined in Regulation (EU) No 1025/2012 of the European Parliament and of the Council [Standardization Regulation] should be a means for providers to demonstrate conformity with the requirements of this Regulation. However, the Commission could adopt common technical specifications in areas where no harmonised standards exist or where they are insufficient.¹⁰⁰

The EP in its amendment elaborates on the role of standard setting organizations with regard to ensuring accuracy, robustness, and cybersecurity and states that “[w]hile standardisation organisations exist to establish standards, coordination on benchmarking is needed to establish how these standardised requirements and characteristics of AI systems should be measured.”¹⁰¹ In addition, it adds that

providers that have already in place quality management systems based on standards such as ISO 9001 or other relevant standards, no duplicative quality management system in full should be expected but rather an adaptation of their existing systems to certain aspects linked to compliance with specific requirements of this Regulation. This should also be reflected in future standardization activities or guidance adopted by the Commission in this respect.¹⁰²

⁹⁶ Id. arts. 4(12), 33.

⁹⁷ Id. art. 34.

⁹⁸ Id. art. 83, paras. 4, 5.

⁹⁹ Draft AI Act, arts. 40, 41.

¹⁰⁰ Id. recital 61; Consolidated Version of the Standardization Regulation, 2012 O.J. (L 316) 12, <https://perma.cc/7NR3-DBYA>.

¹⁰¹ EP, *supra* note 6, amendment 85.

¹⁰² Id. amendment 89.

The EP also emphasizes that standardization requests from the Commission to European Standardization Organizations must specify that they have to be consistent and aimed at ensuring that AI systems or foundation models meet the requirements of the draft AI Act, as well as ensure a balanced representation of all interests in developing the standards.¹⁰³

ENISA recommends, among other things, that specific/technical guidance on how existing standards related to the cybersecurity of software should be applied to AI is developed, the inherent features of machine learning are reflected in standards, and to include potential cybersecurity concerns in AI standards on trustworthiness by establishing liaisons between cybersecurity technical committees and AI technical committees.¹⁰⁴

VI. AI Security Policy Across the Supply Chain

ENISA notes that

[t]he ENISA AI Threat Landscape not only lays the foundation for upcoming cybersecurity policy initiatives and technical guidelines, but also stresses relevant challenges. One area of particular significance is that of the supply chain related to AI and accordingly it is important to highlight the need for an EU ecosystem for secure and trustworthy AI, including all elements of the AI supply chain. The EU secure AI ecosystem should place cybersecurity and data protection at the forefront and foster relevant innovation, capacity-building, awareness raising and research and development initiatives.¹⁰⁵

The draft AI Act places obligations on various economic operators, including distributors. They are defined as “any natural or legal person in the supply chain, other than the provider or the importer, that makes an AI system available on the Union market without affecting its properties.”¹⁰⁶ Article 27 discusses the obligations of distributors in detail, in particular they must verify that high-risk AI systems bear the conformity marking and that the provider and importer have complied with the requirements of chapter 2 of the draft AI Act.¹⁰⁷

In addition, if national market surveillance authorities in the EU Member States find that a particular AI system poses a risk to the health or safety of persons even though it complies with the draft AI Act, they must inform the Commission and include, among other things, the origin and the supply chain of the AI system.¹⁰⁸

¹⁰³ Id. amendments 439, 440.

¹⁰⁴ ENISA, *supra* note 39, at 25.

¹⁰⁵ ENISA, *supra* note 92, at 5.

¹⁰⁶ Draft AI Act, art. 3(7).

¹⁰⁷ Id. art. 27, para. 1.

¹⁰⁸ Id. art. 67, paras. 1, 3.

The more general NIS 2 Directive requires essential and important entities to take appropriate and proportionate technical, operational, and organizational cybersecurity risk management measures and to base them on an all-hazards approach.¹⁰⁹ Among other things, the measures must include supply chain security, including security-related aspects concerning the relationships between each entity and its direct suppliers or service providers.¹¹⁰

¹⁰⁹ NIS 2 Directive, art. 21, para. 1.

¹¹⁰ Id. art. 21, para. 2(d).

New Zealand

Kelly Buchanan
Chief, Foreign, Comparative, and
International Law Division II

SUMMARY New Zealand does not currently have legislation that specifically addresses artificial intelligence (AI). However, the government and entities in the private sector, particularly through the AI Forum of New Zealand, have undertaken various studies, reports, and discussions related to the development and regulation of AI. This includes an algorithm charter signed by various government agencies, and “trustworthy AI” principles and AI “cornerstones” developed by the AI Forum, as well as strategies and plans that reference AI. In addition, the privacy commissioner has published guidance for entities on the use of generative AI.

Several existing laws are relevant to the regulation of AI, including the Privacy Act 2020, consumer protection law, legislation related to human rights, criminal law, and laws related to national security. The New Zealand Information Security Manual as well as legislation and guidance on cyber resilience or security targeted at certain sectors are also relevant to the cybersecurity of AI. In addition, New Zealand’s cybersecurity authorities have worked with international partners to develop guidance on cybersecurity topics relevant to AI.

I. Introduction

New Zealand does not have a dedicated law on artificial intelligence (AI), or specific provisions regarding AI in other legislation. The government is actively considering the issues, however, and various actions have been taken to promote and guide the use and development of AI in the country.

Starting in 2019, the New Zealand government partnered with the Centre for the Fourth Industrial Revolution of the World Economic Forum (WEF) on work that aims to produce a roadmap to guide policymakers in regulating AI.¹ The *Reimagining Regulation for the Age of AI: New Zealand Pilot Project* white paper was published in June 2020.² It describes “a multi-stakeholder, evidence-based policy project anchored in New Zealand,”³ with different focus areas: national conversation, regulatory capability and institutional design, and risk/benefit assessment of AI systems for government. A government spokesperson stated,

¹ Alastair Farr, *Reimagining Regulation in the Age of Artificial Intelligence (AI)*, Digital.govt.nz (Nov. 11, 2019), <https://perma.cc/YFJ5-QG9P>.

² World Economic Forum, *Reimagining Regulation for the Age of AI: New Zealand Pilot Project – White Paper* (June 2020), <https://perma.cc/H2K3-M528>.

³ Id. at 24.

[a]s a small country, New Zealand is seen by WEF as being an ideal test bed for this kind of agile thinking . . . We have a small, stable democracy, with a government that can move quickly. We are well-connected, both internally, across our government and wider society, and we have strong relationships with other countries. We are seen as a leading digital nation.⁴

Various work has been conducted in the public sector related to the use of AI by government agencies and the private sector, including the following:

- The *Algorithm Charter for Aotearoa New Zealand*,⁵ which was released in July 2020 “to increase public confidence and visibility around the use of algorithms in the public sector.”⁶ Charter signatories are to assess their decisions about the use of algorithms using a risk matrix, and to implement a list of commitments related to transparency; partnership (i.e., embedding a Te Ao Māori - Māori worldview - perspective); engaging with people; data considerations; privacy, ethics, and human rights; and human oversight. The charter followed on from a 2018 review of how government agencies use algorithms,⁷ with the resulting report drawing on the *Principles for Safe and Effective Use of Data and Analytics*,⁸ which were developed in 2018 by the privacy commissioner and chief data steward. Other relevant guidance includes the Social Wellbeing Agency’s *Data Protection and Use Policy*,⁹ the Ministry of Social Development’s *Privacy, Human Rights and Ethics Framework*,¹⁰ and *Ngā Tikanga Paihere*, a framework that “draws on 10 tikanga (Te Ao Māori - Māori world concepts) to help [entities] establish goals, boundaries, and principles that guide and inform [their] data practice.”¹¹
- In 2018, the Human Rights Commission published a paper titled *Privacy, Data and Technology: Human Rights Challenges in the Digital Age*, which provides “a high-level summary of the key international and domestic human rights standards and principles that can guide legal and

⁴ Stuart Corner, *How the NZ Government Will Regulate AI* (Mar. 17, 2020), <https://perma.cc/2ZVV-HVR6>.

⁵ Stats NZ, *Algorithm Charter for Aotearoa New Zealand* (July 2020), <https://perma.cc/B43C-79DB>. See Kelly Buchanan, *New Zealand: Government Launches Charter on Use of Algorithms by Public Agencies* (July 31, 2020), <https://perma.cc/7QVE-D9FY>.

⁶ *Algorithm Charter for Aotearoa New Zealand*, Data.govt.nz, <https://perma.cc/A3XD-AX8Z>.

⁷ *Government Algorithm Transparency and Accountability*, Data.govt.nz, <https://perma.cc/UZT2-W6CG>.

⁸ Privacy Commissioner & Stats NZ, *Principles for the Safe and Effective Use of Data and Analytics* (May 2018), <https://perma.cc/YK8A-HU8F>.

⁹ Social Wellbeing Agency, *Data Protection and Use Policy (DPUP)* (version 1.2, Jan. 2022), <https://perma.cc/6HM9-6MBK>.

¹⁰ Ministry of Social Development, *The Privacy, Human Rights and Ethics (PHRaE) Framework*, <https://perma.cc/BH5Z-PJF7>.

¹¹ *Ngā Tikanga Paihere*, Data.govt.nz, <https://perma.cc/A6ZZ-MAVQ>. See also Stats NZ, *Ngā Tikanga Paihere: A Framework Guiding Ethical and Culturally Appropriate Data Use – Guidelines 2020* (Dec. 2020), <https://perma.cc/C2VM-S3KZ>.

policy frameworks in responding to the rapid advance of digital technology.”¹² The paper includes specific discussion of AI, including its use in the criminal justice system.¹³

- New Zealand’s innovation agency, Callaghan Innovation, published a white paper titled *Thinking Ahead: Innovation Through Artificial Intelligence* in 2018.¹⁴ The paper “predicts how AI will affect our agriculture, digital, energy and health sectors within the next few years. It details how different AI technologies will disrupt each sector in waves and showcases local examples of AI-powered businesses.”¹⁵
- In 2020, the Productivity Commission published a research note on *New Zealanders’ Attitudes Towards Robots and AI*.¹⁶ It also considered matters related to algorithms and AI as part of its inquiry into technological change and the future of work,¹⁷ and published a joint report with the Australian Productivity Commission in 2019 on growing the digital economy in the two countries, including the use of AI.¹⁸
- In May 2023, the privacy commissioner published guidance outlining “his expectations around New Zealand agencies, businesses, and organisations using generative artificial intelligence (AI).”¹⁹ This includes a statement that “[g]enerative AI tools, capabilities, and their impact are rapidly evolving. Regulators across the world are actively reviewing the situation, and the Privacy Commissioner has called for New Zealand regulators to come together to determine how best to protect the rights of New Zealanders.”²⁰
- The National Ethics Advisory Committee’s *National Ethical Standards* provide “general principles guiding the ethics of biomedicine as they apply to AI,” and “frame standards applying these principles to specific circumstances.”²¹ They state that “[a]ll researchers employing health data in AI systems throughout the AI life cycle . . . should refer to the ethical

¹² Human Rights Commission, *Privacy, Data and Technology: Human Rights Challenges in the Digital Age 5* (May 2018), <https://perma.cc/Q79G-WA2K>.

¹³ *Id.* at 44–47.

¹⁴ Callaghan Innovation, *Thinking Ahead: Innovation Through Artificial Intelligence* (2018), <https://perma.cc/M9HH-D8WN>.

¹⁵ *Waves of AI Disruption for Key New Zealand Business Sectors*, Callaghan Innovation (Mar. 26, 2018), <https://perma.cc/FJ5G-5JJD>.

¹⁶ Dave Heatly, *New Zealanders’ Attitudes Towards Robots and AI* (Productivity Commission Research Note 2020/1, Feb. 2020), <https://perma.cc/TN8N-M3L2>.

¹⁷ See *Technological Change and the Future of Work*, Productivity Commission, <https://perma.cc/YGF6-5LTW>.

¹⁸ Australian Productivity Commission & New Zealand Productivity Commission, *Growing the Digital Economy in Australia and New Zealand: Maximising Opportunities for SMEs: Joint Research Report* (Jan. 2019), <https://perma.cc/V4WE-KSK5>.

¹⁹ Press Release, Privacy Commissioner, Privacy Commissioner Outlines Expectations Around AI Use (May 25, 2023), <https://perma.cc/K94Z-4XNG>.

²⁰ *Generative Artificial Intelligence – 15 June 2023 Update*, Privacy Commissioner, <https://perma.cc/LW7J-4WMN>.

²¹ *National Ethics Standards – Part 2, 13. Health Data and New Technologies*, National Ethics Advisory Committee, <https://perma.cc/M75F-DTLN>.

principles . . . in the absence of a standard that directly applies to their case.”²² The government announced funding in August 2022 for three international research projects, led by research teams in New Zealand, to explore how AI could provide improved access to health care.²³

- Under the banner of the Christchurch Call to Action,²⁴ New Zealand is working with the United States, Twitter, and Microsoft on an initiative that will “support the creation of new technology to understand the impacts of algorithms on people’s online experiences.”²⁵
- The Royal Society, which promotes research and scholarly activity, has published a report titled *The Age of Artificial Intelligence in Aotearoa New Zealand*, which “outlines what artificial intelligence is, how it is or could be used in Aotearoa New Zealand, and the risks that need to be managed so that all New Zealanders can prosper in an AI world.”²⁶

In academia, the University of Otago established the Centre for AI and Public Policy in 2018.²⁷ The center particularly examines policy options for New Zealand and “acts in an advisory capacity to the Ministries of Broadcasting, Communications and Digital Media, and Government Digital Services.”²⁸

The New Zealand Law Foundation and the University of Otago published a report on *Government Use of Artificial Intelligence in New Zealand* in 2019,²⁹ as part of a project on artificial intelligence and law.³⁰

The Artificial Intelligence Researchers Association published a paper in 2021 that discusses current AI capabilities in New Zealand and makes recommendations for establishing the country

²² Id.

²³ \$5.1 Million for Research Into Artificial Intelligence to Improve Health Outcomes, Ministry of Business, Innovation & Employment (MBIE) (Aug. 19, 2022), <https://perma.cc/9QG6-WYHH>.

²⁴ See *Christchurch Call Story*, Christchurch Call, <https://perma.cc/RVK8-835K>.

²⁵ *Christchurch Call Initiative on Algorithmic Outcomes*, Christchurch Call (Sept. 22, 2022), <https://perma.cc/7AL3-F3V2>.

²⁶ Royal Society, *The Age of Artificial Intelligence in Aotearoa*, <https://perma.cc/HNB5-MBYH>.

²⁷ *Researching the Costs and Benefits of Artificial Intelligence*, Centre for Artificial Intelligence and Public Policy, University of Otago, <https://perma.cc/8TT9-3XXX>.

²⁸ Id.

²⁹ New Zealand Law Foundation & University of Otago, *Government Use of Artificial Intelligence in New Zealand* (2019), <https://perma.cc/Y49N-CPWA>.

³⁰ *Major New Otago Study to Tackle Artificial Intelligence Law and Policy*, University of Otago (Jan. 19, 2017), <https://perma.cc/S7SD-PW86>; *Artificial Intelligence and Law in New Zealand: Outputs*, University of Otago & New Zealand Law Foundation, <https://perma.cc/9H9J-T48E>.

as “a research centre of excellence and trust in AI.”³¹ More recently, in March 2023, it published a discussion paper on the implications of ChatGPT and large language models for policy makers.³²

In terms of private sector self-regulation, the Artificial Intelligence Forum of New Zealand (AI Forum) is a nonprofit organization, funded by its members, that “brings together New Zealand’s community of artificial intelligence technology innovators, end users, investor groups, regulators, researchers, educators, entrepreneurs and interested public to work together to find ways to use AI to help enable a prosperous, inclusive and thriving future for our nation.”³³ The New Zealand government provided foundational support for the forum to undertake research, leading to a 2018 report titled *Artificial Intelligence: Shaping a Future New Zealand*.³⁴ Among its other endeavors, in 2020 the AI Forum published a set of guiding principles for *Trustworthy AI in Aotearoa New Zealand* (AI Principles).³⁵ The AI Forum states,

[t]he AI Principles are designed to assist everyone in the AI ecosystem, including in both the private and public sectors. However, we recognise that Government has additional obligations and a broader role to play in ensuring AI and other emerging technologies serve the long-term public good of New Zealand, including in meeting its obligations under Te Tiriti o Waitangi.

Government regulation and regulators have an important role to play here. Self-regulation in the form of ethical principles or standards may fill a gap where the law is incomplete or out of date, but they are no substitution for democratically-mandated rules backed up by the force of law.³⁶

II. Overview of the Legal and Policy Framework

There is not currently any draft or proposed legislation to regulate AI. In 2020, it was reported that “[t]he New Zealand Government plans to regulate the use of artificial intelligence (AI) algorithms by progressively incorporating AI controls into existing regulations and legislation as they are amended and updated, rather than having any specific regulation to control the use of AI.”³⁷

³¹ *Homepage*, Artificial Intelligence Researchers Association, <https://perma.cc/W8LB-VGLC>. See also Artificial Intelligence Researchers Association, *White Paper: Aotearoa New Zealand Artificial Intelligence – A Strategic Approach* (Nov. 2021), <https://perma.cc/8ZG4-QEAD>.

³² Artificial Intelligence Researchers Association, *Discussion Paper: ChatGPT & Large Language Models – What Are the Implications for Policy Makers?* (Mar. 2023), <https://perma.cc/BU4F-7L9F>.

³³ *About - Harnessing the Power of AI to Enable a Prosperous, Inclusive and Thriving Future New Zealand*, AI Forum New Zealand (2022), <https://perma.cc/S8M8-YWNK>.

³⁴ AI Forum New Zealand, *Artificial Intelligence: Shaping a Future New Zealand* (May 2018), <https://perma.cc/LZE6-CXYZ>.

³⁵ *Trustworthy AI in Aotearoa – The AI Principles* AI Forum New Zealand (Mar. 4, 2020), <https://perma.cc/P76N-JHQP>.

³⁶ AI Forum New Zealand, *Trustworthy AI in Aotearoa: AI Principles 2* (Mar. 2020), <https://perma.cc/Q9FR-P4ZN>.

³⁷ Corner, *supra* note 4.

Existing general legislation that may be relevant to regulating AI, including in relation to cybersecurity, include the Privacy Act 2020,³⁸ Harmful Digital Communications Act 2015 (removal of harmful online content),³⁹ Fair Trading Act 1986 (consumer protection law),⁴⁰ Human Rights Act 1993 (anti-discrimination law),⁴¹ New Zealand Bill of Rights Act 1990 (freedom from unreasonable search and seizure, etc.),⁴² Crimes Act 1961 (cybercrime offenses),⁴³ Telecommunications (Interception Capability and Security) Act 2013 (network security duties),⁴⁴ and the Intelligence and Security Act 2017 (agency responsibilities for cybersecurity).⁴⁵

In May 2023, the Ministry of Business, Innovation & Employment (MBIE) published the *Digital Technologies Industry Transformation Plan*. This document refers to the development of an AI strategy, stating,

[s]ome initial work was developed by MBIE in conjunction with the AI Forum, on draft “cornerstones” to underpin a future AI Strategy for Aotearoa New Zealand. These included the aim that all AI innovation and adoption across New Zealand is done safely and ethically, with the full trust and support of New Zealanders. Future work could look to advance development of an AI Strategy that helps New Zealand leverage the economic opportunities of this technology in a trustworthy way.⁴⁶

The AI Forum’s draft “cornerstones” were published in 2021. They describe six key areas that “together, provide a framework for action, setting our priorities for AI in New Zealand.”⁴⁷ The cornerstones are headed “uniquely New Zealand,” “human-centred and trusted AI,” “investment in the AI economy,” “preparing the workforce,” and “our place in the world.”⁴⁸

The transformation plan also references the *Digital Strategy for Aotearoa* (DSA), which was published in September 2022. The relevant minister’s foreword to that strategy states,

New Zealand stands on the precipice of a huge opportunity to design, build and use digital technologies in world-leading, ethical, equitable ways that reflect the culture and uniqueness of our country.

³⁸ Privacy Act 2020, <https://perma.cc/UQ39-RZSA>.

³⁹ Harmful Digital Communications Act 2015, <https://perma.cc/7M2A-DLMQ>.

⁴⁰ Fair Trading Act 1986, <https://perma.cc/3F6Y-BEEU>.

⁴¹ Human Rights Act 1993, <https://perma.cc/XA7S-4HL4>.

⁴² New Zealand Bill of Rights Act 1990, <https://perma.cc/PT9Q-UYVD>.

⁴³ Crimes Act 1961 ss 248–252, <https://perma.cc/WAE7-RRQ8>.

⁴⁴ Telecommunications (Interception Capability and Security) Act 2013, <https://perma.cc/YL3J-AEZQ>.

⁴⁵ Intelligence and Security Act 2017, <https://perma.cc/PVT7-BQPH>.

⁴⁶ MBIE, *Digital Technologies Industry Transformation Plan* 32 (May 2023), <https://perma.cc/K297-CKU7>.

⁴⁷ *Introducing Aotearoa’s Proposed AI Cornerstones*, AI Forum New Zealand (Apr. 29, 2021), <https://perma.cc/J5W6-TGQ5>.

⁴⁸ *Id.*

To get there, we need to ask ourselves hard questions like:

- How can we build on New Zealand’s inherently high levels of trust to benefit society, and the economy?
- What would it mean to be the first country to embrace the ethical deployment of Artificial Intelligence?
- Are we courageous enough to unlock the benefits of widespread digital thinking?⁴⁹

The DSA sets out three strategic themes: Trust, Inclusion, and Growth. In relation to Trust, the strategy states that this is essential for digital systems, and that, for example, “[p]eople affected by decisions made using data and algorithms should be able to trust that their data was used in appropriate ways.”⁵⁰ Furthermore,

[t]rustworthy digital and data systems are fair, transparent, secure and accountable. They should centre the needs of people most affected by them and honour Te Tiriti o Waitangi / the Treaty of Waitangi and its principles. Trust is important when collecting data, analysing it with artificial intelligence (AI) and other algorithms, and using it to make decisions.⁵¹

The DSA also discusses “getting the right guardrails in place” in order to have trustworthy digital technologies and provide certainty for people developing and using digital technologies. It states,

[r]ules and guidelines must be coherent, comprehensive and easy to follow so people understand how to fulfil their obligations. Some key legislation already addresses some aspects of trust, like the Privacy Act 2020 and the Harmful Digital Communications Act 2015. Legislation to create a trust framework for digital identity services has been introduced to Parliament. Beyond legislation, we have frameworks, guidelines and standards that address various aspects of trust. These include the Algorithm Charter for Aotearoa New Zealand, Ngā Tikanga Paihere guidelines and the Privacy, Human Rights and Ethics framework.

Opportunities in the next few years include:

- developing a responsible and ethical approach to digital technologies, including governance and oversight to ensure trustworthy systems
- identifying and filling any gaps in existing rules and standards, including ways of protecting citizens’ rights to access their personal data and understand how it is being used
- progressing the Digital Identity Services Trust Framework legislation
- making the Algorithm Charter for Aotearoa New Zealand operational across the public sector, and exploring opportunities to encourage uptake more broadly

⁴⁹ *Te Rautaki Matihiko mō Aotearoa: The Digital Strategy for Aotearoa*, Digital.govt.nz (Sept. 2022), <https://perma.cc/Q94K-YLJC>.

⁵⁰ Id.

⁵¹ Id.

- coordinating between public and private organisations so they can learn from each other.⁵²

In terms of “collaboratively shaping the future of digital and data-driven technologies,” the DSA lists several opportunities in the next few years, including “advancing an AI Strategy for Aotearoa with the AI Forum.”⁵³ It also explains that “[t]he Ministry of Business, Innovation & Employment (MBIE) has worked with the AI Forum to develop cornerstones that could underpin a future AI Strategy for Aotearoa New Zealand. These include the aim that all AI innovation and adoption across New Zealand is done safely and ethically, with the full support and trust of New Zealanders.”⁵⁴

The government also published the first action plan, for 2022-23, under the DSA. The action plan “signposts 4 issues that we know we must tackle” for which there currently are no dedicated resources “but where we want to do the groundwork for future initiatives”:⁵⁵

- data ethics and the development and use of artificial intelligence
- enhancing our cyber security
- the challenges and opportunities of digital inclusion
- digital twins.

These issues emerged in the engagement process on the DSA and reflect our shared ambition to design and use digital technologies in world-leading, ethical and equitable ways that reflect our uniqueness. We will continue to flesh these out in the coming months, including their resourcing needs and the lead agencies that can drive progress.⁵⁶

With regard to data ethics and AI, the action plan states,

Because AI is informed by data, our ability to advance ethical and innovative development and use of AI depends heavily on building a trustworthy and ethical data ecosystem.

Aotearoa New Zealand could be a leading global voice in data governance, promoting trust, addressing risks to privacy, embedding te ao Māori perspectives, and supporting networking and coordination across industry, research bodies and the wider community.

As initial steps, we will strive to build data ethics capability within the public sector and will continue to explore the merits of a Centre for Data Ethics and AI. Work in this space would make a particularly strong contribution to the Mahi Tika – Trust pillar of the DSA as well as contribute to Mahi Ake – Growth and Mahi Tahi – Inclusion through enabling new business models and establishing a data ecosystem that works for all.⁵⁷

⁵² Id.

⁵³ Id.

⁵⁴ Id.

⁵⁵ 2022–23 *Action Plan for the Digital Strategy for Aotearoa*, Digital.govt.nz, <https://perma.cc/FAD9-J4AX>.

⁵⁶ Id.

⁵⁷ Id.

III. Definition of Artificial Intelligence (AI) Systems

There is no definition of AI systems in New Zealand law. Various entities have provided definitions of AI in their work, for example,

- The AI Forum, in the *Shaping the Future of New Zealand* report, defined AI as “advanced digital technologies that enable machines to reproduce or surpass abilities that would require intelligence if humans were to perform them.”⁵⁸
- *Rautaki Hanganga o Aotearoa, New Zealand’s Infrastructure Strategy (2022–2052)*, defines AI as “[t]echnology that enables digital devices to respond to and learn from their environments. Artificial intelligence is anticipated to streamline tasks, especially those that are repeatable, and continue to learn and develop through completing tasks and receiving feedback.”⁵⁹
- The Productivity Commission, in its joint report on growing the digital economy in Australia and New Zealand, defined AI as “[a] system able to learn and adapt to perform specific tasks normally requiring human-like cognition and intelligence, such as visual perception, speech recognition and problem solving.”⁶⁰
- The Cyber Security Strategy defines AI as “[a] computerised system capable of simulating human decision making and learning, including performing cognitive functions associated with the human mind including learning and language.”⁶¹
- New Zealand Trade and Enterprise defines AI as “the simulation of human memory, problem solving and decision-making, by machines (most often computer systems).”⁶²

IV. Cybersecurity of AI

A. Relevant Agencies and Roles

There are two key government agencies with roles specifically related to cybersecurity: the New Zealand Computer Emergency Response Team (CERT NZ) and the National Cyber Security Centre (NCSC). Other agencies also have responsibilities related to cybersecurity, including the Department of the Prime Minister and Cabinet (DPMC), which includes the National Cyber Policy Office within the National Security Group.⁶³

⁵⁸ *Artificial Intelligence: Shaping a Future New Zealand*, supra note 34, at 14.

⁵⁹ *Glossary*, Rautaki Hanganga o Aotearoa – New Zealand Infrastructure Strategy, <https://perma.cc/9VS7-8MK8>.

⁶⁰ *Growing the Digital Economy in Australia and New Zealand: Maximising Opportunities for SMEs: Joint Research Report*, supra note 18, at ix.

⁶¹ New Zealand Government, *New Zealand’s Cyber Security Strategy 2019: Enabling New Zealand to Thrive Online* 16 (2019), <https://perma.cc/33PR-5FF5>.

⁶² *How Artificial Intelligence Can Help Your Business Grow*, myNZTE (Jan. 12, 2022), <https://perma.cc/V6BV-TYCL>.

⁶³ See Department of the Prime Minister and Cabinet, *Briefing to the Incoming Minister for the Digital Economy and Communications* 21–22 (Jan. 31, 2023), <https://perma.cc/JAT5-UNX9>.

CERT NZ “works to support businesses, organisations and individuals who are affected (or may be affected) by cyber security incidents.”⁶⁴ Its role includes receiving cyber incident reports, tracking incidents or attacks, and providing advice and alerts to organizations on responding to and preventing attacks.

The NCSC is part of the Government Communications Security Bureau (GCSB) and “supports nationally significant organisations to improve their cyber security,” as well as responding to “national-level harm and advanced threats.”⁶⁵ As part of its role, the NCSC administers the network security provisions of the Telecommunications (Interception Capability and Security) Act 2013. The functions, powers, and duties of the GCSB in relation to cybersecurity are set out in the Intelligence and Security Act 2017. The NCSC maintains the *New Zealand Information Security Manual*, and the director-general of GCSB is the government chief information security officer.⁶⁶

The current Cyber Security Strategy was released in 2019. The strategy notes that “[t]he emergence of AI is an example of a technological shift where the impact for cyber security is largely unknown.”⁶⁷ DPMC’s work program “seeks to progress the five areas” of the strategy.⁶⁸ These are a cyber security aware and active citizenry, a strong and capable cyber security workforce and ecosystem, an internationally active, resilient, and responsive New Zealand, and a proactive tackling of cybercrime.⁶⁹

The minister responsible for cybersecurity matters is currently the Minister for the Digital Economy and Communications.⁷⁰

B. Legislation and Guidance

The Privacy Act 2020 is “the key legislation in New Zealand governing cybersecurity.”⁷¹ However, it only deals with personal information. The Intelligence and Security Act 2017 regulates state-based surveillance and, as noted in Part IV.A, above, establishes the role of the GCSB with respect to responding to cybersecurity incidents impacting nationally significant organizations. In addition, entities regulated by the Financial Markets Authority (FMA) or the Reserve Bank “are subject to separate, sector-specific guidance in relation to cyber resilience.”⁷²

⁶⁴ *About Us*, CERT NZ, <https://perma.cc/VVT3-GRX8>.

⁶⁵ *About Us*, NCSC, <https://perma.cc/D8B5-YVNW>.

⁶⁶ *Id.*

⁶⁷ *New Zealand’s Cyber Security Strategy 2019: Enabling New Zealand to Thrive Online*, *supra* note 61, at 4.

⁶⁸ Department of the Prime Minister and Cabinet, *Aide-Memoire: Briefing to the Incoming Minister for National Security Intelligence* 9 (Jan. 25, 2023), <https://perma.cc/874B-4MYG>.

⁶⁹ *New Zealand’s Cyber Security Strategy 2019: Enabling New Zealand to Thrive Online*, *supra* note 61, at 10.

⁷⁰ *Briefing to the Incoming Minister for the Digital Economy and Communications*, *supra* note 63, at 2.

⁷¹ Derek Roth-Biester et al., *The Privacy, Data Protection and Cybersecurity Law Review: New Zealand*, *The Law Reviews* (Oct. 27, 2022), <https://perma.cc/42UZ-E7YA>.

⁷² *Id.*

In December 2022, the New Zealand cabinet agreed to the development of standalone legislation “to enhance the cyber resilience of critical infrastructure, at a faster pace than the broader resilience reform programme [related to critical infrastructure]. Legislation focused on the cyber resilience is intended to be introduced in 2024, with consultation on the process scheduled for the first half of 2023.”⁷³

1. Privacy Act 2020

The Privacy Act 2020 repealed and replaced the Privacy Act 1983. The new act “retains the principle-based approach contained within the former legislation and strengthens the Act’s privacy protections by promoting early intervention and privacy risk management by agencies (including by introducing a mandatory privacy breach notification regime).”⁷⁴ The act contains 13 privacy principles that govern “how businesses and organisations should collect, handle and use personal information.”⁷⁵ Under the act, if an organization or business has a privacy breach that has either caused or is likely to cause anyone serious harm, it must notify the privacy commissioner and any affected people as soon as possible.⁷⁶

As stated by the privacy commissioner in the guidance on generative AI tools, the Privacy Act is intended to be “technology-neutral,” meaning “the same privacy rights and protections apply to generative AI tools that apply to other activities that use personal information (such as collecting and using personal information via paper or computer).”⁷⁷ The guidance states that the privacy commissioner expects agencies considering implementing a generative AI tool to

- have senior leadership approval,
- review whether a generative AI tool is necessary and proportionate,
- conduct a Privacy Impact Assessment,
- be transparent,
- engage with Māori,
- develop procedures about accuracy and access by individuals,
- ensure human review prior to acting, and
- ensure that personal or confidential information is not retained or disclosed by the generative AI tool.⁷⁸

⁷³ *Aide-Memoire: Briefing to the Incoming Minister for National Security Intelligence*, supra note 68, at 9.

⁷⁴ Roth-Biester et al., supra note 71.

⁷⁵ *Privacy Act 2020 and the Privacy Principles*, Privacy Commissioner, <https://perma.cc/HST4-BGTN>.

⁷⁶ *Privacy Breaches*, Privacy Commissioner, <https://perma.cc/9YA4-ZPVU>.

⁷⁷ *Generative Artificial Intelligence – 15 June 2023 Update*, supra note 20.

⁷⁸ Id.

2. *New Zealand Information Security Manual*

The New Zealand Information Security Manual (NZISM) “details processes and controls essential for the protection of all New Zealand Government information and systems. Controls and processes representing good practice are also provided to enhance the baseline controls.”⁷⁹ While it is intended for use by New Zealand government departments and agencies, Crown entities, local government, and private sector organizations are also encouraged to use the manual.⁸⁰ It contains chapters on, for example, information security governance, system certification and accreditation, information security monitoring and incidents, communications systems and devices, software security, email security, access control and passwords, cryptography, network and gateway security, data management, enterprise systems security, and Public Cloud Security.

With respect to the use of standards within the NZISM, the GCSB explains that

Published standards are widely used in the continuing development of the NZISM. Standards in development are also monitored.

While the NZISM may include a subset of, or directly align with international standards, national or joint standards, the NZISM is also designed to reflect New Zealand conditions, and the national interests of New Zealand.

Cost, adoption rates, international interoperability and obligations, ability to influence vendors, and the threat and risk environment can be unique to New Zealand which can affect the adoption of some elements of international practice and standards.

Existing international standards are extremely well resourced, researched, reviewed and widely published. Care is taken not to create unique NZ solutions which lack compatibility or are not interoperable with international practice and standards.⁸¹

3. *Telecommunications (Interception Capability and Security) Act 2013*

In 2020, the GCSB and NCSC published guidelines for network operators regarding the network security requirements contained in part 3 of the Telecommunications (Interception Capability and Security) Act 2013. It explains that the part

outlines a framework under which network operators are required to engage with the GCSB about proposed changes and developments with their networks where these intersect with national security.

The framework sets out a path to identify and address, prevent, mitigate, or remove the network security risks which may arise.⁸²

⁷⁹ Government Communications Security Bureau (GCSB), *ISM Document: 1. About Information Security* ¶ 1.1.1 (version 3.6, last updated Sept. 2022), <https://perma.cc/93TC-KUTF>.

⁸⁰ Id. ¶ 1.1.2.

⁸¹ *About the NZISM: Standards*, GCSB, <https://perma.cc/MG9D-YAV8>.

⁸² GCSB, *Telecommunications (Interception Capability and Security) Act 2013: Guidelines for Network Operators 3* (May 27, 2020), <https://perma.cc/2ZGB-CHCS>.

Under the act, network operators are required to register,⁸³ with the register maintained by the New Zealand Police. They must act honestly and in good faith when engaging with the GCSB, and have a duty to notify or engage with the GCSB about certain proposed decisions, courses of action, or changes in regard to certain parts of their network. There is also a duty to engage with the GCSB if the operator becomes aware of any network security risk.⁸⁴

4. *Guidance for Entities Regulated by the FMA or Reserve Bank*

The FMA published an information sheet on cybersecurity and operational systems resilience in 2022,⁸⁵ and the Reserve Bank published guidance on cyber resilience in 2021.⁸⁶ The Reserve Bank explains that

[s]ince 2019, we have been progressing our work to build cyber resilience in the financial sector alongside industry and other public bodies, including the National Cyber Security Centre (NCSC), the Computer Emergency Response Team (CERT NZ) and the Financial Markets Authority (FMA).

We have developed a three-step approach to promoting cyber resilience, which:

1. provides new risk management guidance for the entities we regulate (. . .)
2. develops an information collection and gathering plan (which is in development and will be released for consultation)
3. enhances coordination across industry, regulators and government agencies on a collective response to cyber incidents.

Information gathering and sharing is an area where there is a strong case for close coordination among agencies. In developing information gathering and sharing arrangements, we are working closely with the NCSC, CERT NZ and the FMA to avoid duplication and reduce unnecessary compliance costs.⁸⁷

5. *Trustworthy AI Principles*

The AI Forum's AI Principles include "reliability, security and privacy," stating that "AI stakeholders must ensure AI systems and related data are reliable, accurate and secure and the privacy of individuals is protected throughout the AI system's life cycle, with potential risks identified and managed on an ongoing basis."⁸⁸ They also include transparency ("[t]he operation and impacts of an AI system should be transparent, traceable, auditable and generally explainable to a degree appropriate to its use and potential risk profile so outcomes can be understood and challenged, particularly where they relate to people") and human oversight and accountability

⁸³ Telecommunications (Interception Capability and Security) Act 2013 s 60.

⁸⁴ Id. s 46.

⁸⁵ FMA, *Cyber Security & Operational Systems Resilience* (June 2022), <https://perma.cc/ZMK3-5W2E>.

⁸⁶ Reserve Bank of New Zealand, *Guidance on Cyber Resilience* (Apr. 2021), <https://perma.cc/9GXX-BY93>.

⁸⁷ *Improving Cyber Resilience for Regulated Entities*, Reserve Bank of New Zealand (Feb. 28, 2022), <https://perma.cc/B6DW-RB5P>.

⁸⁸ *Trustworthy AI in Aotearoa: AI Principles*, *supra* note 36, at 4.

(“AI stakeholders should retain an appropriate level of human oversight of AI systems and their outputs. Technologies capable of harming individuals or groups should not be deployed until stakeholders have determined appropriate accountability and liability”).⁸⁹

V. International Collaboration on Cybersecurity Guidance

New Zealand’s cybersecurity authorities, specifically the NCSC and CERT NZ, have worked with international partners to develop guidance related to cybersecurity, as noted in the survey on Australia contained in this report.

In particular, the NCSC was involved in the development of the joint guidance on *Cybersecurity Best Practices for Smart Cities*,⁹⁰ along with authorities in the United States, United Kingdom, Canada, and Australia. The NCSC states that the guidance “provides recommendations to balance efficiency and innovation with cyber security, privacy protections, and national security” and “encourages organisations to implement these best practices in alignment with their specific cyber security requirements to ensure the safe and secure operation of infrastructure systems, protection of citizens’ private data, and security of sensitive government and business data.”⁹¹

The NCSC and CERT NZ were also both involved in the preparation of the joint guide, by “seven like-minded nations,” titled *Shifting the Balance of Cybersecurity Risk: Principles and Approaches for Security-by-Design and -Default*.⁹² The NCSC explains that the guide “recommends that software manufacturers adopt secure-by-design and secure-by-default practices, and that customer organisations should hold their manufacturers and suppliers to these standards,” and that the guidance “serves as a cyber security roadmap for manufacturers of technology and associated products.”⁹³

⁸⁹ Id.

⁹⁰ CISA et al., *Cybersecurity Best Practices for Smart Cities* (Apr. 19, 2023), <https://perma.cc/P6YH-FGM7>.

⁹¹ *Joint Guidance: Cyber Security Best Practices for Smart Cities*, NCSC (Apr. 20, 2023), <https://perma.cc/5NLN-S5D3>.

⁹² CISA et al., *Shifting the Balance of Cybersecurity Risk: Principles and Approaches for Security-by-Design and -Default* (Apr. 13, 2023), <https://perma.cc/BXR8-8VGM>.

⁹³ *Joint Guidance: Principles for Security-by-Design and -Default*, NCSC (Apr. 14, 2023), <https://perma.cc/FYA9-7V8R>.

United Kingdom

Clare Feikert-Ahalt
Senior Foreign Law Specialist

SUMMARY The United Kingdom (UK) currently has the third highest number of artificial intelligence (AI) companies in the world. It has adopted a pro-innovation approach to AI. Rather than introducing a legislative framework and a new regulator for AI, the UK employs its existing regulators. The intent of this light-touch approach is to help enable the development and growth of the AI industry. It has introduced a National AI Strategy and is currently working on its proposed AI Framework to help provide guidance, clarity, and security for the AI industry as it develops.

While there is no AI-specific legislation, there are 18 legal frameworks containing over 50 pieces of legislation that touch upon AI. Significant pieces of legislation that impact AI are the Data Protection Act, which applies when personal data is used in AI, and equality laws to ensure that bias is not introduced into AI systems.

The National Security and Investment Act provides the government with the ability to scrutinize and intervene in acquisitions involving AI made by any legal body that could harm the UK's national security.

I. Introduction

In 2021, the United Kingdom (UK) was the top country in Europe for private investment in artificial intelligence (AI) companies.¹ It has the third highest number of AI companies in the world, behind the United States and China.² The UK government has invested 2.5 billion pounds (approximately US\$3.15 billion) in AI since 2014,³ and it is estimated that more than 1.3 million businesses in the UK will use AI and spend £110 billion (approximately US\$138 billion) on this technology by 2024.⁴

¹ Stanford U., *Artificial Intelligence Index Report 2022* (2022), <https://perma.cc/LS2X-PEQN>.

² *Guidance: National AI Strategy - HTML Version*, Dep't for Bus., Energy & Indus. Strategy (last updated Dec. 18, 2022), <https://perma.cc/EJ2D-HEVN>.

³ Dep't for Sci., Innovation & Tech., CP 815, *A Pro-Innovation Approach to AI Regulation* 1 (Mar. 2023), <https://perma.cc/5DP6-VXSJ>.

⁴ Press Release, Dep't for Digit., Culture, Media & Sport & Damian Collins MP, UK Sets Out Proposals for New AI Rulebook to Unleash Innovation and Boost Public Trust in the Technology (July 18, 2022), <https://perma.cc/F52W-5B4Z>; Andrew Evans & Anja Himann, Capital Econ., *AI Activity in UK Businesses* (Dep't for Digit., Culture, Media, and Sport Jan. 2022), <https://perma.cc/F5AG-TTAC>.

The UK government has adopted a pro-innovation position on both the governance and regulation of AI.⁵ It recently set out its commitment to international engagement “to support interoperability across different regulatory regimes.”⁶ The UK is working with international partners to help “shape approaches to AI governance under development.”⁷ It has stated that its work in this area will “reflect the UK’s views on international AI governance and prevent divergence and friction between partners, and guard against abuse of this critical technology.”⁸

II. Overview of the Legal and Policy Framework

A. Legal Framework

There is no bespoke legislative framework that regulates AI across the UK. The government has stated it believes that legislating at this stage in the development of AI “would risk placing undue burdens on businesses”⁹ that could “hold back AI innovation and reduce [its] ability to respond quickly and in a proportionate way to future technological advances.”¹⁰ Instead, it is relying on collaboration between government and business.

AI is currently “partially regulated through a patchwork of legal and regulatory requirements built for other purposes which now also capture uses of AI technologies.”¹¹ Its complexity has been noted:

There are at least 18 legal frameworks (both pervasive and sector specific legislation) that indirectly control the development and use of AI (e.g. consumer rights law, data protection law, product safety law, etc.). Within this there are over 50 individual pieces of primary legislation that must be considered. Additionally, case law interprets legislation and determines how it should be applied. This leads to a highly complex regulatory environment for AI systems that is extremely difficult to understand in its entirety for all relevant stakeholders.¹²

⁵ Dep’t for Digit., Culture, Media & Sport, CP 728, *Establishing a Pro-Innovation Approach to Regulating AI* (July 18, 2022), <https://perma.cc/4TUB-W533>.

⁶ Dep’t for Sci., Innovation & Tech., CP 815, *A Pro-Innovation Approach to AI Regulation* (Mar. 2023), *supra* note 3, at 3.

⁷ *Guidance: National AI Strategy - HTML Version*, Dep’t for Bus., Energy & Indus. Strategy, *supra* note 2.

⁸ *Id.*

⁹ Dep’t for Sci., Innovation & Tech., CP 815, *A Pro-Innovation Approach to AI Regulation* (Mar. 2023), *supra* note 3, at 3.

¹⁰ *Id.* ¶ 11.

¹¹ Dep’t for Digit., Culture, Media & Sport, *Establishing a Pro-Innovation Approach to Regulating AI*, *supra* note 5, at 5.

¹² Dep’t for Sci., Innovation & Tech., RPC-DCMS-5260(1), *Artificial Intelligence Regulation Impact Assessment* ¶ 33 (Mar. 2023), <https://perma.cc/TNE2-3857>.

Examples of cross-sector legislation that regulates aspects of the use and development of AI include the following:

- Data protection laws, which include provisions on automated decision making and data processing. Breaches of this act can result in fines of up to £17.5 million (approximately US\$22 million), or 4% of a company's global turnover.¹³
- Equality laws, which prohibit the government from discriminating, harassing, or victimizing anyone who has a protected characteristic.¹⁴
- The National Security and Investment Act 2021 provides the government with the authority to intervene in acquisitions that could harm the national security of the UK, including companies that develop AI.¹⁵

Sector-specific legislation is also in place in certain areas, such as for medical devices.¹⁶ Competition law includes provisions on protecting consumers against unfair use of AI in algorithms. Breaches of competition law can result in fines of up to 10% of a company's global turnover, imprisonment, and disqualification of company directors for up to 15 years.¹⁷

The UK is reviewing its approach to the regulation of AI. A paper by the Department for Digital, Culture, Media and Sport, presented to the Parliament in July 2022, notes "[t]he extent to which UK laws apply to AI is often a matter of interpretation, making them hard to navigate."¹⁸ The paper and the National AI Strategy, published in September 2021, state that there is a need for greater clarity in both the legal framework and among regulators to ensure there are no overlaps or gaps in areas of regulation and that regulators adopt a consistent approach to AI.¹⁹

An impact assessment on the regulation of AI noted the following:

¹³ Data Protection Act 2018 (DPA), c. 12, <https://perma.cc/5DMR-6FZV>; Information Commissioner's Office (ICO), *Guidance on AI and Data Protection* (last updated Mar. 15, 2023), <https://perma.cc/4MVP-WNTK>; ICO & Alan Turing Inst., *Explaining Decisions Made With AI*, <https://perma.cc/7WMB-8JJ2>.

¹⁴ Equality Act 2010, c. 15, <https://perma.cc/52EB-2DQ2>; and Equal. & Hum. Rts. Comm'n, HC 1206, *Strategic Plan 2022-25* (Mar. 29, 2022), <https://perma.cc/6YG8-43TT>.

¹⁵ National Security and Investment Act 2021, c. 25, <https://perma.cc/9VHY-B8UB>.

¹⁶ Medical Devices Regulations 2002, SI 2002/618, <https://perma.cc/4FSR-SRHU>. See also Med. & Healthcare Products Regul. Agency, *Guidance: Software and AI as a Medical Device Change Programme - Roadmap* (last updated Oct. 17, 2022), <https://perma.cc/H2G5-UKG6>.

¹⁷ Competition Act 1998, c. 41, <https://perma.cc/DX9D-WQJU>; Competition & Mkts. Auth., *Algorithms: How They Can Reduce Competition and Harm Consumers* (2021), <https://perma.cc/YT94-BGH6>.

¹⁸ Dep't for Digit., Culture, Media & Sport, *Establishing a Pro-Innovation Approach to Regulating AI*, *supra* note 5, at 6.

¹⁹ HM Gov't, CP 525, *National AI Strategy* (Sept. 2021), ¶ 27, <https://perma.cc/7KTD-VYM2>; Dep't for Digit., Culture, Media & Sport, *Establishing a Pro-Innovation Approach to Regulating AI*, *supra* note 5, at 6-7.

The current UK regulatory regime only partially addresses the challenges posed by the widespread adoption and use of AI. This can be summarised as ‘regulatory failure’, which arises due to the ‘complex patchwork of legal and regulatory requirements’ that are currently applied to AI systems. Two key issues summarise this regulatory failure. The first, legal and regulatory requirements are highly complex to understand and will become more so in the future. Secondly, rights, duties and responsibilities are not well defined.²⁰

The impact assessment further noted the current regime means that the development of technology is rapidly outpacing the speed at which regulatory oversight and the legislative framework can keep up.²¹ The impact assessment noted “[a] clear governance framework for AI systems, with the agility to keep up with the rapid pace of technological change, will address current issues whilst future-proofing the regulatory regime from emerging risks.”²²

While the government has stated it is not currently planning to introduce legislation to regulate AI, it has accepted that there may be a need later to “enhance regulatory powers, ensure regulatory coordination, or to create new institutional architecture.”²³

B. AI Policy

The UK has stated that it intends its approach to the regulation of AI to be context specific, pro-innovation and risk-based, coherent, and proportionate and adaptable, that is, a light- touch, forward-looking framework.²⁴ It is encouraging regulators to adopt a voluntary or guidance-based approach, which details how the principles interact with relevant legislation to aid developers and users with compliance,²⁵ and the creation of sandboxes for experimenting with technology.²⁶ It has established the Office for AI to “coordinate cross-government processes to accurately assess long term AI and safety risks.”²⁷

There are a number of government reports and policies that address, or touch upon, AI.²⁸ The government released its National AI Strategy in 2022. This is a 10-year plan that aims to help

²⁰ Dep’t for Sci., Innovation & Tech., RPC-DCMS-5260(1), *Artificial Intelligence Regulation Impact Assessment* (Mar. 2023), *supra* note 12, ¶ 32.

²¹ *Id.* ¶ 34.

²² *Id.*

²³ Dep’t for Digit., Culture, Media & Sport, *Establishing a Pro-Innovation Approach to Regulating AI*, *supra* note 5, at 17.

²⁴ *Id.* at 1.

²⁵ Dep’t for Sci., Innovation & Tech., CP 815, *A Pro-Innovation Approach to AI Regulation* (Mar. 2023), *supra* note 3, ¶ 63.

²⁶ *Id.* sec. 3.3.4.

²⁷ HM Gov’t, CP 525, *National AI Strategy* (Sept. 2021), *National AI Strategy*, *supra* note 19, at 60.

²⁸ See, e.g., National Cyber and Security Centre, *Principles for the Security of Machine Learning* (Aug. 2022), <https://perma.cc/FU2M-2A8N>; Equality and Human Rights Commission, *Strategic Plan 2022-25* (Mar. 2022), <https://perma.cc/B7LQ-JNSZ>; ICO & Alan Turing Inst., *Explaining Decisions Made with AI* (Oct. 2022) at 40, <https://perma.cc/H6PT-WLLH>; ICO, *Guidance on AI and Data Protection 14* (last updated Mar. 15, 2023), <https://perma.cc/8WJF-GCYJ>; Department for Science, Innovation & Technology, *Science & Technology*

ensure the UK continues to lead the world in both developing and harnessing AI.²⁹ The National AI Strategy sets out three pillars that aim to develop AI in the UK. Pillar 1 involves “investing in the long term needs of the AI ecosystem,” which considers the “critical inputs that underpin AI innovation.”³⁰ To do this effectively requires supporting the UK’s research, development, and innovation systems;³¹ training, attracting,³² and retaining a diverse range of skilled AI developers;³³ providing access to data and computer resources to developers;³⁴ providing a pro-innovation environment; and ensuring access to global markets for AI developers.³⁵ Under this pillar, the government aims to narrow the gap between the supply and demand for AI skills.³⁶

Pillar 2 aims to support AI to benefit the economy across all sectors and regions. To achieve this, among other things, the government will launch programs to help increase both “the development and adoption of AI technologies in high-potential, lower-AI maturity sectors”; launch a national strategy in health and social care; and publish its defense AI strategy.³⁷

Pillar 3 requires the effective governance of AI in a manner that “encourages innovation, investment, [and] protects the public and safeguards our fundamental values, while working with global partners to promote the responsible development of AI internationally.”³⁸ To help achieve this, the government has proposed an AI governance framework, discussed below, which aims to provide clarity for the regime that governs AI and

- support the development of AI assurance tools and services to provide information about AI systems to users and regulators,

Framework (2023), <https://perma.cc/KH94-TTY9>; HM Government, *National Cyber Strategy 2022* (Dec. 2022), <https://perma.cc/PU3Z-3L9Q>; Department for Culture, Media & Sport & the Department for Digital, Culture, Media & Sport, *Digital Regulation: Driving Growth and Unlocking Innovation* (last updated June 2022), <https://perma.cc/9XVU-7DTD>; Ministry of Defence, *Ambitious, Safe, Responsible: Our Approach to the Delivery of AI-enabled Capability in Defence* (June 2022), <https://perma.cc/5DS9-5NA5>.

²⁹ HM Gov’t, CP 525, *National AI Strategy* (Sept. 2021), *supra* note 19.

³⁰ *Id.* at 22.

³¹ See, e.g., Advanced Rsch. & Invention Agency et al., *Advanced Research and Invention Agency (ARIA): Policy Statement* (Mar. 19, 2021) <https://perma.cc/VM7M-3JFF>.

³² See, e.g., Home Off., *Global Business Mobility Routes: Ver. 5.0*, (May 31, 2023), <https://perma.cc/KV3D-8MQW>; *Get Support to Move Your Business to the UK - The Global Entrepreneur Program*, Great.gov.uk, <https://perma.cc/FHZ8-VETH>.

³³ See, e.g., Dep’t for Educ., CP 338, *Skills for Jobs: Lifelong Learning for Opportunity and Growth* (Jan. 2021), <https://perma.cc/4QB2-Y3QQ>.

³⁴ See further, Dep’t for Digit., Culture, Media & Sport & Dep’t for Sci., Innovation & Tech., *National Data Strategy* (last updated Dec. 9, 2020), <https://perma.cc/3DVC-GF8M>.

³⁵ HM Gov’t, CP 525, *National AI Strategy* (Sept. 2021), *supra* note 19, at 22.

³⁶ *Id.*

³⁷ *Id.* at 48.

³⁸ *Id.*

- contribute to the development of global technical standards,
- help regulators with their responsibilities for AI products and services,
- work to secure international agreements and standards for AI, and
- safely and ethically deploy AI in the government.³⁹

The current proposed AI Framework contains six cross-sectoral principles: pro-innovation, proportionate, trustworthy, adaptable, clear, and collaborative built around the following four key elements “designed to empower our existing regulators and promote coherence across the regulatory landscape”:

- defining AI based on its unique characteristics to support regulator coordination,
- adopting a context-specific approach,
- providing a set of cross-sectoral principles to guide regulator responses to AI risks and opportunities, and
- delivering new central functions to support regulators to deliver the AI regulatory framework, maximizing the benefits of an iterative approach and ensuring that the framework is coherent.⁴⁰

The framework intends to clarify the government’s expectations for responsible AI and describe good governance at all stages of the AI life cycle.⁴¹

8. Existing regulators will be expected to implement the framework underpinned by five values-focused cross-sectoral principles:

- o Safety, security and robustness
- o Appropriate transparency and explainability
- o Fairness
- o Accountability and governance
- o Contestability and redress

These build on, and reflect our commitment to, the Organisation for Economic Co-operation and Development (OECD) values-based AI principles, which promote the ethical use of AI.⁴²

³⁹ Id at 50.

⁴⁰ Dep’t for Sci., Innovation & Tech., CP 815, *A Pro-Innovation Approach to AI Regulation* (Mar. 2023), supra note 3, ¶ 38.

⁴¹ Id.

⁴² Id. ¶ 48.

The principles will initially operate on a non-statutory basis and will be implemented by current regulators based upon their areas of prioritization.⁴³ The intention behind this approach is to provide clarity and give flexibility to the regulators on how they respond while not impeding the innovation of AI.⁴⁴ The government has noted that after a period of time, it “intends to introduce a statutory obligation on regulators as a ‘duty to regard’ the principles”⁴⁵ set out in the Pro-innovation Approach to AI Regulation (2023) paper when parliamentary time allows.

The UK has also adopted a number of policy changes to help the development of AI in the UK, among them, the following:

- new visa routes for those in the AI industry,⁴⁶
- reformed research and development tax relief, including data and cloud computing costs,⁴⁷ and
- a pilot AI Standards Hub to increase the UK’s participation in the development of global technical standards for AI.⁴⁸

The government “currently sees the advantages of a ‘test and learn’ approach given the novelty of regulation in this policy area. This means evidence gathering, monitoring and evaluation will continue throughout the implementation of the framework”⁴⁹ and it has received widespread support for adopting this method.⁵⁰

III. Definition of Artificial Intelligence (AI) Systems

When considering a definition of AI, the government has stated that “no single definition is going to be suitable for every scenario.”⁵¹ The UK acknowledged the move by the European Union (EU) to provide a definition of AI, but it rejected this approach, noting that it does “not think that it captures the full application of AI and its regulatory implications. Our concern is that this lack of

⁴³ Id. ¶¶ 55, 57; Dep’t for Sci., Innovation & Tech., RPC-DCMS-5260(1), *Artificial Intelligence Regulation Impact Assessment* (Mar. 2023), supra note 12, ¶ 114.

⁴⁴ Dep’t for Sci., Innovation & Tech., CP 815, *A Pro-Innovation Approach to AI Regulation* (Mar. 2023), supra note 3, at 1.

⁴⁵ Dep’t for Sci., Innovation & Tech., RPC-DCMS-5260(1), *Artificial Intelligence Regulation Impact Assessment* (Mar. 2023), supra note 12, ¶ 5.

⁴⁶ *Work in the UK as a Leader in Digital Technology (Global Talent Visa)*, Gov.uk, <https://perma.cc/W5M4-TGUX>.

⁴⁷ *Guidance: National AI Strategy - AI Action Plan* (July 18, 2022), Gov.uk, <https://perma.cc/E4VV-BJS2>.

⁴⁸ Press Release, Dep’t for Digit., Culture, Media & Sport, Off. for A.I. & the Rt. Hon. Chris Philp MP, New UK Initiative to Shape Global Standards for Artificial Intelligence (Jan. 12, 2022), <https://perma.cc/5A4H-JYQY>.

⁴⁹ *Guidance: National AI Strategy - HTML Version*, Dep’t for Bus., Energy & Indus. Strategy, supra note 7.

⁵⁰ Dep’t for Sci., Innovation & Tech., RPC-DCMS-5260(1), *Artificial Intelligence Regulation Impact Assessment* (Mar. 2023), supra note 12, ¶ 75.

⁵¹ *Guidance: National AI Strategy - HTML Version*, Dep’t for Bus., Energy & Indus. Strategy, supra note 7.

granularity could hinder innovation.”⁵² There are multiple definitions of AI across different government papers and in legislation.

The AI Strategy defines AI broadly as “[m]achines that perform tasks normally performed by human intelligence, especially when the machines learn from data how to do those tasks.”⁵³ The government has stated this definition is “sufficient for our purposes.”⁵⁴

The proposed AI framework defines AI by reference to the two functional characteristics that cause the need for a unique regulatory response: adaptability and autonomy. Specifically,

- The ‘adaptivity’ of AI can make it difficult to explain the intent or logic of the system’s outcomes:
 - AI systems are ‘trained’ – once or continually – and operate by inferring patterns and connections in data which are often not easily discernible to humans.
 - Through such training, AI systems often develop the ability to perform new forms of inference not directly envisioned by their human programmers.
- The ‘autonomy’ of AI can make it difficult to assign responsibility for outcomes:
 - Some AI systems can make decisions without the express intent or ongoing control of a human.⁵⁵

A legal definition of artificial intelligence is contained in schedule 3 of the National Security and Investment Act 2021 (Notifiable Acquisition) (Specification of Qualifying Entities) Regulations 2021, which the government notes is different to the definition contained in the AI Strategy “due to the clarity needed for legislation.”⁵⁶ The definition states,

“artificial intelligence” means technology enabling the programming or training of a device or software to –

- (i) perceive environments through the use of data;
- (ii) interpret data using automated processing designed to approximate cognitive abilities; and
- (iii) make recommendations, predictions or decisions; with a view to achieving a specific objective[.]⁵⁷

⁵² Dep’t for Digit., Culture, Media and Sport, *Establishing a Pro-Innovation Approach to Regulating AI*, supra note 5, at 8.

⁵³ *Guidance: National AI Strategy - HTML Version*, Dep’t for Bus., Energy & Indus. Strategy, supra note 7.

⁵⁴ *Id.*

⁵⁵ Dep’t for Sci., Innovation & Tech., CP 815, *A Pro-Innovation Approach to AI Regulation* (Mar. 2023), supra note 3, ¶ 39.

⁵⁶ *Guidance: National AI Strategy - HTML Version*, Dep’t for Bus., Energy & Indus. Strategy, supra note 7.

⁵⁷ National Security and Investment Act 2021 (Notifiable Acquisition) (Specification of Qualifying Entities) Regulations 2021, SI 2021/1264, sch. 3, <https://perma.cc/3TPH-Y6YK>.

IV. Cybersecurity of AI

The current proposed regulatory framework intends that the trustworthiness of AI will be achieved through using tools such as “assurance techniques, voluntary guidance and technical standards.”⁵⁸ The Centre for Data Ethics and Innovation has compiled a portfolio of assurance techniques that can be used by those in the AI industry. The portfolio provides “examples of AI assurance techniques being used in the real-world to support the development of trustworthy AI.”⁵⁹

An Impact Assessment on AI notes that the rights, duties, and responsibilities relating to AI in the UK are not well defined. It states, “[k]ey gaps in the UK’s current legal frameworks relate to individual rights, safety standards specific to AI, transparency, human involvement, accountability, and rights to redress.”⁶⁰ This leads to uncertainty over liability for an AI system, which “means businesses cannot be certain whether they may be liable for harms related to the implementation of an AI system. It can also create a lack of trust in AI systems by consumers, as they are not aware of who is ultimately responsible if an AI system causes harm.”⁶¹

A. Data and Data Governance

To help protect against adversarial machine learning, the National Cyber and Security Centre published the *Principles for the Security of Machine Learning* in August 2022. The principles, which apply to “anyone developing, deploying or operating a system with a machine learning component” aim to “provide context and structure to help scientists, engineers, decision makers and risk owners make education decisions about system design and development processes, helping to assess the specific threats to a system.”⁶²

The principles during development are the following:

- Enable your developers, which means that threats specific to machine learning systems are understood by developers, who should have appropriate tools to assess vulnerabilities.
- Design for security, which means being able to identify whether the system has an error caused by an attack or another reason, what should occur after an error, and what mitigations should be put in place to prevent such an error from occurring.

⁵⁸ Dep’t for Sci., Innovation & Tech., CP 815, *A Pro-Innovation Approach to AI Regulation* (Mar. 2023), *supra* note 3, ¶ 16.

⁵⁹ *Guidance CDEI Portfolio of AI Assurance Techniques*, Gov.uk (June 7, 2023), <https://perma.cc/6EL8-TJ9B>.

⁶⁰ Dep’t for Sci., Innovation & Tech., RPC-DCMS-5260(1), *Artificial Intelligence Regulation Impact Assessment*, (Mar. 2023), *supra* note 12, ¶ 35.

⁶¹ *Id.* ¶ 36.

⁶² Nat’l Cyber Sec. Ctr., *Principles for the Security of Machine Learning* (Aug. 2022), <https://perma.cc/FU2M-2A8N>.

- Minimize an adversary's knowledge, which means understanding the risks of disclosing information and making "a balanced assessment of the benefits and risks of sharing information about [the] systems."⁶³
- Design for security (vulnerabilities), which means that the vulnerability of the system should be continually assessed against the risks.
- Secure the supply chain, which means that trusted sources should be used for data and models and validation and verification processes should be used to mitigate risks and mistakes. This can help against data poisoning, where an adversary can mislabel or insert triggers that can result in degraded performance or a loss of integrity in the output.
- Secure your infrastructure (development environment), which means that security should be introduced for the training and development environment for the model and anything or anyone that enters this environment. Thus, appropriate quality assurance and quality control processes should be in place for the supply chain.
- Secure your infrastructure (digital assets), which means digital assets should be protected at all stages.
- Track your asset, which means that the creation, operation and life of models and datasets should be documented. Any changes should be monitored and recorded.
- Design for security (model architecture), which means that the model architecture and capacity should be kept proportionate to the dataset size and requirements.⁶⁴

The principles during deployment are

- Secure your infrastructure (deployment), which means that the implications of the information available to users about the model should be considered and limited.
- Design for security, which means that the use of the database should be monitored, user requests should be logged, and consideration should be given to implementing an alert system for potential compromise.
- Minimize an adversary's knowledge, which means that a balance between transparency and security should be determined.⁶⁵

The principles during operation are

- Design for security, which means that, if continual learning is used, its risks are understood, and that systems and processes are in place to help prevent an adversary from impacting the model's behavior.

⁶³ Id. at 11.

⁶⁴ Id.

⁶⁵ Id.

- Track your asset, which means that when continual learning is conducted, updates should be validated in the same manner as new models or datasets.⁶⁶

The principles during the end of life are

- Minimize an adversary's knowledge, which means that assets should be appropriately decommissioned through archiving or destruction.
- Enable your developers, which means that information learned from the development and operation of the model should be documented and shared.⁶⁷

B. Recordkeeping

The UK General Data Protection Regulation (UK GDPR) contains a recordkeeping requirement for personal data, which is intended to help businesses comply with the law and let individuals know how their data is being used and with whom it is being shared. The government believes that the recordkeeping requirement, in its current form, is burdensome and duplicative of other requirements in the UK GDPR. The government notes that while the recordkeeping requirement will be removed, organizations will still need to document the purposes for which data is being processed, and it is currently working to create a new, flexible system that “encourages organisations to focus on the design of their privacy management programme.”⁶⁸

C. Transparency and Provision of Information to Users

To ensure appropriate standards of transparency and understandability, the government has stated that it anticipates regulators will need to set expectations for those involved in AI to provide information about

- the nature and purpose of the AI in question including information relating to any specific outcome,
- the data being used and information relating to training data,
- the logic and process used and where relevant information to support explainability of decision-making and outcomes,
- accountability for the AI and any specific outcomes.⁶⁹

Regulators should consult the existing technical standards to set requirements for understandability “to ensure appropriate balance between information needs for regulatory enforcement (e.g. around safety) and technical tradeoffs with system robustness.”⁷⁰ The proposed

⁶⁶ Id.

⁶⁷ Id.

⁶⁸ Dep’t for Digit., Culture, Media & Sport, *Data: A New Direction – Government Response to Consultation* (last updated June 23, 2022), <https://perma.cc/WPM7-WBG8>.

⁶⁹ Dep’t for Sci., Innovation & Tech., CP 815, *A Pro-Innovation Approach to AI Regulation* (Mar. 2023), *supra* note 3, Annex A.

⁷⁰ Id.

framework notes that the level of transparency and understandability should be proportionate to the risks posed by the AI system.⁷¹

When personal data is used in AI, the Information Commissioner's Office (ICO) notes that, to ensure a decision made with AI is explainable, certain principles should be followed.

To ensure that the decisions you make using AI are explainable, you [the operator] should follow four principles:

- be transparent;
- be accountable;
- consider the context you are operating in; and,
- reflect on the impact of your AI system on the individuals affected, as well as wider society.⁷²

The ICO has provided six ways that an AI decision can be explained.

- **Rationale explanation:** the reasons that led to a decision, delivered in an accessible and non-technical way.
- **Responsibility explanation:** who is involved in the development, management and implementation of an AI system, and who to contact for a human review of a decision.
- **Data explanation:** what data has been used in a particular decision and how.
- **Fairness explanation:** steps taken across the design and implementation of an AI system to ensure that the decisions it supports are generally unbiased and fair, and whether or not an individual has been treated equitably.
- **Safety and performance explanation:** steps taken across the design and implementation of an AI system to maximise the accuracy, reliability, security and robustness of its decisions and behaviours.
- **Impact explanation:** steps taken across the design and implementation of an AI system to consider and monitor the impacts that the use of an AI system and its decisions has or may have on an individual, and on wider society.⁷³

D. Human Oversight

A review by the Committee on Standards in Public Life states, “[h]uman oversight of AI is a standards imperative. To ensure that public bodies remain accountable for automated decision-making, there needs to be internal control over the AI system, its decision-making process and its outcomes.”⁷⁴ The report found that the type of oversight mechanisms that should be in place depended upon systems and risks posed, noting that if the risk is low, oversight by senior

⁷¹ Id. ¶ 52.

⁷² ICO & Alan Turing Inst., *Explaining Decisions Made with AI*, supra note 13, at 40.

⁷³ Id. at 21.

⁷⁴ Comm. on Standards in Public Life, *Artificial Intelligence and Public Standards* ¶ 5.5.3 (Feb. 2020), <https://perma.cc/44S6-5CDL>.

management would be sufficient, but in higher risk areas “external scrutiny may be necessary.”⁷⁵ The report further noted “[t]o have complete control over their AI systems, senior leadership need to have oversight over the whole AI process, from the point of data entry to the implementation of an AI-assisted decision.”⁷⁶

While there is no specific mention of human oversight in the proposed AI framework, it does note that clear lines of accountability should be provided for across the AI life cycle.⁷⁷ With regard to accountability, the proposed framework provides that any guidance issued from regulators “should reflect that ‘accountability’ refers to the expectation that organisations or individuals will adopt appropriate measures to ensure the proper functioning, throughout their life cycle, of the AI systems that they research, design, develop, train, operate, deploy, or otherwise use.”⁷⁸ The government notes that the establishment of lines of ownership and accountability is essential to provide business certainty and help ensure regulatory compliance.⁷⁹

References to human oversight are made with reference to the use of AI and its interaction with personal data in the UK GDPR, as human interaction in AI systems means that it is not a solely automated process and different provisions of the act apply, as discussed below.⁸⁰

E. Risk Management System

The British Standards Institute (BSI) and the AI Standards Hub has worked with the international AI committee to develop technical standards for AI. It is also active at the European level in CEN-CENELEC/JTC 21. The BSI notes that one of the key standards it has worked on developing is for risk management in AI, ISO/IEC 23894,⁸¹ which was published in February 2022.⁸² The AI Standards Hub notes that, while general principles can be relied upon, there is a

need to flag key considerations for risk in the AI lifecycle. AI systems operate on a far more complex level than other technologies, resulting in a greater number of sources of risk. They will introduce new or emerging risks for organisations, with positive or negative implications for strategic objectives, and changes to existing risk profiles.⁸³

⁷⁵ Id.

⁷⁶ Id.

⁷⁷ Id. ¶ 52.

⁷⁸ Id.

⁷⁹ Id.

⁸⁰ (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 art. 22, <https://perma.cc/MP6N-EF7W>. When the UK left the EU, it incorporated all EU law as it existed on December 31, 2020, into a new body of domestic law known as “retained EU legislation.” References to the UK GDPR throughout this report refer to the EU GDPR incorporated in the domestic law of the UK.

⁸¹ *Artificial Intelligence Standards Development*, British Standards Inst., <https://perma.cc/88D3-8JZ6>.

⁸² ISO, ISO/IEC 23894:2023(en) Information Technology – Artificial Intelligence – Guidance on Risk Management, <https://perma.cc/BU6R-KWK8>.

⁸³ Tim McGarr, *ISO/IEC 23894 – A New Standard for Risk Management of AI*, AI Standards Hub, <https://perma.cc/4XF9-EZSL>.

The AI Standards Hub has noted that the AI standards currently in development

are only starting to address questions in the wide-ranging area of safety, security and resilience. Additional standards development efforts will be needed to mitigate the significant cyber security risks society faces each day. For example, much is covered by established IT standards (e.g., ISO/IEC 27001 in Cyber Security), but it is likely that we will need a bespoke version of 27001 for the AI domain.⁸⁴

F. Conformity Assessments

While the UK is no longer part of the EU, laws of the EU still impact the country. The government has stated, “AI providers need to ensure that their effort is correctly oriented to the full compliance with the EU AI Act.”⁸⁵ BSI is working to help those who will be regulated by the EU AI Act by providing readiness assessments and algorithm testing.⁸⁶ One example of this is that BSI is accredited as a notified body for medical devices and in vitro diagnostic devices, and it is working to ensure that AI parts and components of medical devices it is responsible for as this body are compliant with the new rules contained in the EU AI Act.⁸⁷

G. Robustness

The government has determined that regulators will need to introduce guidance to ensure safety, security and robustness for AI. This guidance should include

- considerations of good cybersecurity practices, such as the NCSC principles for the security of machine learning, as a secured system should be capable of maintaining the integrity of information.
- considerations of privacy practices such as accessibility only to authorised users and safeguards against bad actors.⁸⁸

The government recommends that legal persons review existing technical standards to address AI safety, security, testing, data quality and robustness. It intends to ensure that regulatory guidance on these standards is clarified.⁸⁹ To ensure robustness, developers of AI should be aware “of the specific security threats that could apply at different stages of the AI lifecycle and embed

⁸⁴ Tim McGarr, *Safety, Security and Resilience in Trustworthy AI*, AI Standards Hub, <https://perma.cc/V2EW-Y4Y7>.

⁸⁵ *British Standards Institution: EU AI Act Readiness Assessment and Algorithmic Auditing*, Gov.uk (June 6, 2023), <https://perma.cc/2AYN-V224>.

⁸⁶ *Id.*

⁸⁷ *Id.*

⁸⁸ Dep’t for Sci., Innovation & Tech., CP 815, *A Pro-Innovation Approach to AI Regulation* (Mar. 2023), *supra* note 3, Annex A.

⁸⁹ *Id.* Examples given are standards ISO/IEC 24029-2*, ISO/IEC 5259-1*, ISO/IEC 5259-3*, ISO/IEC 5259-4*, & ISO/IEC TR 5469*.

resilience to these threats into their systems.”⁹⁰ The proposed framework notes that, when implementing this principle, regulators may require regular tests or

due diligence on the functioning, resilience and security of a system. Regulators may also need to consider technical standards addressing safety, robustness and security to benchmark the safe and robust performance of AI systems and to provide AI life cycle actors with guidance for implementing this principle in their remit.⁹¹

The UK has also established a National Cyber Strategy that aims to address cyber security issues, including AI. The aim of this strategy is to ensure the security and resilience of the UK’s cyberspace.⁹²

H. Personal Data Protection

The UK incorporated the EU’s General Data Protection Regulation (EU GDPR)⁹³ into its national law through the Data Protection Act 2018 (DPA) on May 23, 2018, and, upon leaving the EU, the majority of EU legislation as it stood on December 31, 2020, was incorporated into a new body of domestic UK law, known as retained EU legislation.⁹⁴ The ICO has noted that the data protection law does not define AI, so the legal obligations are not dependent upon how it is defined.⁹⁵ However, the DPA does apply to AI systems.

The DPA regulates how personal information may be processed, “requiring personal data to be processed lawfully and fairly, on the basis of the data subject’s consent or another specified basis.”⁹⁶ The following are the six lawful bases for processing data:

- where an individual has given valid consent to data processing for a specific purpose,
- if the processing is necessary for contractual purposes,
- to enable compliance with a legal obligation,
- if it is necessary to protect someone’s life,
- to perform a task in the public interest, or
- if the processing is necessary for the official functions of the processor and there is not a good, overriding reason to protect the personal data.⁹⁷

⁹⁰ Id. ¶ 52.

⁹¹ Id.

⁹² HM Government, *National Cyber Strategy 2022* (Dec. 2022), <https://perma.cc/PU3Z-3L9Q>.

⁹³ EU GDPR.

⁹⁴ DPA, c. 12.

⁹⁵ ICO, *Guidance on AI and Data Protection*, *supra* note 13.

⁹⁶ DPA, c. 12, § 2(1)(a).

⁹⁷ ICO, *Age Appropriate Design: A Code of Practice for Online Services Annex C* (Sept. 2, 2020), <https://perma.cc/376E-YMNX>.

The DPA requires that any data collected should be limited in scope, necessary for the reasons it is processed, accurate, and kept up to date. It also requires providers of information society services (ISS) adopt a risk-based approach when “using people’s data, based on certain key principles, rights and obligations.”⁹⁸ AI systems should only collect and process personal information that is necessary to achieve the intended purpose. Collecting excessive or irrelevant data should be avoided where possible. AI systems should be designed with privacy in mind and techniques that enhance privacy, which include data encryption, should be implemented to minimize the risks to individuals’ personal data. Organizations must also ensure that how AI systems process personal data is transparent and that individuals are informed about the existence of automated decision-making, including the logic used in making decisions, and the significance and potential consequences of the data processing.⁹⁹

In its guidance, the ICO notes that, due to AI often involving the systematic and extensive processing of personal data, profiling and automated decision-making, “[i]n the vast majority of cases, the use of AI will involve a type of processing likely to result in a high risk to individuals’ rights and freedoms, and will therefore trigger the legal requirement for you to undertake a [Data Protection Impact Assessment] DPIA.”¹⁰⁰ A DPIA involves assessing the necessity and proportionality of the data processing and what risks are posed to the rights and freedoms. A DPIA must specify how data will be collected, stored, and used; the volume, type, and sensitivity of the data; the relationship to the individuals whose data is held; the outcome for the individuals, wider society, and the data processor; and whether there are alternatives to AI that pose less risk and, if so, why these were not used.¹⁰¹ Failing to conduct a DPIA can result in sanctions from the ICO.

The ICO has published guidance on data protection compliance and the use of AI. It has noted the general requirements of data protection law mean that a risk-based approach to AI should be used, which means

- assessing the risks to the rights and freedoms of individuals that may arise when you use AI; and
- implementing appropriate and proportionate technical and organisational measures to mitigate these risks.¹⁰²

If these risks cannot be sufficiently mitigated, the ICO has stated this means a planned AI project may have to be halted.¹⁰³ The ICO notes that it has compiled a number of risk areas, the impact of AI in these areas, and the measures that can be taken to “identify, evaluate, minimize, monitor and control these risks,” but it has specified that, due to some risk controls being context specific,

⁹⁸ Id. at 10.

⁹⁹ EU GDPR art. 25.

¹⁰⁰ ICO, *Guidance on AI and Data Protection*, supra note 13. See also ICO, *Data Protection Impact Assessments* (Mar. 15, 2023), <https://perma.cc/8WJF-GCYJ>.

¹⁰¹ ICO, *Guidance on AI and Data Protection*, supra note 13.

¹⁰² ICO, *Data Protection Impact Assessments*, supra note 100, at 7.

¹⁰³ Id.

these are not an exhaustive list of examples.¹⁰⁴ It has stated that a zero tolerance approach to risk is not appropriate or necessary under the law. The only thing necessary is to identify, manage, and mitigate the risks posed by the use of data.¹⁰⁵

1. *Solely Automated Decision-Making*

Article 22 of the UK GDPR provides individuals with the right to be informed of the existence of solely automated decision-making that produces legal, or significantly similar, effects as well as information about the logic involved in the decision-making process and the significance of the consequences of the decision-making on the individual.¹⁰⁶ Individuals also have the right to access information on the existence of a solely automated decision-making process, meaning there is no human involvement, that produces legal or similarly significant legal effects, and information about the logic involved in the decision-making and the potential consequences for the individual. The UK GDPR provides individuals with the right to object to the processing of their personal data in certain circumstances, including solely automated decision-making processes, with limited exceptions.¹⁰⁷

In cases of AI where there is human involvement and, therefore, it is not a solely automated process, the provisions of the DPA continue to apply, including fairness, transparency, and accountability. This means that compliance with the principles contained in Article 5 of the GDPR must be demonstrated, and the data holder must be able to show that the individual whose data was used was treated fairly and in a transparent manner when a decision assisted by AI was made about them.¹⁰⁸

2. *Fairness*

The government has noted that the concept of fairness in the DPA applies to both AI systems and their use, but that this concept is “highly context-specific . . . and concepts of fairness exist in a variety of legislative frameworks, [so] navigating fairness in the context of AI is a complex exercise. Fairness has an evolving meaning in the context of the use of machine learning and AI, and there is a question of how unfair outcomes resulting from the use of AI systems can be prevented.”¹⁰⁹ A recent government consultation found that the data protection regime was not sufficiently clear with regard to fairness in the obligations it imposes on bodies that are developing and deploying AI systems, but the government does not plan to introduce legislation on this matter.¹¹⁰

¹⁰⁴ Id.

¹⁰⁵ Id.

¹⁰⁶ EU GDPR art. 22.

¹⁰⁷ ICO & Alan Turing Inst., *Explaining Decisions Made with AI*, supra note 13, at 12.

¹⁰⁸ Id. at 13.

¹⁰⁹ Dep’t for Digit., Culture, Media & Sport, *Data: A New Direction – Government Response to Consultation*, supra note 68.

¹¹⁰ Id.

3. *Bias*

The Equality Act applies to the government and a wide range of organizations, including education providers, employers, associations, membership bodies, service providers and those who provide public functions. There are nine characteristics that are protected by the act, which are

- age,
- disability,
- gender reassignment,
- marriage and civil partnership,
- race,
- pregnancy and maternity,
- religion and belief,
- sex, and
- sexual orientation.

Any behavior that discriminates, harasses, or victimizes a person due to one or more of these characteristics is prohibited.

To ensure that AI does not discriminate due to any of these characteristics, it must be demonstrated that the AI system does not cause “the decision recipient to be treated worse than someone else because of one of these protected characteristics; or results in a worse impact on someone with a protected characteristic than someone without one.”¹¹¹

To help address concerns of bias in AI system, the government intends to introduce a new condition to schedule 1 of the DPA “to enable the processing of sensitive personal data for the purpose of monitoring and correcting bias in AI systems. The new condition will be subject to appropriate safeguards, such as limitations on re-use and the implementation of security and privacy preserving measures when processing for this purpose.”¹¹² BSI is also working on the development of ISO/IEC TR 24027 to address bias in AI systems and AI-aided decision-making.¹¹³

4. *Storing Personal Data*

Any personal data collected must be stored in a manner that enables the identification of the data subject and held for no longer than necessary. Personal data must be processed in a way that

¹¹¹ ICO & Alan Turing Inst., *Explaining Decisions Made with AI*, supra note 13, at 14.

¹¹² Dep’t for Digit., Culture, Media & Sport, *Data: A New Direction – Government Response to Consultation*, supra note 68.

¹¹³ *Artificial Intelligence Standards Development*, British Standards Inst., supra note 81.

ensures the security of the data and protects against unauthorized processing, accidental loss, destruction, or damage. The DPA places a duty on the data controller to ensure the principles of the DPA are complied with and demonstrate how this compliance is achieved.¹¹⁴ The DPA also provides for regulatory oversight of its provisions and enforcement mechanisms to ensure it is implemented properly.

V. Adherence to Standardized Risk Management Frameworks

The UK is actively engaged in developing international standards for the use of AI, with BSI and the AI Standard Hub working to contribute to the development of global technical standards. The AI Standards Hub aims to provide tools, guidance, and educational materials for developers and users of AI and increase compliance with the standards.¹¹⁵ The government has noted “[s]tandards are often used as ‘soft law’ in codes of conduct/practice and binding/non-binding guidance, but it can also be designated as voluntary tools to show legal compliance.”¹¹⁶ The proposed framework states these standards

can be used by regulators to complement sector-specific approaches to AI regulation by providing common benchmarks and practical guidance to organisations. Overall, technical standards can embed flexibility into regulatory regimes and drive responsible innovation by helping organisations to address AI-related risks.¹¹⁷

The National AI Strategy notes that technical standards help embed “transparency and accountability in the design and deployment of technologies. AI technical standards (e.g. for the accuracy, explainability and reliability) should ensure that safety, trust and security are the heart of AI products and services.”¹¹⁸

VI. AI Security Policy Across the Supply Chain

The government has stated there are difficulties posed when regulating the AI supply chain, notably that overregulation could potentially stifle innovation.

AI supply chains can be complex and opaque, making effective governance of AI and supply chain risk management difficult. Inappropriate allocation of AI risk, liability, and responsibility for AI governance throughout the AI life cycle and within AI supply chains could impact negatively on innovation.¹¹⁹

¹¹⁴ DPA, pt. 2, c. 2.

¹¹⁵ Press Release, Dep’t for Digit., Culture, Media & Sport, Off. for A.I. & the Rt. Hon. Chris Philp MP, New UK Initiative to Shape Global Standards for Artificial Intelligence (Jan. 12, 2022), *supra* note 48.

¹¹⁶ Dep’t for Digit., Culture, Media and Sport, *Establishing a Pro-Innovation Approach to Regulating AI*, *supra* note 5, at 6.

¹¹⁷ Dep’t for Sci., Innovation & Tech., CP 815, *A Pro-Innovation Approach to AI Regulation* (Mar. 2023), *supra* note 3, ¶ 111.

¹¹⁸ HM Gov’t, CP 525, *National AI Strategy* (Sept. 2021), *supra* note 19, at 56.

¹¹⁹ Dep’t for Sci., Innovation & Tech., CP 815, *A Pro-Innovation Approach to AI Regulation* (Mar. 2023), *supra* note 3, ¶ 81.

The proposed framework notes that it is too soon to introduce new measures to regulate the AI supply chain as “[i]t is not yet clear how responsibility and liability for demonstrating compliance with the AI regulatory principles will be or should ideally be, allocated to existing supply chain actors within the AI life cycle.”¹²⁰ The government intends to rely on assurance techniques and technical standards to support supply chain risk management to help build trust in AI systems.¹²¹

The *Principles for the Security of Machine Learning* notes that securing the supply chain for the sources of data is of significant importance to ensure that AI is working with accurate information. It advises that the validation and verification process for creation and acquisition of datasets can both protect against data poisoning and help businesses “understand and mitigate mistakes or biases in a dataset that can impact performance.”¹²²

VII. National Security and AI

The National Security and Investment Act 2021 (2021 Act) establishes a mandatory notification system for the acquisition of artificial intelligence and provides the government with the authority to intervene in any acquisitions that could harm the national security of the UK. The government intends that, in the area of AI, the 2021 Act will “mitigate risks arising from a small number of potentially concerning actors.”¹²³

The 2021 Act covers 17 areas of the economy, which are referred to as notifiable acquisitions, and includes artificial intelligence, as defined in the National Security and Investment Act 2021 (Notifiable Acquisition) (Specification of Qualifying Entities) Regulations 2021. One of the reasons the government has included AI on the notifiable acquisition list is because it is “inherently dual-use and potentially easy to repurpose.”¹²⁴ The government has stated, “[t]he opportunity to use AI positively across the UK economy can only be harnessed if sensitive and critical applications of AI can be protected.”¹²⁵

Under the 2021 Act, AI is a notifiable acquisition if a legal person, excluding individuals, such as a company, limited liability partnership, partnership, trust, unincorporated association or a trust gains control of a qualifying entity. The 2021 Act applies to entities formed overseas if they conduct activities in the UK, or supply goods or services to individuals in the UK.¹²⁶ The term “qualifying asset” is defined in the 2021 Act as land, tangible (corporeal in Scotland) moveable property, or “ideas, information or techniques which have industrial, commercial or other

¹²⁰ Id. ¶ 82.

¹²¹ Id. ¶ 84.

¹²² Nat’l Cyber Sec. Ctr., *Principles for the Security of Machine Learning* (Aug. 2022), supra note 62, at 15.

¹²³ *Guidance: National AI Strategy - HTML Version*, Dep’t for Bus., Energy & Indus. Strategy, supra note 7.

¹²⁴ Cabinet Off., *Guidance: National Security and Investment Act: Details of the 17 Types of Notifiable Acquisitions* (last updated Apr. 27, 2023), <https://perma.cc/879E-2K5R>.

¹²⁵ Id.

¹²⁶ National Security and Investment Act 2021, c. 25, § 7.

economic value.”¹²⁷ The 2021 Act provides a number of examples for the latter category that cover trade secrets, databases, source code, algorithms, formulae, designs, plans, drawings and specifications, and software.¹²⁸

A legal person gains a control of an entity where it increases the percentage of shares, or voting rights, it holds from 25% or less to more than 25%; from 50% or less to more than 50% or from less than 75% to 75% or more; acquires voting rights that “enable the person to secure or prevent the passage of any class of resolution governing the affairs of the entity”; or where the acquisition results in a new ability of the legal person to materially influence the policy of the entity.¹²⁹ In cases where the acquisition does not meet the mandatory notification requirements, a voluntary notification regime exists. If a legal person believes that its acquisition may raise national security concerns, it can voluntarily notify the secretary of state.

The government has set out a test to help determine whether an acquisition is a notifiable acquisition.

- does the qualifying entity carry on research into, or develop or produce goods, software or technology that use AI?
- is the AI work of the qualifying entity used for one of the following applications: identification or tracking, advanced robotics or cyber security?¹³⁰

If both questions are answered affirmatively, the government must be notified of the acquisition.¹³¹ It must then review it and can either clear it, impose conditions, or unwind or block the acquisition in its entirety.

The secretary of state may also give a “call-in notice” to undertake a national security assessment when it is believed an event that triggers the provisions of the 2021 Act has occurred, is in progress, or is being contemplated and it has not received a notification. These notices may be issued up to five years after the event occurred, provided they are made within six months of the secretary of state becoming aware of the event.¹³²

During the time the acquisition is being assessed, the secretary of state has the power to “impose interim remedies in order to ensure that the effectiveness of the national assessment or subsequent remedies is not prejudiced by action taken by the parties.”¹³³ At the end of the assessment, the secretary of state may notify the parties that no risk has been found and the

¹²⁷ Id.

¹²⁸ Id.

¹²⁹ Id. § 8.

¹³⁰ Cabinet Off., *Guidance: National Security and Investment Act: Details of the 17 Types of Notifiable Acquisitions* (last updated Apr. 27, 2023), *supra* note 124; National Security and Investment Act 2021 (Notifiable Acquisition) (Specification of Qualifying Entities) Regulations 2021, sched. 3, ¶ 2.

¹³¹ Cabinet Off., *Guidance: National Security and Investment Act: Details of the 17 Types of Notifiable Acquisitions* (last updated Apr. 27, 2023), *supra* note 124.

¹³² Id.

¹³³ National Security and Investment Act 2021, Explanatory Notes, ¶ 37.

acquisition may proceed, or that there is a national security risk and that an order has been made to either prevent, remedy or mitigate the risk. Once an order has been made, it must be kept under review, and it can be varied or revoked. Parties to the acquisition that are subject to an order may request that the order be reviewed and also have a right to apply to the High Court for judicial review of the decision, which must be filed within 28 days. The secretary of state, with approval from the Treasury, may provide financial assistance, such as a loan, guarantee or indemnity to a legal entity that has a final order made against it.¹³⁴

If a legal person completes a notifiable acquisition and fails to inform the government and obtain approval, the acquisition is void, and the legal person acquiring it can face civil or criminal penalties, which can result in either imprisonment for up to five years, a fine, or both.¹³⁵ Failing to comply with an order can also result in either imprisonment for up to five years, a fine, or both.¹³⁶

VIII. Regulatory Bodies

The UK has stated that it currently does not intend to create a central regulatory body for AI.¹³⁷ Instead, it is adopting a cross-sector approach, using existing regulators that “take a tailored approach to the uses of AI in a range of settings.”¹³⁸ To ensure proper access to contestability and redress for issues that may arise with AI, the government has stated that the regulators should create, or update, guidance with information on where complaints should be directed for those who have been adversely impacted by AI.¹³⁹

The proposed AI framework envisages that where regulators discover gaps, they will work with the government to determine potential actions to correct it, such as updates to the Regulators Code, or new legislation.¹⁴⁰ To help provide oversight to ensure the regulatory approach to the implementation of the framework is working well, the government intends to introduce a central monitoring and evaluation framework to ensure that the cross-sector approach functions effectively.¹⁴¹

¹³⁴ Id. c. 25 § 30.

¹³⁵ Id. § 32. See also Cabinet Off., *Guidance: Check If You Need to Tell the Government About an Acquisition That Could Harm the UK's National Security* (last updated Apr. 27, 2023), <https://perma.cc/JD6Q-73CW>.

¹³⁶ National Security and Investment Act 2021, c. 25 § 33.

¹³⁷ Dep't for Sci., Innovation & Tech., RPC-DCMS-5260(1), *Artificial Intelligence Regulation Impact Assessment*, (Mar. 2023), supra note 12, ¶ 114.

¹³⁸ Press Release, Dep't for Digit., Culture, Media & Sport & Damian Collins MP, UK Sets Out Proposals for New AI Rulebook to Unleash Innovation and Boost Public Trust in the Technology (July 18, 2022), supra note 4.

¹³⁹ Dep't for Sci., Innovation & Tech., CP 815, *A Pro-Innovation Approach to AI Regulation* (Mar. 2023), supra note 3, Annex A.

¹⁴⁰ Id. ¶ 65.

¹⁴¹ Id.

Although the government is working to provide clarity for regulators, the Regulation of AI Impact Assessment notes potential deficiencies in the current approach. It states that the different regulators may have varying interpretations of the law, which might lead to both uncertainty and an inefficient overlap between the responsibilities of different regulators. The assessment gives the example that both the Equality and Human Rights Commission and the ICO “purport to regulate the discriminatory effects of AI.”¹⁴² Other concerns that have been raised regarding the use of current regulators include a lack of technical expertise and the variety of powers the regulators have at their disposal.¹⁴³

To help mitigate the risks posed by AI not falling solely within the remit of one regulator, the government is establishing a “central, cross-economy risk function” that allows the government to identify, “assess and prioritise AI risks, ensuring that any intervention is proportionate and consistent with levels of risk mitigation activity elsewhere across the economy or AI life cycle.”¹⁴⁴ The central risk framework will be designed with existing regulators and, where a risk has been identified and prioritized that does not fall within the remit of the current regulators, the central risk function will identify measures to address the gap. The central risk function will also serve to help smaller regulators that do not have technical AI expertise understand the risks posed by AI.¹⁴⁵

¹⁴² Dep’t for Sci., Innovation & Tech., RPC-DCMS-5260(1), *Artificial Intelligence Regulation Impact Assessment* (Mar. 2023), *supra* note 12, ¶ 35.

¹⁴³ *Id.*

¹⁴⁴ Dep’t for Sci., Innovation & Tech., CP 815, *A Pro-Innovation Approach to AI Regulation* (Mar. 2023), *supra* note 3, Box 3.2.

¹⁴⁵ *Id.*

Table of Primary Sources

Jurisdiction	Type of Source	Citation	URL
Australia	Statute	Corporations Act 2001 (Cth)	https://perma.cc/5S7W-CTXW
		Criminal Code Act 1995 (Cth)	https://perma.cc/9YWA-732B
		Privacy Act 1988 (Cth)	https://perma.cc/TP5W-Z238
		Security of Critical Infrastructure Act 2018 (Cth)	https://perma.cc/QX3Y-QZHL
		Telecommunications (Interception and Access) Act 1979 (Cth)	https://perma.cc/42DG-GN2G
		Telecommunications Act 1997 (Cth)	https://perma.cc/P85S-MMK8 (vol 1), https://perma.cc/ET5H-TFCF (vol 2)
	Regulation	Security of Critical Infrastructure (Application) Rules (LIN 22/026) 2022 (Cth)	https://perma.cc/FN7T-N64L
		Security of Critical Infrastructure (Critical infrastructure risk management program) Rules (LIN 23/006) 2023 (Cth)	https://perma.cc/BU5H-8GTT
Canada	Statute	An Act respecting cyber security, amending the Telecommunications Act and making consequential amendments to other Acts (Bill C-26), 44th Parliament, 1st Session, June 14, 2022	https://perma.cc/T5EK-5E5Z

Jurisdiction	Type of Source	Citation	URL
		An Act to enact the Consumer Privacy Protection Act, the Personal Information and Data Protection Tribunal Act and the Artificial Intelligence and Data Act and to make consequential and related amendments to other Acts (Bill C-27), 44th Parliament, 1st Session, June 16, 2022	https://perma.cc/594V-V3UN
		Personal Information Protection and Electronic Documents Act, S.C. 2000, c. 5	https://perma.cc/ZB9S-BR99
European Union	Treaty	Charter of Fundamental Rights of the European Union (EU Charter)	https://perma.cc/PAX8-4MYJ
		Treaty on European Union (consolidated version) (TEU)	https://perma.cc/9E8Y-B6C5
		Treaty on the Functioning of the European Union (consolidated version) (TFEU)	https://perma.cc/FM38-RYTH
	Legislative Act	Cybersecurity Act (CSA)	https://perma.cc/8E4S-2BPJ
		Digital Services Act (DSA)	https://perma.cc/Y5S3-Z7YX
		General Data Protection Regulation (GDPR)	https://perma.cc/7Y47-L7XX
		Network and Information Security (NIS) Directive	https://perma.cc/JH4W-FHFB
		NIS 2 Directive	https://perma.cc/EGT7-7Q3F
		Proposal for a Regulation of the European Parliament and of the Council Laying Down Harmonised Rules on Artificial Intelligence (Artificial Intelligence Act) and Amending Certain Union Legislative Acts (Draft AI Act)	https://perma.cc/RWT9-9D97

Jurisdiction	Type of Source	Citation	URL
		Proposal for a Regulation of the European Parliament and of the Council on Horizontal Cybersecurity Requirements for Products with Digital Elements and Amending Regulation (EU) 2019/1020 (Cyber Resilience Act, CRA)	https://perma.cc/N2TV-ZJRD
		Standardization Regulation (consolidated version)	https://perma.cc/7NR3-DBYA
New Zealand	Statute	Crimes Act 1961	https://perma.cc/WAE7-RRQ8
		Fair Trading Act 1986	https://perma.cc/3F6Y-BEEU
		Harmful Digital Communications Act 2015	https://perma.cc/7M2A-DLMQ
		Human Rights Act 1993	https://perma.cc/XA7S-4HL4
		Intelligence and Security Act 2017	https://perma.cc/PVT7-BQPH
		New Zealand Bill of Rights Act 1990	https://perma.cc/PT9Q-UYVD
		Privacy Act 2020	https://perma.cc/UQ39-RZSA
		Telecommunications (Interception Capability and Security) Act 2013	https://perma.cc/YL3J-AEZQ
United Kingdom	Statute	Competition Act 1998, c. 41	https://perma.cc/DX9D-WQJU
		Data Protection Act 2018, c. 12	https://perma.cc/5DMR-6FZV
		Equality Act 2010, c. 15 (Great Britain)	https://perma.cc/52EB-2DQ2

Safety and Security of Artificial Intelligence Systems: Table of Primary Sources

Jurisdiction	Type of Source	Citation	URL
		National Security and Investment Act 2021, c. 25	https://perma.cc/9VHY-B8UB
	Regulation	Medical Devices Regulations 2002, SI 2002/618	https://perma.cc/4FSR-SRHU
		National Security and Investment Act 2021 (Notifiable Acquisition) (Specification of Qualifying Entities) Regulations 2021, SI 2021/1264	https://perma.cc/3TPH-Y6YK